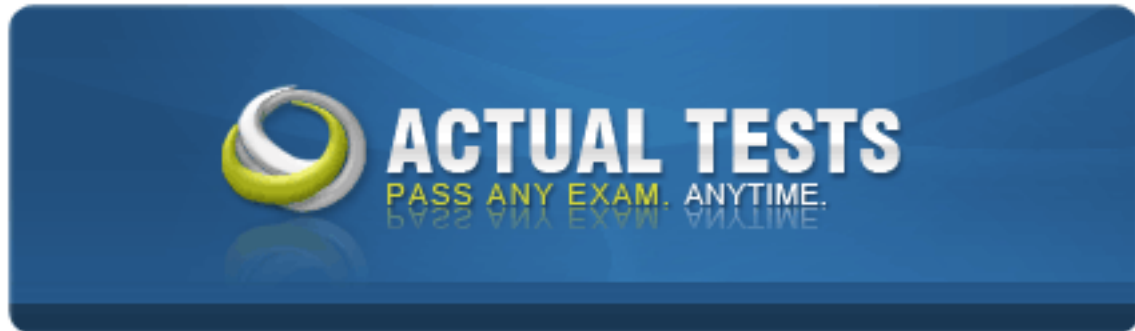


Amazon AWS Certified Security - Specialty



AWS Certified Security Specialty

Version: 10.0

QUESTION NO: 1

The Security team believes that a former employee may have gained unauthorized access to AWS resources sometime in the past 3 months by using an identified access key.

What approach would enable the Security team to find out what the former employee may have done within AWS?

A.

Use the AWS CloudTrail console to search for user activity.

B.

Use the Amazon CloudWatch Logs console to filter CloudTrail data by user.

C.

Use AWS Config to see what actions were taken by the user.

D.

Use Amazon Athena to query CloudTrail logs stored in Amazon S3.

Answer: A

Explanation:

QUESTION NO: 2

The Security Engineer implemented a new vault lock policy for 10TB of data and called initiate-vault-lock 12 hours ago. The Audit team identified a typo that is allowing incorrect access to the vault.

What is the MOST cost-effective way to correct this?

A.

Call the abort-vault-lock operation, fix the typo, and call the initiate-vault-lock again.

B.

Copy the vault data to Amazon S3, delete the vault, and create a new vault with the data.

C.

Update the policy, keeping the vault lock in place.

D.

Update the policy and call initiate-vault-lock again to apply the new policy.

Answer: A

Explanation:

QUESTION NO: 3

A company wants to control access to its AWS resources by using identities and groups that are defined in its existing Microsoft Active Directory.

What must the company create in its AWS account to map permissions for AWS services to Active Directory user attributes?

- A.**
AWS IAM groups
- B.**
AWS IAM users
- C.**
AWS IAM roles
- D.**
AWS IAM access keys

Answer: C

Reference:

<https://aws.amazon.com/blogs/security/how-to-connect-your-on-premises-active-directory-to-aws-using-ad-connector/>

QUESTION NO: 4

A company has contracted with a third party to audit several AWS accounts. To enable the audit, cross-account IAM roles have been created in each account targeted for audit. The Auditor is having trouble accessing some of the accounts.

Which of the following may be causing this problem? (Choose three.)

- A.**

The external ID used by the Auditor is missing or incorrect.

B.

The Auditor is using the incorrect password.

C.

The Auditor has not been granted sts:AssumeRole for the role in the destination account.

D.

The Amazon EC2 role used by the Auditor must be set to the destination account role.

E.

The secret key used by the Auditor is missing or incorrect.

F.

The role ARN used by the Auditor is missing or incorrect.

Answer: C,E,F

Reference:

<https://aws.amazon.com/ru/blogs/security/how-to-use-external-id-when-granting-access-to-your-aws-resources/>

QUESTION NO: 5

Compliance requirements state that all communications between company on-premises hosts and EC2 instances be encrypted in transit. Hosts use custom proprietary protocols for their communication, and EC2 instances need to be fronted by a load balancer for increased availability.

Which of the following solutions will meet these requirements?

A.

Offload SSL termination onto an SSL listener on a Classic Load Balancer, and use a TCP connection between the load balancer and the EC2 instances.

B.

Route all traffic through a TCP listener on a Classic Load Balancer, and terminate the TLS connection on the EC2 instances.

C.

Create an HTTPS listener using an Application Load Balancer, and route all of the communication through that load balancer.

D.

Offload SSL termination onto an SSL listener using an Application Load Balancer, and re-spawn and SSL connection between the load balancer and the EC2 instances.

Answer: B

Explanation:

QUESTION NO: 6

An application is currently secured using network access control lists and security groups. Web servers are located in public subnets behind an Application Load Balancer (ALB); application servers are located in private subnets.

How can edge security be enhanced to safeguard the Amazon EC2 instances against attack? (Choose two.)

A.

Configure the application's EC2 instances to use NAT gateways for all inbound traffic.

B.

Move the web servers to private subnets without public IP addresses.

C.

Configure AWS WAF to provide DDoS attack protection for the ALB.

D.

Require all inbound network traffic to route through a bastion host in the private subnet.

E.

Require all inbound and outbound network traffic to route through an AWS Direct Connect connection.

Answer: B,C

Explanation:

QUESTION NO: 7

A Security Administrator is restricting the capabilities of company root user accounts. The company uses AWS Organizations and has enabled it for all feature sets, including consolidated

billing. The top-level account is used for billing and administrative purposes, not for operational AWS resource purposes.

How can the Administrator restrict usage of member root user accounts across the organization?

A.

Disable the use of the root user account at the organizational root. Enable multi-factor authentication of the root user account for each organizational member account.

B.

Configure IAM user policies to restrict root account capabilities for each Organizations member account.

C.

Create an organizational unit (OU) in Organizations with a service control policy that controls usage of the root user. Add all operational accounts to the new OU.

D.

Configure AWS CloudTrail to integrate with Amazon CloudWatch Logs and then create a metric filter for RootAccountUsage.

Answer: C

Reference:

https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_about-scps.html

QUESTION NO: 8

A Systems Engineer has been tasked with configuring outbound mail through Simple Email Service (SES) and requires compliance with current TLS standards.

The mail application should be configured to connect to which of the following endpoints and corresponding ports?

A.

email.us-east-1.amazonaws.com over port 8080

B.

email-pop3.us-east-1.amazonaws.com over port 995

C.

email-smtp.us-east-1.amazonaws.com over port 587

D.

email-imap.us-east-1.amazonaws.com over port 993

Answer: C

Reference:

<https://docs.aws.amazon.com/ses/latest/DeveloperGuide/smtp-connect.html>

QUESTION NO: 9

A threat assessment has identified a risk whereby an internal employee could exfiltrate sensitive data from production host running inside AWS (Account 1). The threat was documented as follows:

Threat description: A malicious actor could upload sensitive data from Server X by configuring credentials for an AWS account (Account 2) they control and uploading data to an Amazon S3 bucket within their control.

Server X has outbound internet access configured via a proxy server. Legitimate access to S3 is required so that the application can upload encrypted files to an S3 bucket. Server X is currently using an IAM instance role. The proxy server is not able to inspect any of the server communication due to TLS encryption.

Which of the following options will mitigate the threat? (Choose two.)

A.

Bypass the proxy and use an S3 VPC endpoint with a policy that whitelists only certain S3 buckets within Account 1.

B.

Block outbound access to public S3 endpoints on the proxy server.

C.

Configure Network ACLs on Server X to deny access to S3 endpoints.

D.

Modify the S3 bucket policy for the legitimate bucket to allow access only from the public IP addresses associated with the application server.

E.

Remove the IAM instance role from the application server and save API access keys in a trusted and encrypted application config file.

Answer: A,C

Explanation:

QUESTION NO: 10

A company will store sensitive documents in three Amazon S3 buckets based on a data classification scheme of "Sensitive," "Confidential," and "Restricted." The security solution must meet all of the following requirements:

Each object must be encrypted using a unique key.

Items that are stored in the "Restricted" bucket require two-factor authentication for decryption.

AWS KMS must automatically rotate encryption keys annually.

Which of the following meets these requirements?

A.

Create a Customer Master Key (CMK) for each data classification type, and enable the rotation of it annually. For the "Restricted" CMK, define the MFA policy within the key policy. Use S3 SSE-KMS to encrypt the objects.

B.

Create a CMK grant for each data classification type with EnableKeyRotation and MultiFactorAuthPresent set to true. S3 can then use the grants to encrypt each object with a unique CMK.

C.

Create a CMK for each data classification type, and within the CMK policy, enable rotation of it annually, and define the MFA policy. S3 can then create DEK grants to uniquely encrypt each object within the S3 bucket.

D.

Create a CMK with unique imported key material for each data classification type, and rotate them annually. For the "Restricted" key material, define the MFA policy in the key policy. Use S3 SSE-KMS to encrypt the objects.

Answer: A

Explanation:

QUESTION NO: 11

An organization wants to deploy a three-tier web application whereby the application servers run on Amazon EC2 instances. These EC2 instances need access to credentials that they will use to authenticate their SQL connections to an Amazon RDS DB instance. Also, AWS Lambda functions must issue queries to the RDS database by using the same database credentials.

The credentials must be stored so that the EC2 instances and the Lambda functions can access them. No other access is allowed. The access logs must record when the credentials were accessed and by whom.

What should the Security Engineer do to meet these requirements?

A.

Store the database credentials in AWS Key Management Service (AWS KMS). Create an IAM role with access to AWS KMS by using the EC2 and Lambda service principals in the role's trust policy. Add the role to an EC2 instance profile. Attach the instance profile to the EC2 instances. Set up Lambda to use the new role for execution.

B.

Store the database credentials in AWS KMS. Create an IAM role with access to KMS by using the EC2 and Lambda service principals in the role's trust policy. Add the role to an EC2 instance profile. Attach the instance profile to the EC2 instances and the Lambda function.

C.

Store the database credentials in AWS Secrets Manager. Create an IAM role with access to Secrets Manager by using the EC2 and Lambda service principals in the role's trust policy. Add the role to an EC2 instance profile. Attach the instance profile to the EC2 instances and the Lambda function.

D.

Store the database credentials in AWS Secrets Manager. Create an IAM role with access to Secrets Manager by using the EC2 and Lambda service principals in the role's trust policy. Add the role to an EC2 instance profile. Attach the instance profile to the EC2 instances. Set up Lambda to use the new role for execution.

Answer: D

Explanation:

QUESTION NO: 12

A company has a customer master key (CMK) with imported key materials. Company policy requires that all encryption keys must be rotated every year.

What can be done to implement the above policy?

- A.**
Enable automatic key rotation annually for the CMK.
- B.**
Use AWS Command Line Interface to create an AWS Lambda function to rotate the existing CMK annually.
- C.**
Import new key material to the existing CMK and manually rotate the CMK.
- D.**
Create a new CMK, import new key material to it, and point the key alias to the new CMK.

Answer: D

Explanation:

QUESTION NO: 13

A water utility company uses a number of Amazon EC2 instances to manage updates to a fleet of 2,000 Internet of Things (IoT) field devices that monitor water quality. These devices each have unique access credentials.

An operational safety policy requires that access to specific credentials is independently auditable.

What is the MOST cost-effective way to manage the storage of credentials?

- A.**
Use AWS Systems Manager to store the credentials as Secure Strings Parameters. Secure by using an AWS KMS key.
- B.**
Use AWS Key Management System to store a master key, which is used to encrypt the credentials. The encrypted credentials are stored in an Amazon RDS instance.
- C.**

Use AWS Secrets Manager to store the credentials.

D.

Store the credentials in a JSON file on Amazon S3 with server-side encryption.

Answer: A

Explanation:

QUESTION NO: 14

An organization is using Amazon CloudWatch Logs with agents deployed on its Linux Amazon EC2 instances. The agent configuration files have been checked and the application log files to be pushed are configured correctly. A review has identified that logging from specific instances is missing.

Which steps should be taken to troubleshoot the issue? (Choose two.)

A.

Use an EC2 run command to confirm that the “awslogs” service is running on all instances.

B.

Verify that the permissions used by the agent allow creation of log groups/streams and to put log events.

C.

Check whether any application log entries were rejected because of invalid time stamps by reviewing /var/cwlogs/rejects.log.

D.

Check that the trust relationship grants the service “cwlogs.amazonaws.com” permission to write objects to the Amazon S3 staging bucket.

E.

Verify that the time zone on the application servers is in UTC.

Answer: B,C

Explanation:

QUESTION NO: 15

A Security Engineer must design a solution that enables the Incident Response team to audit for changes to a user's IAM permissions in the case of a security incident.

How can this be accomplished?

A.

Use AWS Config to review the IAM policy assigned to users before and after the incident.

B.

Run the GenerateCredentialReport via the AWS CLI, and copy the output to Amazon S3 daily for auditing purposes.

C.

Copy AWS CloudFormation templates to S3, and audit for changes from the template.

D.

Use Amazon EC2 Systems Manager to deploy images, and review AWS CloudTrail logs for changes.

Answer: A

Explanation:

QUESTION NO: 16

A company has complex connectivity rules governing ingress, egress, and communications between Amazon EC2 instances. The rules are so complex that they cannot be implemented within the limits of the maximum number of security groups and network access control lists (network ACLs).

What mechanism will allow the company to implement all required network rules without incurring additional cost?

A.

Configure AWS WAF rules to implement the required rules.

B.

Use the operating system built-in, host-based firewall to implement the required rules.

C.

Use a NAT gateway to control ingress and egress according to the requirements.

D.

Launch an EC2-based firewall product from the AWS Marketplace, and implement the required

rules in that product.

Answer: B

Explanation:

QUESTION NO: 17

An IAM user with full EC2 permissions could not start an Amazon EC2 instance after it was stopped for a maintenance task. Upon starting the instance, the instance state would change to "Pending", but after a few seconds, it would switch back to "Stopped".

An inspection revealed that the instance has attached Amazon EBS volumes that were encrypted by using a Customer Master Key (CMK). When these encrypted volumes were detached, the IAM user was able to start the EC2 instances.

The IAM user policy is as follows:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        <Action>
      ],
      "Resource": [
        "arn:aws:kms:us-east-1:012345678910:key/ebs-encryption-key"
      ]
      <CONDITION>
    }
  ]
}
```

What additional items need to be added to the IAM user policy? (Choose two.)

A.
kms:GenerateDataKey

B.
kms:Decrypt

C.

kms:CreateGrant

D.

“Condition”: {

“Bool”: {

“kms:ViaService”: “ec2.us-west-2.amazonaws.com”

}

}

E.

“Condition”: {

“Bool”: {

“kms:GrantIsForAWSResource”: true

}

}

Answer: C,E

Explanation:

QUESTION NO: 18

A Security Administrator has a website hosted in Amazon S3. The Administrator has been given the following requirements:

Users may access the website by using an Amazon CloudFront distribution.

Users may not access the website directly by using an Amazon S3 URL.

Which configurations will support these requirements? (Choose two.)

A.

Associate an origin access identity with the CloudFront distribution.

B.

Implement a “Principal”: “cloudfront.amazonaws.com” condition in the S3 bucket policy.

C.

Modify the S3 bucket permissions so that only the origin access identity can access the bucket contents.

D.

Implement security groups so that the S3 bucket can be accessed only by using the intended CloudFront distribution.

E.

Configure the S3 bucket policy so that it is accessible only through VPC endpoints, and place the CloudFront distribution into the specified VPC.

Answer: A,C

Explanation:

QUESTION NO: 19

A Security Engineer has created an Amazon CloudWatch event that invokes an AWS Lambda function daily. The Lambda function runs an Amazon Athena query that checks AWS CloudTrail logs in Amazon S3 to detect whether any IAM user accounts or credentials have been created in the past 30 days. The results of the Athena query are created in the same S3 bucket. The Engineer runs a test execution of the Lambda function via the AWS Console, and the function runs successfully.

After several minutes, the Engineer finds that his Athena query has failed with the error message: "Insufficient Permissions". The IAM permissions of the Security Engineer and the Lambda function are shown below:

Security Engineer

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "s3:*",
        "iam:*",
        "lambda:*",
        "athena:Get*",
        "athena:List*",
        "cloudwatch:*"
      ],
      "Resource": "*"
    }
  ]
}
```

Lambda function execution role

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "athena:*",
        "cloudwatch:*"
      ],
      "Resource": "*"
    }
  ]
}
```


What is causing the error?

- A.**
The Lambda function does not have permissions to start the Athena query execution.
- B.**
The Security Engineer does not have permissions to start the Athena query execution.
- C.**
The Athena service does not support invocation through Lambda.
- D.**
The Lambda function does not have permissions to access the CloudTrail S3 bucket.

Answer: B

Explanation:

QUESTION NO: 20

A company requires that IP packet data be inspected for invalid or malicious content.

Which of the following approaches achieve this requirement? (Choose two.)

- A.**
Configure a proxy solution on Amazon EC2 and route all outbound VPC traffic through it. Perform inspection within proxy software on the EC2 instance.
- B.**
Configure the host-based agent on each EC2 instance within the VPC. Perform inspection within the host-based agent.
- C.**
Enable VPC Flow Logs for all subnets in the VPC. Perform inspection from the Flow Log data within Amazon CloudWatch Logs.
- D.**
Configure Elastic Load Balancing (ELB) access logs. Perform inspection from the log data within the ELB access log files.
- E.**
Configure the CloudWatch Logs agent on each EC2 instance within the VPC. Perform inspection from the log data within CloudWatch Logs.

Answer: A,B

Explanation:

QUESTION NO: 21

An organization has a system in AWS that allows a large number of remote workers to submit data files. File sizes vary from a few kilobytes to several megabytes. A recent audit highlighted a concern that data files are not encrypted while in transit over untrusted networks.

Which solution would remediate the audit finding while minimizing the effort required?

A.

Upload an SSL certificate to IAM, and configure Amazon CloudFront with the passphrase for the private key.

B.

Call KMS.Encrypt() in the client, passing in the data file contents, and call KMS.Decrypt() server-side.

C.

Use AWS Certificate Manager to provision a certificate on an Elastic Load Balancing in front of the web service's servers.

D.

Create a new VPC with an Amazon VPC VPN endpoint, and update the web service's DNS record.

Answer: C

Explanation:

QUESTION NO: 22

Which option for the use of the AWS Key Management Service (KMS) supports key management best practices that focus on minimizing the potential scope of data exposed by a possible future key compromise?

A.

Use KMS automatic key rotation to replace the master key, and use this new master key for future encryption operations without re-encrypting previously encrypted data.

B.

Generate a new Customer Master Key (CMK), re-encrypt all existing data with the new CMK, and use it for all future encryption operations.

C.

Change the CMK alias every 90 days, and update key-calling applications with the new key alias.

D.

Change the CMK permissions to ensure that individuals who can provision keys are not the same individuals who can use the keys.

Answer: A

Explanation:

QUESTION NO: 23

A Security Engineer must enforce the use of only Amazon EC2, Amazon S3, Amazon RDS, Amazon DynamoDB, and AWS STS in specific accounts.

What is a scalable and efficient approach to meet this requirement?

A.

Set up an AWS Organizations hierarchy, and replace the FullAWSAccess policy with the following Service Control Policy for the governed organization units:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "s3:*", "sts:*", "dynamodb:*", "rds:*", "ec2:*",
      ],
      "Effect": "Allow",
      "Resource": "*"
    }
  ]
}
```

B.

Create multiple IAM users for the regulated accounts, and attach the following policy statement to restrict services as required:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": "*",
      "Effect": "Allow",
      "Resource": "*"
    },
    {
      "NotAction": [
        "dynamodb:*", "rds:*", "ec2:*",
        "s3:*", "sts:*"
      ],
      "Effect": "Deny",
      "Resource": "*"
    }
  ]
}
```

C.

Set up an Organizations hierarchy, replace the global FullAWSAccess with the following Service Control Policy at the top level:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "dynamodb:*", "rds:*", "ec2:*",
        "s3:*", "sts:*"
      ],
      "Effect": "Allow",
      "Resource": "*"
    }
  ]
}
```

D.

Set up all users in the Active Directory for federated access to all accounts in the company. Associate Active Directory groups with IAM groups, and attach the following policy statement to

restrict services as required:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": *
      "Effect": "Allow",
      "Resource": "*"
    }
    {
      "NotAction": [
        "dynamodb:*", "rds:*", "ec2:*",
"s3:*", "sts:*"
      ],
      "Effect": "Deny ",
      "Resource": "*"
    }
  ]
}
```

Answer: A

Explanation:

QUESTION NO: 24

A company's database developer has just migrated an Amazon RDS database credential to be stored and managed by AWS Secrets Manager. The developer has also enabled rotation of the credential within the Secrets Manager console and set the rotation to change every 30 days.

After a short period of time, a number of existing applications have failed with authentication errors.

What is the MOST likely cause of the authentication errors?

A.

Migrating the credential to RDS requires that all access come through requests to the Secrets

Manager.

B.

Enabling rotation in Secrets Manager causes the secret to rotate immediately, and the applications are using the earlier credential.

C.

The Secrets Manager IAM policy does not allow access to the RDS database.

D.

The Secrets Manager IAM policy does not allow access for the applications.

Answer: A

Explanation:

QUESTION NO: 25

A Security Engineer launches two Amazon EC2 instances in the same Amazon VPC but in separate Availability Zones. Each instance has a public IP address and is able to connect to external hosts on the internet. The two instances are able to communicate with each other by using their private IP addresses, but they are not able to communicate with each other when using their public IP addresses.

Which action should the Security Engineer take to allow communication over the public IP addresses?

A.

Associate the instances to the same security groups.

B.

Add 0.0.0.0/0 to the egress rules of the instance security groups.

C.

Add the instance IDs to the ingress rules of the instance security groups.

D.

Add the public IP addresses to the ingress rules of the instance security groups.

Answer: D

Explanation:

QUESTION NO: 26

The Security Engineer is managing a web application that processes highly sensitive personal information. The application runs on Amazon EC2. The application has strict compliance requirements, which instruct that all incoming traffic to the application is protected from common web exploits and that all outgoing traffic from the EC2 instances is restricted to specific whitelisted URLs.

Which architecture should the Security Engineer use to meet these requirements?

A.

Use AWS Shield to scan inbound traffic for web exploits. Use VPC Flow Logs and AWS Lambda to restrict egress traffic to specific whitelisted URLs.

B.

Use AWS Shield to scan inbound traffic for web exploits. Use a third-party AWS Marketplace solution to restrict egress traffic to specific whitelisted URLs.

C.

Use AWS WAF to scan inbound traffic for web exploits. Use VPC Flow Logs and AWS Lambda to restrict egress traffic to specific whitelisted URLs.

D.

Use AWS WAF to scan inbound traffic for web exploits. Use a third-party AWS Marketplace solution to restrict egress traffic to specific whitelisted URLs.

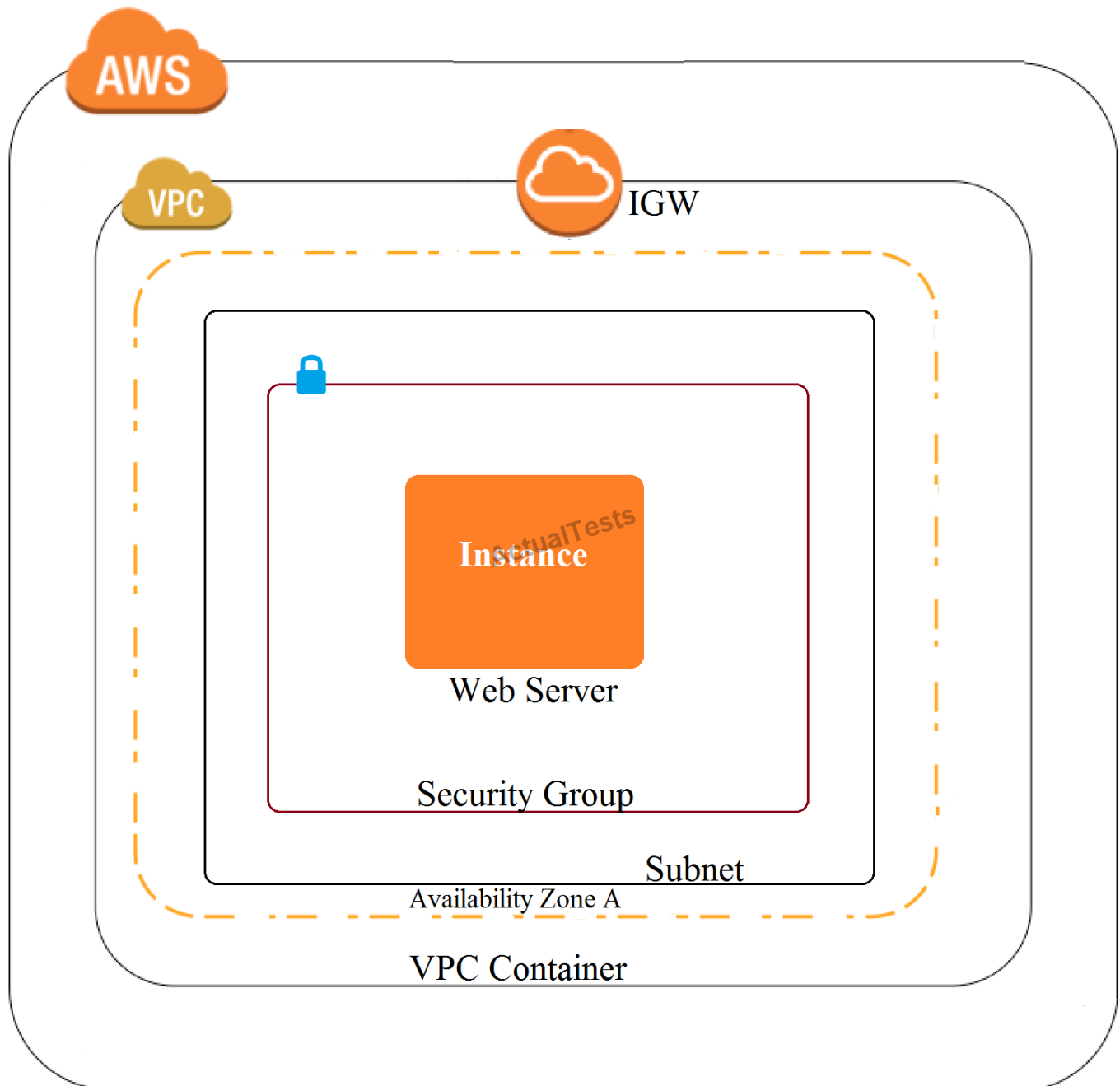
Answer: D

Explanation:

QUESTION NO: 27

A company recently experienced a DDoS attack that prevented its web server from serving content. The website is static and hosts only HTML, CSS, and PDF files that users download.

Based on the architecture shown in the image, what is the BEST way to protect the site against future attacks while minimizing the ongoing operational overhead?



A.

Move all the files to an Amazon S3 bucket. Have the web server serve the files from the S3 bucket.

B.

Launch a second Amazon EC2 instance in a new subnet. Launch an Application Load Balancer in front of both instances.

C.

Launch an Application Load Balancer in front of the EC2 instance. Create an Amazon CloudFront distribution in front of the Application Load Balancer.

D.

Move all the files to an S3 bucket. Create a CloudFront distribution in front of the bucket and

terminate the web server.

Answer: A

Explanation:

QUESTION NO: 28

The Information Technology department has stopped using Classic Load Balancers and switched to Application Load Balancers to save costs. After the switch, some users on older devices are no longer able to connect to the website.

What is causing this situation?

A.

Application Load Balancers do not support older web browsers.

B.

The Perfect Forward Secrecy settings are not configured correctly.

C.

The intermediate certificate is installed within the Application Load Balancer.

D.

The cipher suites on the Application Load Balancers are blocking connections.

Answer: D

Explanation:

QUESTION NO: 29

A security team is responsible for reviewing AWS API call activity in the cloud environment for security violations. These events must be recorded and retained in a centralized location for both current and future AWS regions.

What is the SIMPLEST way to meet these requirements?

A.

Enable AWS Trusted Advisor security checks in the AWS Console, and report all security incidents for all regions.

B.

Enable AWS CloudTrail by creating individual trails for each region, and specify a single Amazon S3 bucket to receive log files for later analysis.

C.

Enable AWS CloudTrail by creating a new trail and applying the trail to all regions. Specify a single Amazon S3 bucket as the storage location.

D.

Enable Amazon CloudWatch logging for all AWS services across all regions, and aggregate them to a single Amazon S3 bucket for later analysis.

Answer: B

Reference:

<https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-create-a-trail-using-the-console-first-time.html>

QUESTION NO: 30

A Security Administrator is performing a log analysis as a result of a suspected AWS account compromise. The Administrator wants to analyze suspicious AWS CloudTrail log files but is overwhelmed by the volume of audit logs being generated.

What approach enables the Administrator to search through the logs MOST efficiently?

A.

Implement a "write-only" CloudTrail event filter to detect any modifications to the AWS account resources.

B.

Configure Amazon Macie to classify and discover sensitive data in the Amazon S3 bucket that contains the CloudTrail audit logs.

C.

Configure Amazon Athena to read from the CloudTrail S3 bucket and query the logs to examine account activities.

D.

Enable Amazon S3 event notifications to trigger an AWS Lambda function that sends an email alarm when there are new CloudTrail API entries.

Answer: C

Reference:

<https://docs.aws.amazon.com/athena/latest/ug/cloudtrail-logs.html>

QUESTION NO: 31

During a recent security audit, it was discovered that multiple teams in a large organization have placed restricted data in multiple Amazon S3 buckets, and the data may have been exposed. The auditor has requested that the organization identify all possible objects that contain personally identifiable information (PII) and then determine whether this information has been accessed.

What solution will allow the Security team to complete this request?

A.

Using Amazon Athena, query the impacted S3 buckets by using the PII query identifier function. Then, create a new Amazon CloudWatch metric for Amazon S3 object access to alert when the objects are accessed.

B.

Enable Amazon Macie on the S3 buckets that were impacted, then perform data classification. For identified objects that contain PII, use the research function for auditing AWS CloudTrail logs and S3 bucket logs for GET operations.

C.

Enable Amazon GuardDuty and enable the PII rule set on the S3 buckets that were impacted, then perform data classification. Using the PII findings report from GuardDuty, query the S3 bucket logs by using Athena for GET operations.

D.

Enable Amazon Inspector on the S3 buckets that were impacted, then perform data classification. For identified objects that contain PII, query the S3 bucket logs by using Athena for GET operations.

Answer: B

Explanation:

QUESTION NO: 32

During a recent internal investigation, it was discovered that all API logging was disabled in a

production account, and the root user had created new API keys that appear to have been used several times.

What could have been done to detect and automatically remediate the incident?

A.

Using Amazon Inspector, review all of the API calls and configure the inspector agent to leverage SNS topics to notify security of the change to AWS CloudTrail, and revoke the new API keys for the root user.

B.

Using AWS Config, create a config rule that detects when AWS CloudTrail is disabled, as well as any calls to the root user create-api-key. Then use a Lambda function to re-enable CloudTrail logs and deactivate the root API keys.

C.

Using Amazon CloudWatch, create a CloudWatch event that detects AWS CloudTrail deactivation and a separate Amazon Trusted Advisor check to automatically detect the creation of root API keys. Then use a Lambda function to enable AWS CloudTrail and deactivate the root API keys.

D.

Using Amazon CloudTrail, create a new CloudTrail event that detects the deactivation of CloudTrail logs, and a separate CloudTrail event that detects the creation of root API keys. Then use a Lambda function to enable CloudTrail and deactivate the root API keys.

Answer: C

Explanation:

QUESTION NO: 33

An application has a requirement to be resilient across not only Availability Zones within the application's primary region but also be available within another region altogether.

Which of the following supports this requirement for AWS resources that are encrypted by AWS KMS?

A.

Copy the application's AWS KMS CMK from the source region to the target region so that it can be used to decrypt the resource after it is copied to the target region.

B.

Configure AWS KMS to automatically synchronize the CMK between regions so that it can be

used to decrypt the resource in the target region.

C.

Use AWS services that replicate data across regions, and re-wrap the data encryption key created in the source region by using the CMK in the target region so that the target region's CMK can decrypt the database encryption key.

D.

Configure the target region's AWS service to communicate with the source region's AWS KMS so that it can decrypt the resource in the target region.

Answer: C

Explanation:

QUESTION NO: 34

An organization policy states that all encryption keys must be automatically rotated every 12 months.

Which AWS Key Management Service (KMS) key type should be used to meet this requirement?

A.

AWS managed Customer Master Key (CMK)

B.

Customer managed CMK with AWS generated key material

C.

Customer managed CMK with imported key material

D.

AWS managed data key

Answer: A

Reference:

<https://docs.aws.amazon.com/kms/latest/developerguide/rotate-keys.html>

QUESTION NO: 35

A Security Engineer received an AWS Abuse Notice listing EC2 instance IDs that are reportedly abusing other hosts.

Which action should the Engineer take based on this situation? (Choose three.)

- A.**
Use AWS Artifact to capture an exact image of the state of each instance.
- B.**
Create EBS Snapshots of each of the volumes attached to the compromised instances.
- C.**
Capture a memory dump.
- D.**
Log in to each instance with administrative credentials to restart the instance.
- E.**
Revoke all network ingress and egress except for to/from a forensics workstation.
- F.**
Run Auto Recovery for Amazon EC2.

Answer: B,C,E

Explanation:

QUESTION NO: 36

A Security Administrator is configuring an Amazon S3 bucket and must meet the following security requirements:

- Encryption in transit
- Encryption at rest
- Logging of all object retrievals in AWS CloudTrail

Which of the following meet these security requirements? (Choose three.)

- A.**
Specify "aws:SecureTransport": "true" within a condition in the S3 bucket policy.
- B.**

Enable a security group for the S3 bucket that allows port 443, but not port 80.

C.

Set up default encryption for the S3 bucket.

D.

Enable Amazon CloudWatch Logs for the AWS account.

E.

Enable API logging of data events for all S3 objects.

F.

Enable S3 object versioning for the S3 bucket.

Answer: A,C,E

Reference:

<https://docs.aws.amazon.com/AmazonCloudWatch/latest/events/log-s3-data-events.html>

QUESTION NO: 37

What is the function of the following AWS Key Management Service (KMS) key policy attached to a customer master key (CMK)?

```
{
  "Effect": "Allow",
  "Principal": {
    "AWS": "arn:aws:iam::111122223333:user/ExampleUser"
  },
  "Action": [
    "kms:Encrypt",
    "kms:Decrypt",
    "kms:GenerateDataKey*",
    "kms:CreateGrant",
    "kms:ListGrants"
  ],
  "Resource": "*",
  "Condition": {
    "StringEquals": {
      "kms:ViaService": [
        "workmail.us-west-2.amazonaws.com",
        "ses.us-west-2.amazonaws.com"
      ]
    }
  }
}
```

A.

The Amazon WorkMail and Amazon SES services have delegated KMS encrypt and decrypt permissions to the ExampleUser principal in the 111122223333 account.

B.

The ExampleUser principal can transparently encrypt and decrypt email exchanges specifically between ExampleUser and AWS.

C.

The CMK is to be used for encrypting and decrypting only when the principal is ExampleUser and the request comes from WorkMail or SES in the specified region.

D.

The key policy allows WorkMail or SES to encrypt or decrypt on behalf of the user for any CMK in the account.

Answer: C

Reference:

<https://docs.aws.amazon.com/kms/latest/developerguide/policy-conditions.html#conditions-kms-via-service>

QUESTION NO: 38

A Security Engineer who was reviewing AWS Key Management Service (AWS KMS) key policies found this statement in each key policy in the company AWS account.

```
{  
  "Sid": "Enable IAM User Permissions",  
  "Effect": "Allow",  
  "Principal": {  
    "AWS": "arn:aws:iam::111122223333:root"  
  },  
  "Action": "kms:*",  
  "Resource": "*"   
}
```

What does the statement allow?

A.

All principals from all AWS accounts to use the key.

B.

Only the root user from account 111122223333 to use the key.

C.

All principals from account 111122223333 to use the key but only on Amazon S3.

D.

Only principals from account 111122223333 that have an IAM policy applied that grants access to this key to use the key.

Answer: D

Reference:

<https://docs.aws.amazon.com/kms/latest/developerguide/key-policies.html>

QUESTION NO: 39

A Software Engineer wrote a customized reporting service that will run on a fleet of Amazon EC2 instances. The company security policy states that application logs for the reporting service must be centrally collected.

What is the MOST efficient way to meet these requirements?

A.

Write an AWS Lambda function that logs into the EC2 instance to pull the application logs from the EC2 instance and persists them into an Amazon S3 bucket.

B.

Enable AWS CloudTrail logging for the AWS account, create a new Amazon S3 bucket, and then configure Amazon CloudWatch Logs to receive the application logs from CloudTrail.

C.

Create a simple cron job on the EC2 instances that synchronizes the application logs to an Amazon S3 bucket by using rsync.

D.

Install the Amazon CloudWatch Logs Agent on the EC2 instances, and configure it to send the application logs to CloudWatch Logs.

Answer: D

Reference:

<https://aws.amazon.com/blogs/devops/new-how-to-better-monitor-your-custom-application-metrics-using-amazon-cloudwatch-agent/>

QUESTION NO: 40

A Security Engineer is trying to determine whether the encryption keys used in an AWS service are in compliance with certain regulatory standards.

Which of the following actions should the Engineer perform to get further guidance?

- A.**
Read the AWS Customer Agreement.
- B.**
Use AWS Artifact to access AWS compliance reports.
- C.**
Post the question on the AWS Discussion Forums.
- D.**
Run AWS Config and evaluate the configuration outputs.

Answer: B

Explanation:

QUESTION NO: 41

The Development team receives an error message each time the team members attempt to encrypt or decrypt a Secure String parameter from the SSM Parameter Store by using an AWS KMS customer managed key (CMK).

Which CMK-related issues could be responsible? (Choose two.)

- A.**
The CMK specified in the application does not exist.
- B.**
The CMK specified in the application is currently in use.
- C.**
The CMK specified in the application is using the CMK KeyID instead of CMK Amazon Resource Name.
- D.**
The CMK specified in the application is not enabled.
- E.**
The CMK specified in the application is using an alias.

Answer: A,D

Explanation:

QUESTION NO: 42

An application has been written that publishes custom metrics to Amazon CloudWatch. Recently, IAM changes have been made on the account and the metrics are no longer being reported.

Which of the following is the LEAST permissive solution that will allow the metrics to be delivered?

A.

Add a statement to the IAM policy used by the application to allow logs:putLogEvents and logs:createLogStream

B.

Modify the IAM role used by the application by adding the CloudWatchFullAccess managed policy.

C.

Add a statement to the IAM policy used by the application to allow cloudwatch:putMetricData.

D.

Add a trust relationship to the IAM role used by the application for cloudwatch.amazonaws.com.

Answer: C

Explanation:

QUESTION NO: 43

A Developer's laptop was stolen. The laptop was not encrypted, and it contained the SSH key used to access multiple Amazon EC2 instances. A Security Engineer has verified that the key has not been used, and has blocked port 22 to all EC2 instances while developing a response plan.

How can the Security Engineer further protect currently running instances?

A.

Delete the key-pair key from the EC2 console, then create a new key pair.

B.

Use the modify-instance-attribute API to change the key on any EC2 instance that is using the key.

C.

Use the EC2 RunCommand to modify the authorized_keys file on any EC2 instance that is using the key.

D.

Update the key pair in any AMI used to launch the EC2 instances, then restart the EC2 instances.

Answer: C

Reference:

<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/ec2-key-pairs.html#delete-key-pair>

QUESTION NO: 44

An organization has tens of applications deployed on thousands of Amazon EC2 instances. During testing, the Application team needs information to let them know whether the network access control lists (network ACLs) and security groups are working as expected.

How can the Application team's requirements be met?

A.

Turn on VPC Flow Logs, send the logs to Amazon S3, and use Amazon Athena to query the logs.

B.

Install an Amazon Inspector agent on each EC2 instance, send the logs to Amazon S3, and use Amazon EMR to query the logs.

C.

Create an AWS Config rule for each network ACL and security group configuration, send the logs to Amazon S3, and use Amazon Athena to query the logs.

D.

Turn on AWS CloudTrail, send the trails to Amazon S3, and use AWS Lambda to query the trails.

Answer: A

Reference:

<https://aws.amazon.com/blogs/aws/vpc-flow-logs-log-and-view-network-traffic-flows/>

QUESTION NO: 45

An application outputs logs to a text file. The logs must be continuously monitored for security

incidents.

Which design will meet the requirements with MINIMUM effort?

A.

Create a scheduled process to copy the component's logs into Amazon S3. Use S3 events to trigger a Lambda function that updates Amazon CloudWatch metrics with the log data. Set up CloudWatch alerts based on the metrics.

B.

Install and configure the Amazon CloudWatch Logs agent on the application's EC2 instance. Create a CloudWatch metric filter to monitor the application logs. Set up CloudWatch alerts based on the metrics.

C.

Create a scheduled process to copy the application log files to AWS CloudTrail. Use S3 events to trigger Lambda functions that update CloudWatch metrics with the log data. Set up CloudWatch alerts based on the metrics.

D.

Create a file watcher that copies data to Amazon Kinesis when the application writes to the log file. Have Kinesis trigger a Lambda function to update Amazon CloudWatch metrics with the log data. Set up CloudWatch alerts based on the metrics.

Answer: A

Explanation:

QUESTION NO: 46

The Security Engineer for a mobile game has to implement a method to authenticate users so that they can save their progress. Because most of the users are part of the same OpenID-Connect compatible social media website, the Security Engineer would like to use that as the identity provider.

Which solution is the SIMPLEST way to allow the authentication of users using their social media identities?

A.

Amazon Cognito

B.

AssumeRoleWithWebIdentity API

C.

Amazon Cloud Directory

D.

Active Directory (AD) Connector

Answer: A

Reference:

<https://docs.aws.amazon.com/cognito/latest/developerguide/cognito-user-pools-identity-provider.html>

QUESTION NO: 47

A Software Engineer is trying to figure out why network connectivity to an Amazon EC2 instance does not appear to be working correctly. Its security group allows inbound HTTP traffic from 0.0.0.0/0, and the outbound rules have not been modified from the default. A custom network ACL associated with its subnet allows inbound HTTP traffic from 0.0.0.0/0 and has no outbound rules.

What would resolve the connectivity issue?

A.

The outbound rules on the security group do not allow the response to be sent to the client on the ephemeral port range.

B.

The outbound rules on the security group do not allow the response to be sent to the client on the HTTP port.

C.

An outbound rule must be added to the network ACL to allow the response to be sent to the client on the ephemeral port range.

D.

An outbound rule must be added to the network ACL to allow the response to be sent to the client on the HTTP port.

Answer: D

Explanation:

QUESTION NO: 48

A Security Engineer has been asked to create an automated process to disable IAM user access keys that are more than three months old.

Which of the following options should the Security Engineer use?

A.

In the AWS Console, choose the IAM service and select "Users". Review the "Access Key Age" column.

B.

Define an IAM policy that denies access if the key age is more than three months and apply to all users.

C.

Write a script that uses the GenerateCredentialReport, GetCredentialReport, and UpdateAccessKey APIs.

D.

Create an Amazon CloudWatch alarm to detect aged access keys and use an AWS Lambda function to disable the keys older than 90 days.

Answer: A

Reference:

https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_access-keys.html

QUESTION NO: 49

The InfoSec team has mandated that in the future only approved Amazon Machine Images (AMIs) can be used.

How can the InfoSec team ensure compliance with this mandate?

A.

Terminate all Amazon EC2 instances and relaunch them with approved AMIs.

B.

Patch all running instances by using AWS Systems Manager.

C.

Deploy AWS Config rules and check all running instances for compliance.

D.

Define a metric filter in Amazon CloudWatch Logs to verify compliance.

Answer: C

Explanation:

QUESTION NO: 50

A pharmaceutical company has digitized versions of historical prescriptions stored on premises. The company would like to move these prescriptions to AWS and perform analytics on the data in them. Any operation with this data requires that the data be encrypted in transit and at rest.

Which application flow would meet the data protection requirements on AWS?

A.

Digitized files -> Amazon Kinesis Data Analytics

B.

Digitized files -> Amazon Kinesis Data Firehose -> Amazon S3 -> Amazon Athena

C.

Digitized files -> Amazon Kinesis Data Streams -> Kinesis Client Library consumer -> Amazon S3 -> Athena

D.

Digitized files -> Amazon Kinesis Data Firehose -> Amazon Elasticsearch

Answer: A

Explanation:

QUESTION NO: 51

The Security Engineer created a new AWS Key Management Service (AWS KMS) key with the following key policy:

```
{  
  "Effect": "Allow",  
  "Principal": {"AWS": "arn:aws:iam::111122223333:root"},  
  "Action": "kms:*",  
  "Resource": "*" }  
}
```

What are the effects of the key policy? (Choose two.)

A.

The policy allows access for the AWS account 111122223333 to manage key access through IAM policies.

B.

The policy allows all IAM users in account 111122223333 to have full access to the KMS key.

C.

The policy allows the root user in account 111122223333 to have full access to the KMS key.

D.

The policy allows the KMS service-linked role in account 111122223333 to have full access to the KMS key.

E.

The policy allows all IAM roles in account 111122223333 to have full access to the KMS key.

Answer: A,B

Explanation:

QUESTION NO: 52

A company uses AWS Organization to manage 50 AWS accounts. The finance staff members log in as AWS IAM users in the FinanceDept AWS account. The staff members need to read the consolidated billing information in the MasterPayer AWS account. They should not be able to view any other resources in the MasterPayer AWS account. IAM access to billing has been enabled in the MasterPayer account.

Which of the following approaches grants the finance staff the permissions they require without granting any unnecessary permissions?

A.

Create an IAM group for the finance users in the FinanceDept account, then attach the AWS managed ReadOnlyAccess IAM policy to the group.

B.

Create an IAM group for the finance users in the MasterPayer account, then attach the AWS managed ReadOnlyAccess IAM policy to the group.

C.

Create an AWS IAM role in the FinanceDept account with the ViewBilling permission, then grant the finance users in the MasterPayer account the permission to assume that role.

D.

Create an AWS IAM role in the MasterPayer account with the ViewBilling permission, then grant the finance users in the FinanceDept account the permission to assume that role.

Answer: D

Explanation:

QUESTION NO: 53

A Solutions Architect is designing a web application that uses Amazon CloudFront, an Elastic Load Balancing Application Load Balancer, and an Auto Scaling group of Amazon EC2 instances. The load balancer and EC2 instances are in the US West (Oregon) region. It has been decided that encryption in transit is necessary by using a customer-branded domain name from the client to CloudFront and from CloudFront to the load balancer.

Assuming that AWS Certificate Manager is used, how many certificates will need to be generated?

A.

One in the US West (Oregon) region and one in the US East (Virginia) region.

B.

Two in the US West (Oregon) region and none in the US East (Virginia) region.

C.

One in the US West (Oregon) region and none in the US East (Virginia) region.

D.

Two in the US East (Virginia) region and none in the US West (Oregon) region.

Answer: A

Explanation:

QUESTION NO: 54

A Security Engineer has been asked to troubleshoot inbound connectivity to a web server. This single web server is not receiving inbound connections from the internet, whereas all other web servers are functioning properly.

The architecture includes network ACLs, security groups, and a virtual security appliance. In addition, the Development team has implemented Application Load Balancers (ALBs) to distribute the load across all web servers. It is a requirement that traffic between the web servers and the internet flow through the virtual security appliance.

The Security Engineer has verified the following:

1. The rule set in the Security Groups is correct
2. The rule set in the network ACLs is correct
3. The rule set in the virtual appliance is correct

Which of the following are other valid items to troubleshoot in this scenario? (Choose two.)

- A.**
Verify that the 0.0.0.0/0 route in the route table for the web server subnet points to a NAT gateway.
- B.**
Verify which Security Group is applied to the particular web server's elastic network interface (ENI).
- C.**
Verify that the 0.0.0.0/0 route in the route table for the web server subnet points to the virtual security appliance.
- D.**
Verify the registered targets in the ALB.
- E.**
Verify that the 0.0.0.0/0 route in the public subnet points to a NAT gateway.

Answer: B,D

Explanation:

QUESTION NO: 55

Which approach will generate automated security alerts should too many unauthorized AWS API requests be identified?

- A.**
Create an Amazon CloudWatch metric filter that looks for API call error codes and then implement an alarm based on that metric's rate.
- B.**
Configure AWS CloudTrail to stream event data to Amazon Kinesis. Configure an AWS Lambda function on the stream to alarm when the threshold has been exceeded.
- C.**
Run an Amazon Athena SQL query against CloudTrail log files. Use Amazon QuickSight to create an operational dashboard.
- D.**
Use the Amazon Personal Health Dashboard to monitor the account's use of AWS services, and raise an alert if service error rates increase.

Answer: B

Explanation:

QUESTION NO: 56

A company has multiple production AWS accounts. Each account has AWS CloudTrail configured to log to a single Amazon S3 bucket in a central account. Two of the production accounts have trails that are not logging anything to the S3 bucket.

Which steps should be taken to troubleshoot the issue? (Choose three.)

- A.**
Verify that the log file prefix is set to the name of the S3 bucket where the logs should go.
- B.**
Verify that the S3 bucket policy allows access for CloudTrail from the production AWS account IDs.
- C.**

Create a new CloudTrail configuration in the account, and configure it to log to the account's S3 bucket.

D.

Confirm in the CloudTrail Console that each trail is active and healthy.

E.

Open the global CloudTrail configuration in the master account, and verify that the storage location is set to the correct S3 bucket.

F.

Confirm in the CloudTrail Console that the S3 bucket name is set correctly.

Answer: A,B,F

Explanation:

QUESTION NO: 57

Amazon CloudWatch Logs agent is successfully delivering logs to the CloudWatch Logs service. However, logs stop being delivered after the associated log stream has been active for a specific number of hours.

What steps are necessary to identify the cause of this phenomenon? (Choose two.)

A.

Ensure that file permissions for monitored files that allow the CloudWatch Logs agent to read the file have not been modified.

B.

Verify that the OS Log rotation rules are compatible with the configuration requirements for agent streaming.

C.

Configure an Amazon Kinesis producer to first put the logs into Amazon Kinesis Streams.

D.

Create a CloudWatch Logs metric to isolate a value that changes at least once during the period before logging stops.

E.

Use AWS CloudFormation to dynamically create and maintain the configuration file for the CloudWatch Logs agent.

Answer: B,E

Explanation:

QUESTION NO: 58

A company has deployed a custom DNS server in AWS. The Security Engineer wants to ensure that Amazon EC2 instances cannot use the Amazon-provided DNS.

How can the Security Engineer block access to the Amazon-provided DNS in the VPC?

- A.**
Deny access to the Amazon DNS IP within all security groups.
- B.**
Add a rule to all network access control lists that deny access to the Amazon DNS IP.
- C.**
Add a route to all route tables that black holes traffic to the Amazon DNS IP.
- D.**
Disable DNS resolution within the VPC configuration.

Answer: D

Reference:

<https://docs.aws.amazon.com/vpc/latest/userguide/vpc-dns.html>

QUESTION NO: 59

An employee accidentally exposed an AWS access key and secret access key during a public presentation. The company Security Engineer immediately disabled the key.

How can the Engineer assess the impact of the key exposure and ensure that the credentials were not misused? (Choose two.)

- A.**
Analyze AWS CloudTrail for activity.
- B.**

Analyze Amazon CloudWatch Logs for activity.

C.

Download and analyze the IAM Use report from AWS Trusted Advisor.

D.

Analyze the resource inventory in AWS Config for IAM user activity.

E.

Download and analyze a credential report from IAM.

Answer: A,E

Explanation:

QUESTION NO: 60

Which of the following minimizes the potential attack surface for applications?

A.

Use security groups to provide stateful firewalls for Amazon EC2 instances at the hypervisor level.

B.

Use network ACLs to provide stateful firewalls at the VPC level to prevent access to any specific AWS resource.

C.

Use AWS Direct Connect for secure trusted connections between EC2 instances within private subnets.

D.

Design network security in a single layer within the perimeter network (also known as DMZ, demilitarized zone, and screened subnet) to facilitate quicker responses to threats.

Answer: B

Explanation:

QUESTION NO: 61

A distributed web application is installed across several EC2 instances in public subnets residing in two Availability Zones. Apache logs show several intermittent brute-force attacks from hundreds

of IP addresses at the layer 7 level over the past six months.

What would be the BEST way to reduce the potential impact of these attacks in the future?

- A.**
Use custom route tables to prevent malicious traffic from routing to the instances.
- B.**
Update security groups to deny traffic from the originating source IP addresses.
- C.**
Use network ACLs.
- D.**
Install intrusion prevention software (IPS) on each instance.

Answer: C

Explanation:

QUESTION NO: 62

A company plans to move most of its IT infrastructure to AWS. They want to leverage their existing on-premises Active Directory as an identity provider for AWS.

Which combination of steps should a Security Engineer take to federate the company's on-premises Active Directory with AWS? (Choose two.)

- A.**
Create IAM roles with permissions corresponding to each Active Directory group.
- B.**
Create IAM groups with permissions corresponding to each Active Directory group.
- C.**
Configure Amazon Cloud Directory to support a SAML provider.
- D.**
Configure Active Directory to add relying party trust between Active Directory and AWS.
- E.**
Configure Amazon Cognito to add relying party trust between Active Directory and AWS.

Answer: A,D

Reference:

<https://aws.amazon.com/blogs/security/aws-federated-authentication-with-active-directory-federation-services-ad-fs/>

QUESTION NO: 63

A security alert has been raised for an Amazon EC2 instance in a customer account that is exhibiting strange behavior. The Security Engineer must first isolate the EC2 instance and then use tools for further investigation.

What should the Security Engineer use to isolate and research this event? (Choose three.)

- A.**
AWS CloudTrail
- B.**
Amazon Athena
- C.**
AWS Key Management Service (AWS KMS)
- D.**
VPC Flow Logs
- E.**
AWS Firewall Manager
- F.**
Security groups

Answer: A,D,F

Explanation:

QUESTION NO: 64

A financial institution has the following security requirements:

Cloud-based users must be contained in a separate authentication domain.

Cloud-based users cannot access on-premises systems.

As part of standing up a cloud environment, the financial institution is creating a number of Amazon managed databases and Amazon EC2 instances. An Active Directory service exists on-premises that has all the administrator accounts, and these must be able to access the databases and instances.

How would the organization manage its resources in the MOST secure manner? (Choose two.)

- A.**
Configure an AWS Managed Microsoft AD to manage the cloud resources.
- B.**
Configure an additional on-premises Active Directory service to manage the cloud resources.
- C.**
Establish a one-way trust relationship from the existing Active Directory to the new Active Directory service.
- D.**
Establish a one-way trust relationship from the new Active Directory to the existing Active Directory service.
- E.**
Establish a two-way trust between the new and existing Active Directory services.

Answer: B,C

Explanation:

QUESTION NO: 65

An organization wants to be alerted when an unauthorized Amazon EC2 instance in its VPC performs a network port scan against other instances in the VPC. When the Security team performs its own internal tests in a separate account by using pre-approved third-party scanners from the AWS Marketplace, the Security team also then receives multiple Amazon GuardDuty events from Amazon CloudWatch alerting on its test activities.

How can the Security team suppress alerts about authorized security tests while still receiving alerts about the unauthorized activity?

- A.**
Use a filter in AWS CloudTrail to exclude the IP addresses of the Security team's EC2 instances.

B.

Add the Elastic IP addresses of the Security team's EC2 instances to a trusted IP list in Amazon GuardDuty.

C.

Install the Amazon Inspector agent on the EC2 instances that the Security team uses.

D.

Grant the Security team's EC2 instances a role with permissions to call Amazon GuardDuty API operations.

Answer: C

Explanation:

QUESTION NO: 66

An organization is moving non-business-critical applications to AWS while maintaining a mission-critical application in an on-premises data center. An on-premises application must share limited confidential information with the applications in AWS. The internet performance is unpredictable.

Which configuration will ensure continued connectivity between sites MOST securely?

A.

VPN and a cached storage gateway

B.

AWS Snowball Edge

C.

VPN Gateway over AWS Direct Connect

D.

AWS Direct Connect

Answer: C

Explanation:

QUESTION NO: 67

An application has been built with Amazon EC2 instances that retrieve messages from Amazon SQS. Recently, IAM changes were made and the instances can no longer retrieve messages.

What actions should be taken to troubleshoot the issue while maintaining least privilege? (Choose two.)

- A.**
Configure and assign an MFA device to the role used by the instances.
- B.**
Verify that the SQS resource policy does not explicitly deny access to the role used by the instances.
- C.**
Verify that the access key attached to the role used by the instances is active.
- D.**
Attach the AmazonSQSFullAccess managed policy to the role used by the instances.
- E.**
Verify that the role attached to the instances contains policies that allow access to the queue.

Answer: B,E

Reference:

<https://docs.aws.amazon.com/AWSSimpleQueueService/latest/SQSDeveloperGuide/sqs-using-identity-based-policies.html>

QUESTION NO: 68

A company has a forensic logging use case whereby several hundred applications running on Docker on EC2 need to send logs to a central location. The Security Engineer must create a logging solution that is able to perform real-time analytics on the log files, grants the ability to replay events, and persists data.

Which AWS Services, together, can satisfy this use case? (Choose two.)

- A.**
Amazon Elasticsearch
- B.**
Amazon Kinesis

- C.**
Amazon SQS
- D.**
Amazon CloudWatch
- E.**
Amazon Athena

Answer: B,D

Explanation:

QUESTION NO: 69

Which of the following is the most efficient way to automate the encryption of AWS CloudTrail logs using a Customer Master Key (CMK) in AWS KMS?

- A.**
Use the KMS direct encrypt function on the log data every time a CloudTrail log is generated.
- B.**
Use the default Amazon S3 server-side encryption with S3-managed keys to encrypt and decrypt the CloudTrail logs.
- C.**
Configure CloudTrail to use server-side encryption using KMS-managed keys to encrypt and decrypt CloudTrail logs.
- D.**
Use encrypted API endpoints so that all AWS API calls generate encrypted CloudTrail log entries using the TLS certificate from the encrypted API call.

Answer: C

Reference:

<https://docs.aws.amazon.com/awscloudtrail/latest/userguide/encrypting-cloudtrail-log-files-with-aws-kms.html>

QUESTION NO: 70

An organization is using AWS CloudTrail, Amazon CloudWatch Logs, and Amazon CloudWatch to send alerts when new access keys are created. However, the alerts are no longer appearing in the Security Operations mail box.

Which of the following actions would resolve this issue?

A.

In CloudTrail, verify that the trail logging bucket has a log prefix configured.

B.

In Amazon SNS, determine whether the "Account spend limit" has been reached for this alert.

C.

In SNS, ensure that the subscription used by these alerts has not been deleted.

D.

In CloudWatch, verify that the alarm threshold "consecutive periods" value is equal to, or greater than 1.

Answer: D

Explanation:

QUESTION NO: 71

A Security Engineer must add additional protection to a legacy web application by adding the following HTTP security headers:

-Content Security-Policy

-X-Frame-Options

-X-XSS-Protection

The Engineer does not have access to the source code of the legacy web application.

Which of the following approaches would meet this requirement?

A.

Configure an Amazon Route 53 routing policy to send all web traffic that does not include the required headers to a black hole.

B.

Implement an AWS Lambda@Edge origin response function that inserts the required headers.

C.

Migrate the legacy application to an Amazon S3 static website and front it with an Amazon CloudFront distribution.

D.

Construct an AWS WAF rule to replace existing HTTP headers with the required security headers by using regular expressions.

Answer: B

Explanation:

QUESTION NO: 72

During a security event, it is discovered that some Amazon EC2 instances have not been sending Amazon CloudWatch logs.

Which steps can the Security Engineer take to troubleshoot this issue? (Choose two.)

A.

Connect to the EC2 instances that are not sending the appropriate logs and verify that the CloudWatch Logs agent is running.

B.

Log in to the AWS account and select CloudWatch Logs. Check for any monitored EC2 instances that are in the "Alerting" state and restart them using the EC2 console.

C.

Verify that the EC2 instances have a route to the public AWS API endpoints.

D.

Connect to the EC2 instances that are not sending logs. Use the command prompt to verify that the right permissions have been set for the Amazon SNS topic.

E.

Verify that the network access control lists and security groups of the EC2 instances have the access to send logs over SNMP.

Answer: A,B

Explanation:

QUESTION NO: 73

A Security Engineer discovers that developers have been adding rules to security groups that allow SSH and RDP traffic from 0.0.0.0/0 instead of the organization firewall IP.

What is the most efficient way to remediate the risk of this activity?

- A.**
Delete the internet gateway associated with the VPC.
- B.**
Use network access control lists to block source IP addresses matching 0.0.0.0/0.
- C.**
Use a host-based firewall to prevent access from all but the organization's firewall IP.
- D.**
Use AWS Config rules to detect 0.0.0.0/0 and invoke an AWS Lambda function to update the security group with the organization's firewall IP.

Answer: B

Explanation:

QUESTION NO: 74

In response to the past DDoS attack experiences, a Security Engineer has set up an Amazon CloudFront distribution for an Amazon S3 bucket. There is concern that some users may bypass the CloudFront distribution and access the S3 bucket directly.

What must be done to prevent users from accessing the S3 objects directly by using URLs?

- A.**
Change the S3 bucket/object permission so that only the bucket owner has access.
- B.**
Set up a CloudFront origin access identity (OAI), and change the S3 bucket/object permission so that only the OAI has access.
- C.**
Create IAM roles for CloudFront, and change the S3 bucket/object permission so that only the IAM role has access.

D.

Redirect S3 bucket access to the corresponding CloudFront distribution.

Answer: B

Explanation:

QUESTION NO: 75

A company plans to move most of its IT infrastructure to AWS. The company wants to leverage its existing on-premises Active Directory as an identity provider for AWS.

Which steps should be taken to authenticate to AWS services using the company's on-premises Active Directory? (Choose three.)

A.

Create IAM roles with permissions corresponding to each Active Directory group.

B.

Create IAM groups with permissions corresponding to each Active Directory group.

C.

Create a SAML provider with IAM.

D.

Create a SAML provider with Amazon Cloud Directory.

E.

Configure AWS as a trusted relying party for the Active Directory

F.

Configure IAM as a trusted relying party for Amazon Cloud Directory.

Answer: A,C,E

Reference:

<https://aws.amazon.com/blogs/security/aws-federated-authentication-with-active-directory-federation-services-ad-fs/>

QUESTION NO: 76

A Security Analyst attempted to troubleshoot the monitoring of suspicious security group changes. The Analyst was told that there is an Amazon CloudWatch alarm in place for these AWS CloudTrail log events. The Analyst tested the monitoring setup by making a configuration change to the security group but did not receive any alerts.

Which of the following troubleshooting steps should the Analyst perform?

A.

Ensure that CloudTrail and S3 bucket access logging is enabled for the Analyst's AWS account. B. Verify that a metric filter was created and then mapped to an alarm. Check the alarm notification action.

B.

Check the CloudWatch dashboards to ensure that there is a metric configured with an appropriate dimension for security group changes.

C.

Verify that the Analyst's account is mapped to an IAM policy that includes permissions for cloudwatch: GetMetricStatistics and Cloudwatch: ListMetrics.

Answer: B

Explanation:

QUESTION NO: 77

Example.com hosts its internal document repository on Amazon EC2 instances. The application runs on EC2 instances and previously stored the documents on encrypted Amazon EBS volumes. To optimize the application for scale, example.com has moved the files to Amazon S3. The security team has mandated that all the files are securely deleted from the EBS volume, and it must certify that the data is unreadable before releasing the underlying disks.

Which of the following methods will ensure that the data is unreadable by anyone else?

A.

Change the volume encryption on the EBS volume to use a different encryption mechanism. Then, release the EBS volumes back to AWS.

B.

Release the volumes back to AWS. AWS immediately wipes the disk after it is deprovisioned.

C.

Delete the encryption key used to encrypt the EBS volume. Then, release the EBS volumes back

to AWS.

D.

Delete the data by using the operating system delete commands. Run Quick Format on the drive and then release the EBS volumes back to AWS.

Answer: D

Explanation:

QUESTION NO: 78

A Systems Administrator has written the following Amazon S3 bucket policy designed to allow access to an S3 bucket for only an authorized AWS IAM user from the IP address range 10.10.10.0/24:

```
{
  "Version": "2012-10-17",
  "Id": "S3Policy1",
  "Statement": [
    {
      "Sid": ["OfficeAllowIP"],
      "Effect": ["Allow"],
      "Principal": ["*"],
      "Action": ["s3:*"],
      "Resource": ["arn:aws:s3:::Bucket"],
      "Condition": {
        "IpAddress": [
          {
            "aws:SourceIp": "10.10.10.0/24"
          }
        ]
      }
    }
  ]
}
```

When trying to download an object from the S3 bucket from 10.10.10.40, the IAM user receives an access denied message.

What does the Administrator need to change to grant access to the user?

- A.**
Change the "Resource" from "arn: aws:s3:::Bucket" to "arn:aws:s3:::Bucket/*".
- B.**
Change the "Principal" from "*" to {AWS:"arn:aws:iam: : account-number: user/username"}
- C.**
Change the "Version" from "2012-10-17" to the last revised date of the policy

D.

Change the "Action" from ["s3:*"] to ["s3:GetObject", "s3:ListBucket"]

Answer: A

Explanation:

QUESTION NO: 79

The Security Engineer has discovered that a new application that deals with highly sensitive data is storing Amazon S3 objects with the following key pattern, which itself contains highly sensitive data.

Pattern:

"randomID_datestamp_PII.csv"

Example:

"1234567_12302017_000-00-0000 csv"

The bucket where these objects are being stored is using server-side encryption (SSE).

Which solution is the most secure and cost-effective option to protect the sensitive data?

A.

Remove the sensitive data from the object name, and store the sensitive data using S3 user-defined metadata.

B.

Add an S3 bucket policy that denies the action s3:GetObject

C.

Use a random and unique S3 object key, and create an S3 metadata index in Amazon DynamoDB using client-side encrypted attributes.

D.

Store all sensitive objects in Binary Large Objects (BLOBS) in an encrypted Amazon RDS instance.

Answer: B

Explanation:

QUESTION NO: 80

AWS CloudTrail is being used to monitor API calls in an organization. An audit revealed that CloudTrail is failing to deliver events to Amazon S3 as expected.

What initial actions should be taken to allow delivery of CloudTrail events to S3? (Choose two.)

- A.**
Verify that the S3 bucket policy allow CloudTrail to write objects.
- B.**
Verify that the IAM role used by CloudTrail has access to write to Amazon CloudWatch Logs.
- C.**
Remove any lifecycle policies on the S3 bucket that are archiving objects to Amazon Glacier.
- D.**
Verify that the S3 bucket defined in CloudTrail exists.
- E.**
Verify that the log file prefix defined in CloudTrail exists in the S3 bucket.

Answer: D,E

Explanation:

QUESTION NO: 81

Due to new compliance requirements, a Security Engineer must enable encryption with customer-provided keys on corporate data that is stored in DynamoDB. The company wants to retain full control of the encryption keys.

Which DynamoDB feature should the Engineer use to achieve compliance'?

- A.**
Use AWS Certificate Manager to request a certificate. Use that certificate to encrypt data prior to uploading it to DynamoDB.
- B.**
Enable S3 server-side encryption with the customer-provided keys. Upload the data to Amazon S3, and then use S3Copy to move all data to DynamoDB

C.

Create a KMS master key. Generate per-record data keys and use them to encrypt data prior to uploading it to DynamoDS. Dispose of the cleartext and encrypted data keys after encryption without storing.

D.

Use the DynamoDB Java encryption client to encrypt data prior to uploading it to DynamoDB.

Answer: D

Explanation:

QUESTION NO: 82

A Security Engineer must design a system that can detect whether a file on an Amazon EC2 host has been modified. The system must then alert the Security Engineer of the modification.

What is the MOST efficient way to meet these requirements?

A.

Install antivirus software and ensure that signatures are up-to-date. Configure Amazon CloudWatch alarms to send alerts for security events.

B.

Install host-based IDS software to check for file integrity. Export the logs to Amazon CloudWatch Logs for monitoring and alerting.

C.

Export system log files to Amazon S3. Parse the log files using an AWS Lambda function that will send alerts of any unauthorized system login attempts through Amazon SNS.

D.

Use Amazon CloudWatch Logs to detect file system changes. If a change is detected, automatically terminate and recreate the instance from the most recent AMI. Use Amazon SNS to send notification of the event.

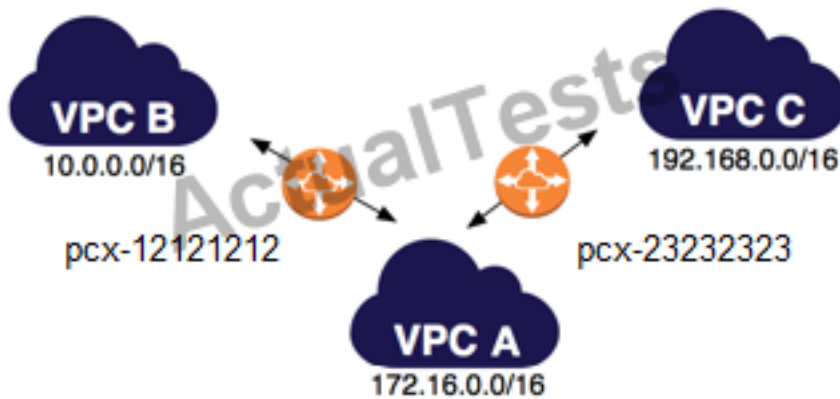
Answer: D

Explanation:

QUESTION NO: 83

A company has multiple VPCs in their account that are peered, as shown in the diagram. A Security Engineer wants to perform penetration tests of the Amazon EC2 instances in all three VPCs.

How can this be accomplished? (Choose two.)



- A.**
Deploy a pre-authorized scanning engine from the AWS Marketplace into VPC B, and use it to scan instances in all three VPCs. Do not complete the penetration test request form.
- B.**
Deploy a pre-authorized scanning engine from the Marketplace into each VPC, and scan instances in each VPC from the scanning engine in that VPC. Do not complete the penetration test request form.
- C.**
Create a VPN connection from the data center to VPC A. Use an on-premises scanning engine to scan the instances in all three VPCs. Complete the penetration test request form for all three VPCs.
- D.**
Create a VPN connection from the data center to each of the three VPCs. Use an on-premises scanning engine to scan the instances in each VPC. Do not complete the penetration test request form.
- E.**
Create a VPN connection from the data center to each of the three VPCs. Use an on-premises scanning engine to scan the instances in each VPC. Complete the penetration test request form for all three VPCs.

Answer: C,E

Explanation:

QUESTION NO: 84

The Security Engineer is managing a traditional three-tier web application that is running on Amazon EC2 instances. The application has become the target of increasing numbers of malicious attacks from the Internet.

What steps should the Security Engineer take to check for known vulnerabilities and limit the attack surface? (Choose two.)

- A.**
Use AWS Certificate Manager to encrypt all traffic between the client and application servers.
- B.**
Review the application security groups to ensure that only the necessary ports are open.
- C.**
Use Elastic Load Balancing to offload Secure Sockets Layer encryption.
- D.**
Use Amazon Inspector to periodically scan the backend instances.
- E.**
Use AWS Key Management Services to encrypt all the traffic between the client and application servers.

Answer: B,D

Explanation:

QUESTION NO: 85

For compliance reasons, an organization limits the use of resources to three specific AWS regions. It wants to be alerted when any resources are launched in unapproved regions.

Which of the following approaches will provide alerts on any resources launched in an unapproved region?

- A.**
Develop an alerting mechanism based on processing AWS CloudTrail logs.
- B.**

Monitor Amazon S3 Event Notifications for objects stored in buckets in unapproved regions.

C.

Analyze Amazon CloudWatch Logs for activities in unapproved regions.

D.

Use AWS Trusted Advisor to alert on all resources being created.

Answer: A

Explanation:

QUESTION NO: 86

A company runs an application on AWS that needs to be accessed only by employees. Most employees work from the office, but others work remotely or travel.

How can the Security Engineer protect this workload so that only employees can access it?

A.

Add each employee's home IP address to the security group for the application so that only those users can access the workload.

B.

Create a virtual gateway for VPN connectivity for each employee, and restrict access to the workload from within the VPC.

C.

Use a VPN appliance from the AWS Marketplace for users to connect to, and restrict workload access to traffic from that appliance.

D.

Route all traffic to the workload through AWS WAF. Add each employee's home IP address into an AWS WAF rule, and block all other traffic.

Answer: B

Explanation:

QUESTION NO: 87

A Systems Engineer is troubleshooting the connectivity of a test environment that includes a virtual security appliance deployed inline. In addition to using the virtual security appliance, the Development team wants to use security groups and network ACLs to accomplish various security requirements in the environment.

What configuration is necessary to allow the virtual security appliance to route the traffic?

- A.**
Disable network ACLs.
- B.**
Configure the security appliance's elastic network interface for promiscuous mode.
- C.**
Disable the Network Source/Destination check on the security appliance's elastic network interface
- D.**
Place the security appliance in the public subnet with the internet gateway

Answer: D

Explanation:

QUESTION NO: 88

A Security Architect is evaluating managed solutions for storage of encryption keys. The requirements are:

- Storage is accessible by using only VPCs.
- Service has tamper-evident controls.
- Access logging is enabled.
- Storage has high availability.

Which of the following services meets these requirements?

- A.**
Amazon S3 with default encryption
- B.**
AWS CloudHSM

C.

Amazon DynamoDB with server-side encryption

D.

AWS Systems Manager Parameter Store

Answer: B

Reference:

<https://aws.amazon.com/blogs/aws/aws-cloud-hsm-secure-key-storage-and-cryptographic-operations/>

QUESTION NO: 89

An AWS account includes two S3 buckets: bucket1 and bucket2. The bucket2 does not have a policy defined, but bucket1 has the following bucket policy:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "AWS": "arn:aws:iam: : 123456789012: user/alice" },
      "Action": "s3:*",
      "Resource": [ "arn:aws:s3: : bucket1", "arn:aws:s3: : bucket1/*" ]
    }
  ]
}
```

In addition, the same account has an IAM User named "alice", with the following IAM policy.

```
{  
  "Version": "2012-10-17",  
  "Statement": [{  
    "Effect": "Allow",  
    "Action": "s3:*",  
    "Resource": ["arn:aws:s3:::bucket2", "arn:aws:s3:::bucket2/*"]  
  }  
]  
}
```

Which buckets can user "alice" access?

- A.**
Bucket1 only
- B.**
Bucket2 only
- C.**
Both bucket1 and bucket2
- D.**
Neither bucket1 nor bucket2

Answer: C

Explanation:

QUESTION NO: 90

An organization has three applications running on AWS, each accessing the same data on Amazon S3. The data on Amazon S3 is server-side encrypted by using an AWS KMS Customer Master Key (CMK).

What is the recommended method to ensure that each application has its own programmatic access control permissions on the KMS CMK?

A.

Change the key policy permissions associated with the KMS CMK for each application when it must access the data in Amazon S3.

B.

Have each application assume an IAM role that provides permissions to use the AWS Certificate Manager CMK.

C.

Have each application use a grant on the KMS CMK to add or remove specific access controls on the KMS CMK.

D.

Have each application use an IAM policy in a user context to have specific access permissions on the KMS CMK.

Answer: D

Explanation:

QUESTION NO: 91

The Security Engineer is given the following requirements for an application that is running on Amazon EC2 and managed by using AWS CloudFormation templates with EC2 Auto Scaling groups:

-Have the EC2 instances bootstrapped to connect to a backend database.

-Ensure that the database credentials are handled securely.

-Ensure that retrievals of database credentials are logged.

Which of the following is the MOST efficient way to meet these requirements?

A.

Pass databases credentials to EC2 by using CloudFormation stack parameters with the property set to true. Ensure that the instance is configured to log to Amazon CloudWatch Logs.

B.

Store database passwords in AWS Systems Manager Parameter Store by using SecureString parameters. Set the IAM role for the EC2 instance profile to allow access to the parameters.

C.

Create an AWS Lambda that ingests the database password and persists it to Amazon S3 with server-side encryption. Have the EC2 instances retrieve the S3 object on startup, and log all script

invocations to syslog.

D.

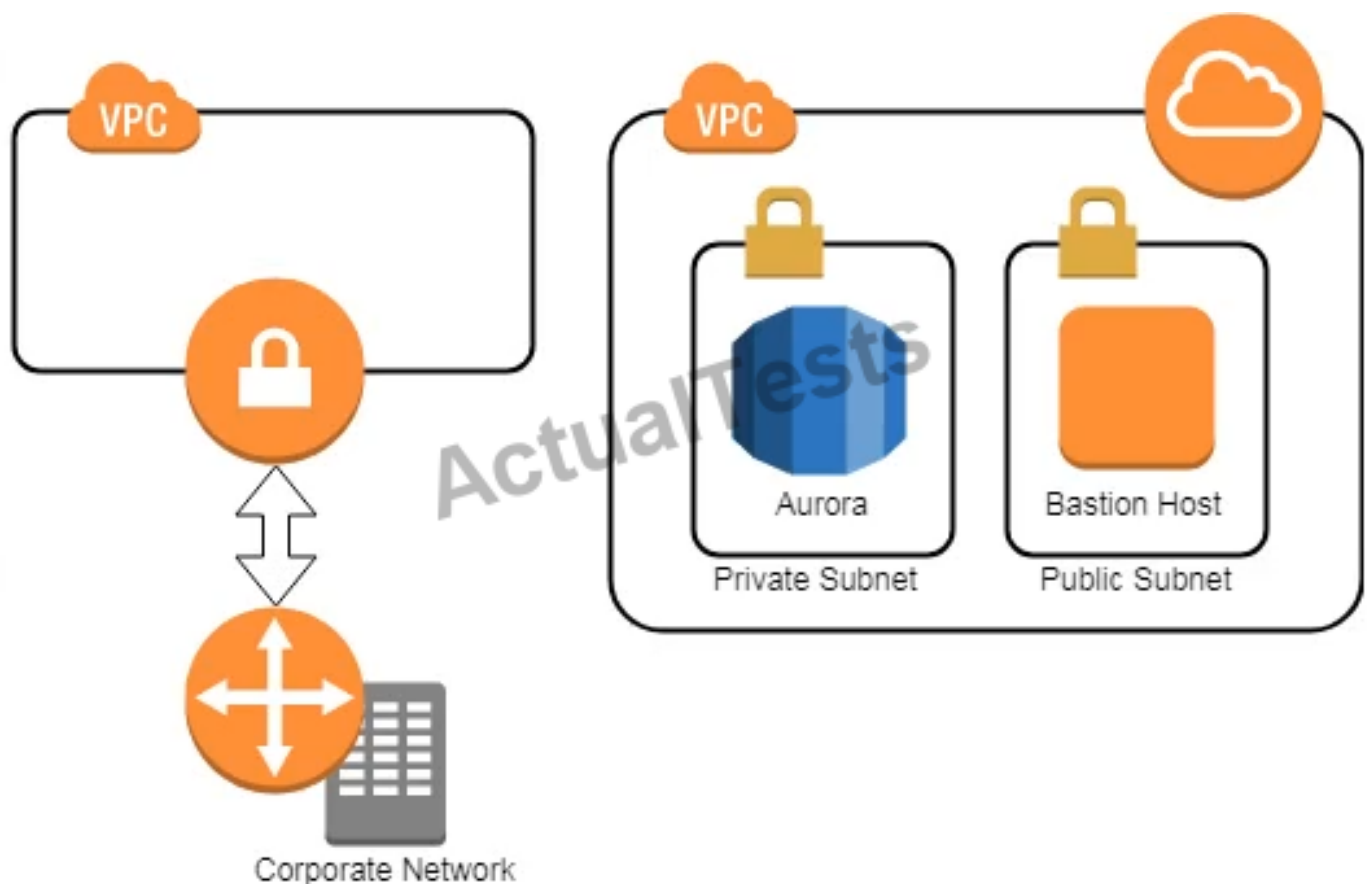
Write a script that is passed in as UserData so that it is executed upon launch of the EC2 instance. Ensure that the instance is configured to log to Amazon CloudWatch Logs.

Answer: B

Explanation:

QUESTION NO: 92

A company has two AWS accounts, each containing one VPC. The first VPC has a VPN connection with its corporate network. The second VPC, without a VPN, hosts an Amazon Aurora database cluster in private subnets. Developers manage the Aurora database from a bastion host in a public subnet as shown in the image.



A security review has flagged this architecture as vulnerable, and a Security Engineer has been asked to make this design more secure. The company has a short deadline and a second VPN connection to the Aurora account is not possible.

How can the Security Engineer securely set up the bastion host?

A.

Move the bastion host to the VPC with VPN connectivity. Create a VPC peering relationship between the bastion host VPC and Aurora VPC.

B.

Create an SSH port forwarding tunnel on the Developer's workstation to the bastion host to ensure that only authorized SSH clients can access the bastion host.

C.

Move the bastion host to the VPC with VPN connectivity. Create a cross-account trust relationship between the bastion VPC and Aurora VPC, and update the Aurora security group for the relationship.

D.

Create an AWS Direct Connect connection between the corporate network and the Aurora account, and adjust the Aurora security group for this connection.

Answer: B

Explanation:

QUESTION NO: 93

An organization operates a web application that serves users globally. The application runs on Amazon EC2 instances behind an Application Load Balancer. There is an Amazon CloudFront distribution in front of the load balancer, and the organization uses AWS WAF. The application is currently experiencing a volumetric attack whereby the attacker is exploiting a bug in a popular mobile game.

The application is being flooded with HTTP requests from all over the world with the User-Agent set to the following string: Mozilla/5.0 (compatible; ExampleCorp; ExampleGame/1.22; Mobile/1.0)

What mitigation can be applied to block attacks resulting from this bug while continuing to service legitimate requests?

A.

Create a rule in AWS WAF rules with conditions that block requests based on the presence of ExampleGame/1.22 in the User-Agent header

B.

Create a geographic restriction on the CloudFront distribution to prevent access to the application

from most geographic regions

C.

Create a rate-based rule in AWS WAF to limit the total number of requests that the web application services.

D.

Create an IP-based blacklist in AWS WAF to block the IP addresses that are originating from requests that contain ExampleGame/1.22 in the User-Agent header.

Answer: C

Explanation:

QUESTION NO: 94

Some highly sensitive analytics workloads are to be moved to Amazon EC2 hosts. Threat modeling has found that a risk exists where a subnet could be maliciously or accidentally exposed to the internet.

Which of the following mitigations should be recommended?

A.

Use AWS Config to detect whether an Internet Gateway is added and use an AWS Lambda function to provide auto-remediation.

B.

Within the Amazon VPC configuration, mark the VPC as private and disable Elastic IP addresses.

C.

Use IPv6 addressing exclusively on the EC2 hosts, as this prevents the hosts from being accessed from the internet.

D.

Move the workload to a Dedicated Host, as this provides additional network security controls and monitoring.

Answer: B

Explanation:

QUESTION NO: 95

A Developer who is following AWS best practices for secure code development requires an application to encrypt sensitive data to be stored at rest, locally in the application, using AWS KMS. What is the simplest and MOST secure way to decrypt this data when required?

- A.**
Request KMS to provide the stored unencrypted data key and then use the retrieved data key to decrypt the data.
- B.**
Keep the plaintext data key stored in Amazon DynamoDB protected with IAM policies. Query DynamoDB to retrieve the data key to decrypt the data
- C.**
Use the Encrypt API to store an encrypted version of the data key with another customer managed key. Decrypt the data key and use it to decrypt the data when required.
- D.**
Store the encrypted data key alongside the encrypted data. Use the Decrypt API to retrieve the data key to decrypt the data when required.

Answer: D

Explanation:

QUESTION NO: 96

A Security Administrator at a university is configuring a fleet of Amazon EC2 instances. The EC2 instances are shared among students, and non-root SSH access is allowed. The Administrator is concerned about students attacking other AWS account resources by using the EC2 instance metadata service.

What can the Administrator do to protect against this potential attack?

- A.**
Disable the EC2 instance metadata service.
- B.**
Log all student SSH interactive session activity.
- C.**
Implement iptables-based restrictions on the instances.
- D.**
Install the Amazon Inspector agent on the instances.

Answer: C

Explanation:

QUESTION NO: 97

An organization receives an alert that indicates that an EC2 instance behind an ELB Classic Load Balancer has been compromised.

What techniques will limit lateral movement and allow evidence gathering?

A.

Remove the instance from the load balancer and terminate it.

B.

Remove the instance from the load balancer, and shut down access to the instance by tightening the security group.

C.

Reboot the instance and check for any Amazon CloudWatch alarms.

D.

Stop the instance and make a snapshot of the root EBS volume.

Answer: B

Explanation:

QUESTION NO: 98

A Development team has asked for help configuring the IAM roles and policies in a new AWS account. The team using the account expects to have hundreds of master keys and therefore does not want to manage access control for customer master keys (CMKs).

Which of the following will allow the team to manage AWS KMS permissions in IAM without the complexity of editing individual key policies?

A.

The account's CMK key policy must allow the account's IAM roles to perform KMS EnableKey.

B.

Newly created CMKs must have a key policy that allows the root principal to perform all actions.

C.

Newly created CMKs must allow the root principal to perform the kms CreateGrant API operation.

D.

Newly created CMKs must mirror the IAM policy of the KMS key administrator.

Answer: D

Explanation:

QUESTION NO: 99

An Amazon EC2 instance is part of an EC2 Auto Scaling group that is behind an Application Load Balancer (ALB). It is suspected that the EC2 instance has been compromised.

Which steps should be taken to investigate the suspected compromise? (Choose three.)

A.

Detach the elastic network interface from the EC2 instance.

B.

Initiate an Amazon Elastic Block Store volume snapshot of all volumes on the EC2 instance.

C.

Disable any Amazon Route 53 health checks associated with the EC2 instance.

D.

De-register the EC2 instance from the ALB and detach it from the Auto Scaling group.

E.

Attach a security group that has restrictive ingress and egress rules to the EC2 instance.

F.

Add a rule to an AWS WAF to block access to the EC2 instance.

Answer: A,E,F

Explanation:

QUESTION NO: 100

A company has five AWS accounts and wants to use AWS CloudTrail to log API calls. The log files must be stored in an Amazon S3 bucket that resides in a new account specifically built for centralized services with a unique top-level prefix for each trail. The configuration must also enable detection of any modification to the logs.

Which of the following steps will implement these requirements? (Choose three.)

A.

Create a new S3 bucket in a separate AWS account for centralized storage of CloudTrail logs, and enable "Log File Validation" on all trails.

B.

Use an existing S3 bucket in one of the accounts, apply a bucket policy to the new centralized S3 bucket that permits the CloudTrail service to use the "s3: PutObject" action and the "s3 GetBucketACL" action, and specify the appropriate resource ARNs for the CloudTrail trails.

C.

Apply a bucket policy to the new centralized S3 bucket that permits the CloudTrail service to use the "s3 PutObject" action and the "s3 GetBucketACL" action, and specify the appropriate resource ARNs for the CloudTrail trails.

D.

Use unique log file prefixes for trails in each AWS account.

E.

Configure CloudTrail in the centralized account to log all accounts to the new centralized S3 bucket.

F.

Enable encryption of the log files by using AWS Key Management Service

Answer: B,E,F

Explanation:

QUESTION NO: 101

A Security Engineer is implementing a solution to allow users to seamlessly encrypt Amazon S3 objects without having to touch the keys directly. The solution must be highly scalable without requiring continual management. Additionally, the organization must be able to immediately delete the encryption keys.

Which solution meets these requirements?

A.

Use AWS KMS with AWS managed keys and the ScheduleKeyDeletion API with a PendingWindowInDays set to 0 to remove the keys if necessary.

B.

Use KMS with AWS imported key material and then use the DeleteImportedKeyMaterial API to remove the key material if necessary.

C.

Use AWS CloudHSM to store the keys and then use the CloudHSM API or the PKCS11 library to delete the keys if necessary.

D.

Use the Systems Manager Parameter Store to store the keys and then use the service API operations to delete the key if necessary.

Answer: B

Explanation:

QUESTION NO: 102

An application uses Amazon Cognito to manage end users' permissions when directly accessing AWS resources, including Amazon DynamoDB. A new feature request reads as follows:

Provide a mechanism to mark customers as suspended pending investigation or suspended permanently. Customers should still be able to log in when suspended, but should not be able to make changes.

The priorities are to reduce complexity and avoid potential for future security issues.

Which approach will meet these requirements and priorities?

A.

Create a new database field "suspended_status" and modify the application logic to validate that field when processing requests.

B.

Add suspended customers to second Cognito user pool and update the application login flow to check both user pools.

C.

Use Amazon Cognito Sync to push out a "suspension_status" parameter and split the IAM policy into normal users and suspended users.

D.

Move suspended customers to a second Cognito group and define an appropriate IAM access policy for the group.

Answer: A

Explanation:

QUESTION NO: 103

A company stores data on an Amazon EBS volume attached to an Amazon EC2 instance. The data is asynchronously replicated to an Amazon S3 bucket. Both the EBS volume and the S3 bucket are encrypted with the same AWS KMS Customer Master Key (CMK). A former employee scheduled a deletion of that CMK before leaving the company.

The company's Developer Operations department learns about this only after the CMK has been deleted.

Which steps must be taken to address this situation?

A.

Copy the data directly from the EBS encrypted volume before the volume is detached from the EC2 instance.

B.

Recover the data from the EBS encrypted volume using an earlier version of the KMS backing key.

C.

Make a request to AWS Support to recover the S3 encrypted data.

D.

Make a request to AWS Support to restore the deleted CMK, and use it to recover the data.

Answer: A

Explanation:

QUESTION NO: 104

An AWS Lambda function was misused to alter data, and a Security Engineer must identify who invoked the function and what output was produced. The Engineer cannot find any logs created by the Lambda function in Amazon CloudWatch Logs.

Which of the following explains why the logs are not available?

A.

The execution role for the Lambda function did not grant permissions to write log data to CloudWatch Logs.

B.

The Lambda function was executed by using Amazon API Gateway, so the logs are not stored in CloudWatch Logs.

C.

The execution role for the Lambda function did not grant permissions to write to the Amazon S3 bucket where CloudWatch Logs stores the logs.

D.

The version of the Lambda function that was executed was not current.

Answer: A

Reference:

<https://docs.aws.amazon.com/lambda/latest/dg/troubleshooting.html>

QUESTION NO: 105

A company has Windows Amazon EC2 instances in a VPC that are joined to on-premises Active Directory servers for domain services. The security team has enabled Amazon GuardDuty on the AWS account to alert on issues with the instances.

During a weekly audit of network traffic, the Security Engineer notices that one of the EC2 instances is attempting to communicate with a known command-and-control server but failing. This alert does not show up in GuardDuty.

Why did GuardDuty fail to alert to this behavior?

A.

GuardDuty did not have the appropriate alerts activated.

B.

GuardDuty does not see these DNS requests.

- C.**
GuardDuty only monitors active network traffic flow for command-and-control activity.
- D.**
GuardDuty does not report on command-and-control activity.

Answer: C

Explanation:

QUESTION NO: 106

The AWS Systems Manager Parameter Store is being used to store database passwords used by an AWS Lambda function. Because this is sensitive data, the parameters are stored as type SecureString and protected by an AWS KMS key that allows access through IAM. When the function executes, this parameter cannot be retrieved as the result of an access denied error.

Which of the following actions will resolve the access denied error?

- A.**
Update the ssm.amazonaws.com principal in the KMS key policy to allow kms: Decrypt.
- B.**
Update the Lambda configuration to launch the function in a VPC.
- C.**
Add a policy to the role that the Lambda function uses, allowing kms: Decrypt for the KMS key.
- D.**
Add lambda.amazonaws.com as a trusted entity on the IAM role that the Lambda function uses.

Answer: A

Reference:

<https://aws.amazon.com/blogs/compute/sharing-secrets-with-aws-lambda-using-aws-systems-manager-parameter-store/>

QUESTION NO: 107

A company's security policy requires that VPC Flow Logs are enabled on all VPCs. A Security Engineer is looking to automate the process of auditing the VPC resources for compliance.

What combination of actions should the Engineer take? (Choose two.)

- A.**
Create an AWS Lambda function that determines whether Flow Logs are enabled for a given VPC.
- B.**
Create an AWS Config configuration item for each VPC in the company AWS account.
- C.**
Create an AWS Config managed rule with a resource type of AWS::Lambda::Function.
- D.**
Create an Amazon CloudWatch Event rule that triggers on events emitted by AWS Config.
- E.**
Create an AWS Config custom rule, and associate it with an AWS Lambda function that contains the evaluating logic.

Answer: B,D

Explanation:

QUESTION NO: 108

A Security Engineer is looking for a way to control access to data that is being encrypted under a CMK. The Engineer is also looking to use additional authenticated data (AAD) to prevent tampering with ciphertext.

Which action would provide the required functionality?

- A.**
Pass the key alias to AWS KMS when calling Encrypt and Decrypt API actions.
- B.**
Use IAM policies to restrict access to Encrypt and Decrypt API actions.
- C.**
Use kms:EncryptionContext as a condition when defining IAM policies for the CMK.
- D.**
Use key policies to restrict access to the appropriate IAM groups.

Answer: D

Reference:

<https://docs.aws.amazon.com/crypto/latest/userguide/crypto-ug.pdf>

QUESTION NO: 109

An application makes calls to AWS services using the AWS SDK. The application runs on Amazon EC2 instances with an associated IAM role. When the application attempts to access an object within an Amazon S3 bucket; the Administrator receives the following error message: HTTP 403: Access Denied.

Which combination of steps should the Administrator take to troubleshoot this issue? (Choose three.)

- A.**
Confirm that the EC2 instance's security group authorizes S3 access.
- B.**
Verify that the KMS key policy allows decrypt access for the KMS key for this IAM principle.
- C.**
Check the S3 bucket policy for statements that deny access to objects.
- D.**
Confirm that the EC2 instance is using the correct key pair.
- E.**
Confirm that the IAM role associated with the EC2 instance has the proper privileges.
- F.**
Confirm that the instance and the S3 bucket are in the same Region.

Answer: B,C,E

Explanation:

QUESTION NO: 110

A Security Engineer must implement mutually authenticated TLS connections between containers that communicate inside a VPC.

Which solution would be MOST secure and easy to maintain?

A.

Use AWS Certificate Manager to generate certificates from a public certificate authority and deploy them to all the containers.

B.

Create a self-signed certificate in one container and use AWS Secrets Manager to distribute the certificate to the other containers to establish trust.

C.

Use AWS Certificate Manager Private Certificate Authority (ACM PCA) to create a subordinate certificate authority, then create the private keys in the containers and sign them using the ACM PCA API.

D.

Use AWS Certificate Manager Private Certificate Authority (ACM PCA) to create a subordinate certificate authority, then use AWS Certificate Manager to generate the private certificates and deploy them to all the containers.

Answer: D

Explanation:

QUESTION NO: 111

The Accounting department at Example Corp. has made a decision to hire a third-party firm, AnyCompany, to monitor Example Corp.'s AWS account to help optimize costs.

The Security Engineer for Example Corp. has been tasked with providing AnyCompany with access to the required Example Corp. AWS resources. The Engineer has created an IAM role and granted permission to AnyCompany's AWS account to assume this role.

When customers contact AnyCompany, they provide their role ARN for validation. The Engineer is concerned that one of AnyCompany's other customers might deduce Example Corp.'s role ARN and potentially compromise the company's account.

What steps should the Engineer perform to prevent this outcome?

A.

Create an IAM user and generate a set of long-term credentials. Provide the credentials to AnyCompany. Monitor access in IAM access advisor and plan to rotate credentials on a recurring basis.

B.

Request an external ID from AnyCompany and add a condition with sts:ExternalId to the role's trust policy.

C.

Require two-factor authentication by adding a condition to the role's trust policy with aws:MultiFactorAuthPresent.

D.

Request an IP range from AnyCompany and add a condition with aws:SourceIp to the role's trust policy.

Answer: B

Reference:

https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_create_for-user_externalid.html

QUESTION NO: 112

A company maintains sensitive data in an Amazon S3 bucket that must be protected using an AWS KMS CMK. The company requires that keys be rotated automatically every year.

How should the bucket be configured?

A.

Select server-side encryption with Amazon S3-managed keys (SSE-S3) and select an AWS-managed CMK.

B.

Select Amazon S3-AWS KMS managed encryption keys (S3-KMS) and select a customer-managed CMK with key rotation enabled.

C.

Select server-side encryption with Amazon S3-managed keys (SSE-S3) and select a customer-managed CMK that has imported key material.

D.

Select server-side encryption with AWS KMS-managed keys (SSE-KMS) and select an alias to an AWS-managed CMK.

Answer: B

Reference:

<https://docs.aws.amazon.com/AmazonS3/latest/dev/UsingKMSEncryption.html>

QUESTION NO: 113

An Amazon S3 bucket is encrypted using an AWS KMS CMK. An IAM user is unable to download objects from the S3 bucket using the AWS Management Console; however, other users can download objects from the S3 bucket.

Which policies should the Security Engineer review and modify to resolve this issue? (Choose three.)

- A.**
The CMK policy
- B.**
The VPC endpoint policy
- C.**
The S3 bucket policy
- D.**
The S3 ACL
- E.**
The IAM policy

Answer: A,C,E

Reference:

<https://aws.amazon.com/premiumsupport/knowledge-center/decrypt-kms-encrypted-objects-s3/>

QUESTION NO: 114

While analyzing a company's security solution, a Security Engineer wants to secure the AWS account root user.

What should the Security Engineer do to provide the highest level of security for the account?

A.

Create a new IAM user that has administrator permissions in the AWS account. Delete the password for the AWS account root user.

B.

Create a new IAM user that has administrator permissions in the AWS account. Modify the permissions for the existing IAM users.

C.

Replace the access key for the AWS account root user. Delete the password for the AWS account root user.

D.

Create a new IAM user that has administrator permissions in the AWS account. Enable multi-factor authentication for the AWS account root user.

Answer: D

Explanation:

If you continue to use the root user credentials, we recommend that you follow the security best practice to enable multi-factor authentication (MFA) for your account. Because your root user can perform sensitive operations in your account, adding an additional layer of authentication helps you to better secure your account. Multiple types of MFA are available.

Reference:

https://docs.aws.amazon.com/IAM/latest/UserGuide/id_root-user.html

QUESTION NO: 115

A Security Engineer is working with a Product team building a web application on AWS. The application uses Amazon S3 to host the static content, Amazon API Gateway to provide RESTful services; and Amazon DynamoDB as the backend data store. The users already exist in a directory that is exposed through a SAML identity provider.

Which combination of the following actions should the Engineer take to enable users to be authenticated into the web application and call APIs? (Choose three.)

A.

Create a custom authorization service using AWS Lambda.

B.

Configure a SAML identity provider in Amazon Cognito to map attributes to the Amazon Cognito

user pool attributes.

C.

Configure the SAML identity provider to add the Amazon Cognito user pool as a relying party.

D.

Configure an Amazon Cognito identity pool to integrate with social login providers.

E.

Update DynamoDB to store the user email addresses and passwords.

F.

Update API Gateway to use a COGNITO_USER_POOLS authorizer.

Answer: B,C,F

Explanation:

QUESTION NO: 116

While securing the connection between a company's VPC and its on-premises data center, a Security Engineer sent a ping command from an on-premises host (IP address 203.0.113.12) to an Amazon EC2 instance (IP address 172.31.16.139). The ping command did not return a response. The flow log in the VPC showed the following:

```
2 123456789010 eni-1235b8ca 203.0.113.12 172.31.16.139 0 0 1 4 336 1432917027  
1432917142 ACCEPT OK
```

```
2 123456789010 eni-1235b8ca 172.31.16.139 203.0.113.12 0 0 1 4 336 1432917094  
1432917142 REJECT OK
```

What action should be performed to allow the ping to work?

A.

In the security group of the EC2 instance, allow inbound ICMP traffic.

B.

In the security group of the EC2 instance, allow outbound ICMP traffic.

C.

In the VPC's NACL, allow inbound ICMP traffic.

D.

In the VPC's NACL, allow outbound ICMP traffic.

Answer: D

Explanation:

QUESTION NO: 117

A Security Engineer is building a Java application that is running on Amazon EC2. The application communicates with an Amazon RDS instance and authenticates with a user name and password.

Which combination of steps can the Engineer take to protect the credentials and minimize downtime when the credentials are rotated? (Choose two.)

A.

Have a Database Administrator encrypt the credentials and store the ciphertext in Amazon S3. Grant permission to the instance role associated with the EC2 instance to read the object and decrypt the ciphertext.

B.

Configure a scheduled job that updates the credential in AWS Systems Manager Parameter Store and notifies the Engineer that the application needs to be restarted.

C.

Configure automatic rotation of credentials in AWS Secrets Manager.

D.

Store the credential in an encrypted string parameter in AWS Systems Manager Parameter Store. Grant permission to the instance role associated with the EC2 instance to access the parameter and the AWS KMS key that is used to encrypt it.

E.

Configure the Java application to catch a connection failure and make a call to AWS Secrets Manager to retrieve updated credentials when the password is rotated. Grant permission to the instance role associated with the EC2 instance to access Secrets Manager.

Answer: C,E

Explanation:

QUESTION NO: 118

A company has several production AWS accounts and a central security AWS account. The security account is used for centralized monitoring and has IAM privileges to all resources in every

corporate account. All of the company's Amazon S3 buckets are tagged with a value denoting the data classification of their contents.

A Security Engineer is deploying a monitoring solution in the security account that will enforce bucket policy compliance. The system must monitor S3 buckets in all production accounts and confirm that any policy change is in accordance with the bucket's data classification. If any change is out of compliance, the Security team must be notified quickly.

Which combination of actions would build the required solution? (Choose three.)

- A.**
Configure Amazon CloudWatch Events in the production accounts to send all S3 events to the security account event bus.
- B.**
Enable Amazon GuardDuty in the security account, and join the production accounts as members.
- C.**
Configure an Amazon CloudWatch Events rule in the security account to detect S3 bucket creation or modification events.
- D.**
Enable AWS Trusted Advisor and activate email notifications for an email address assigned to the security contact.
- E.**
Invoke an AWS Lambda function in the security account to analyze S3 bucket settings in response to S3 events, and send non-compliance notifications to the Security team.
- F.**
Configure event notifications on S3 buckets for PUT, POST, and DELETE events.

Answer: C,E,F

Explanation:

QUESTION NO: 119

A company plans to migrate a sensitive dataset to Amazon S3. A Security Engineer must ensure that the data is encrypted at rest. The encryption solution must enable the company to generate its own keys without needing to manage key storage or the encryption process.

What should the Security Engineer use to accomplish this?

- A.**
Server-side encryption with Amazon S3-managed keys (SSE-S3)
- B.**
Server-side encryption with AWS KMS-managed keys (SSE-KMS)
- C.**
Server-side encryption with customer-provided keys (SSE-C)
- D.**
Client-side encryption with an AWS KMS-managed CMK

Answer: B

Reference:

<https://aws.amazon.com/s3/faqs/>

QUESTION NO: 120

A Security Engineer is defining the logging solution for a newly developed product. Systems Administrators and Developers need to have appropriate access to event log files in AWS CloudTrail to support and troubleshoot the product.

Which combination of controls should be used to protect against tampering with and unauthorized access to log files? (Choose two.)

- A.**
Ensure that the log file integrity validation mechanism is enabled.
- B.**
Ensure that all log files are written to at least two separate Amazon S3 buckets in the same account.
- C.**
Ensure that Systems Administrators and Developers can edit log files, but prevent any other access.
- D.**
Ensure that Systems Administrators and Developers with job-related need-to-know requirements only are capable of viewing – but not modifying – the log files.
- E.**
Ensure that all log files are stored on Amazon EC2 instances that allow SSH access from the internal corporate network only.

Answer: A,D

Explanation:

QUESTION NO: 121

A company has a few dozen application servers in private subnets behind an Elastic Load Balancer (ELB) in an AWS Auto Scaling group. The application is accessed from the web over HTTPS. The data must always be encrypted in transit. The Security Engineer is worried about potential key exposure due to vulnerabilities in the application software.

Which approach will meet these requirements while protecting the external certificate during a breach?

A.

Use a Network Load Balancer (NLB) to pass through traffic on port 443 from the internet to port 443 on the instances.

B.

Purchase an external certificate, and upload it to the AWS Certificate Manager (for use with the ELB) and to the instances. Have the ELB decrypt traffic, and route and re-encrypt with the same certificate.

C.

Generate an internal self-signed certificate and apply it to the instances. Use AWS Certificate Manager to generate a new external certificate for the ELB. Have the ELB decrypt traffic, and route and re-encrypt with the internal certificate.

D.

Upload a new external certificate to the load balancer. Have the ELB decrypt the traffic and forward it on port 80 to the instances.

Answer: C

Explanation:

QUESTION NO: 122

Which of the following are valid event sources that are associated with web access control lists that trigger AWS WAF rules? (Choose two.)

- A.**
Amazon S3 static web hosting
- B.**
Amazon CloudFront distribution
- C.**
Application Load Balancer
- D.**
Amazon Route 53
- E.**
VPC Flow Logs

Answer: B,C

Explanation:

A web access control list (web ACL) gives you fine-grained control over the web requests that your Amazon API Gateway API, Amazon CloudFront distribution or Application Load Balancer responds to.

Reference:

<https://docs.aws.amazon.com/waf/latest/developerguide/web-acl.html>

QUESTION NO: 123

A company uses identity federation to authenticate users into an identity account (987654321987) where the users assume an IAM role named IdentityRole. The users then assume an IAM role named JobFunctionRole in the target AWS account (123456789123) to perform their job functions.

A user is unable to assume the IAM role in the target account. The policy attached to the role in the identity account is:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "sts:AssumeRole"
      ],
      "Resource": [
        "arn:aws:iam::*:role/JobFunctionRole"
      ],
      "Effect": "Allow"
    }
  ]
}
```

What should be done to enable the user to assume the appropriate role in the target account?

A.

Update the IAM policy attached to the role in the identity account to be:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "sts:AssumeRole"
      ],
      "Resource": [
        "arn:aws:iam::123456789123:role/JobFunctionRole"
      ],
      "Effect": "Allow"
    }
  ]
}
```

B.

Update the trust policy on the role in the target account to be:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::987654321987:role/IdentityRole"
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

C.

Update the trust policy on the role in the identity account to be:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::987654321987:root"
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

D.

Update the IAM policy attached to the role in the target account to be:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "Stmt1502946463000",
      "Effect": "Allow",
      "Action": "sts:AssumeRole",
      "Resource": "arn:aws:iam::123456789123:role/JobFunctionRole"
    }
  ]
}
```

Answer: A

Explanation:

QUESTION NO: 124

A Security Engineer is working with the development team to design a supply chain application that stores sensitive inventory data in an Amazon S3 bucket. The application will use an AWS KMS customer master key (CMK) to encrypt the data on Amazon S3. The inventory data on Amazon S3 will be shared with vendors. All vendors will use AWS principals from their own AWS accounts to access the data on Amazon S3. The vendor list may change weekly, and the solution must support cross-account access.

What is the MOST efficient way to manage access control for the KMS CMK?

- A.**
Use KMS grants to manage key access. Programmatically create and revoke grants to manage vendor access.
- B.**
Use an IAM role to manage key access. Programmatically update the IAM role policies to manage vendor access.
- C.**
Use KMS key policies to manage key access. Programmatically update the KMS key policies to manage vendor access.
- D.**
Use delegated access across AWS accounts by using IAM roles to manage key access. Programmatically update the IAM trust policy to manage cross-account vendor access.

Answer: A

Explanation:

QUESTION NO: 125

A Security Engineer is setting up an AWS CloudTrail trail for all regions in an AWS account. For added security, the logs are stored using server-side encryption with AWS KMS-managed keys (SSE-KMS) and have log integrity validation enabled.

While testing the solution, the Security Engineer discovers that the digest files are readable, but the log files are not. What is the MOST likely cause?

- A.**
The log files fail integrity validation and automatically are marked as unavailable.

B.

The KMS key policy does not grant the Security Engineer's IAM user or role permissions to decrypt with it.

C.

The bucket is set up to use server-side encryption with Amazon S3-managed keys (SSE-S3) as the default and does not allow SSE-KMS-encrypted files.

D.

An IAM policy applicable to the Security Engineer's IAM user or role denies access to the "CloudTrail/" prefix in the Amazon S3 bucket.

Answer: B

Explanation:

QUESTION NO: 126

A corporate cloud security policy states that communications between the company's VPC and KMS must travel entirely within the AWS network and not use public service endpoints.

Which combination of the following actions MOST satisfies this requirement? (Choose two.)

A.

Add the aws:sourceVpce condition to the AWS KMS key policy referencing the company's VPC endpoint ID.

B.

Remove the VPC internet gateway from the VPC and add a virtual private gateway to the VPC to prevent direct, public internet connectivity.

C.

Create a VPC endpoint for AWS KMS with private DNS enabled.

D.

Use the KMS Import Key feature to securely transfer the AWS KMS key over a VPN.

E.

Add the following condition to the AWS KMS key policy: "aws:SourceIp": "10.0.0.0/16".

Answer: A,C

Explanation:

An IAM policy can deny access to KMS except through your VPC endpoint with the following

condition statement:

```
"Condition": {  
  "StringNotEquals": {  
    "aws:sourceVpce": "vpce-0295a3caf8414c94a"  
  }  
}
```

If you select the Enable Private DNS Name option, the standard AWS KMS DNS hostname (<https://kms.<region>.amazonaws.com>) resolves to your VPC endpoint.

QUESTION NO: 127

A company had one of its Amazon EC2 key pairs compromised. A Security Engineer must identify which current Linux EC2 instances were deployed and used the compromised key pair.

How can this task be accomplished?

A.

Obtain the list of instances by directly querying Amazon EC2 using: `aws ec2 describe-instances --filters "Name=key-name,Values=KEYNAMEHERE"`.

B.

Obtain the fingerprint for the key pair from the AWS Management Console, then search for the fingerprint in the Amazon Inspector logs.

C.

Obtain the output from the EC2 instance metadata using: `curl http://169.254.169.254/latest/meta-data/public-keys/0/`.

D.

Obtain the fingerprint for the key pair from the AWS Management Console, then search for the fingerprint in Amazon CloudWatch Logs using: `aws logs filter-log-events`.

Answer: D

Explanation:

QUESTION NO: 128

A Security Engineer for a large company is managing a data processing application used by 1,500 subsidiary companies. The parent and subsidiary companies all use AWS. The application uses TCP port 443 and runs on Amazon EC2 behind a Network Load Balancer (NLB). For compliance reasons, the application should only be accessible to the subsidiaries and should not be available on the public internet. To meet the compliance requirements for restricted access, the Engineer has received the public and private CIDR block ranges for each subsidiary.

What solution should the Engineer use to implement the appropriate access restrictions for the application?

A.

Create a NACL to allow access on TCP port 443 from the 1,500 subsidiary CIDR block ranges. Associate the NACL to both the NLB and EC2 instances

B.

Create an AWS security group to allow access on TCP port 443 from the 1,500 subsidiary CIDR block ranges. Associate the security group to the NLB. Create a second security group for EC2 instances with access on TCP port 443 from the NLB security group.

C.

Create an AWS PrivateLink endpoint service in the parent company account attached to the NLB. Create an AWS security group for the instances to allow access on TCP port 443 from the AWS PrivateLink endpoint. Use AWS PrivateLink interface endpoints in the 1,500 subsidiary AWS accounts to connect to the data processing application.

D.

Create an AWS security group to allow access on TCP port 443 from the 1,500 subsidiary CIDR block ranges. Associate the security group with EC2 instances.

Answer: C

Explanation:

QUESTION NO: 129

To meet regulatory requirements, a Security Engineer needs to implement an IAM policy that restricts the use of AWS services to the us-east-1 Region.

What policy should the Engineer implement?

A.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

B.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "ec2:Region": "us-east-1"
        }
      }
    }
  ]
}
```

C.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": "*",
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

D.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "NotAction": "*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": "us-east-1"
        }
      }
    }
  ]
}
```

Answer: B

Explanation:

QUESTION NO: 130

A company uses user data scripts that contain sensitive information to bootstrap Amazon EC2 instances. A Security Engineer discovers that this sensitive information is viewable by people who should not have access to it.

What is the MOST secure way to protect the sensitive information used to bootstrap the instances?

A.

Store the scripts in the AMI and encrypt the sensitive data using AWS KMS. Use the instance role profile to control access to the KMS keys needed to decrypt the data.

B.

Store the sensitive data in AWS Systems Manager Parameter Store using the encrypted string parameter and assign the GetParameters permission to the EC2 instance role.

C.

Externalize the bootstrap scripts in Amazon S3 and encrypt them using AWS KMS. Remove the scripts from the instance and clear the logs after the instance is configured.

D.

Block user access of the EC2 instance's metadata service using IAM policies. Remove all scripts and clear the logs after execution.

Answer: A

Explanation:

QUESTION NO: 131

A company is building a data lake on Amazon S3. The data consists of millions of small files containing sensitive information. The Security team has the following requirements for the architecture:

Data must be encrypted in transit.

Data must be encrypted at rest.

The bucket must be private, but if the bucket is accidentally made public, the data must remain confidential.

Which combination of steps would meet the requirements? (Choose two.)

A.

Enable AES-256 encryption using server-side encryption with Amazon S3-managed encryption keys (SSE-S3) on the S3 bucket.

B.

Enable default encryption with server-side encryption with AWS KMS-managed keys (SSE-KMS) on the S3 bucket.

C.

Add a bucket policy that includes a deny if a PutObject request does not include `aws:SecureTransport`.

D.

Add a bucket policy with `aws:SourceIp` to Allow uploads and downloads from the corporate intranet only.

E.

Add a bucket policy that includes a deny if a PutObject request does not include `s3:x-amz-server-side-encryption:"aws:kms"`

F.

Enable Amazon Macie to monitor and act on changes to the data lake's S3 bucket.

Answer: B,C

Explanation:

Bucket encryption using KMS will protect both in case disks are stolen as well as if the bucket is public.

This is because the KMS key would need to have privileges granted to it for users outside of AWS.

QUESTION NO: 132

A Security Engineer discovered a vulnerability in an application running on Amazon ECS. The vulnerability allowed attackers to install malicious code. Analysis of the code shows it exfiltrates data on port 5353 in batches at random time intervals.

While the code of the containers is being patched, how can Engineers quickly identify all compromised hosts and stop the egress of data on port 5353?

A.

Enable AWS Shield Advanced and AWS WAF. Configure an AWS WAF custom filter for egress traffic on port 5353

B.

Enable Amazon Inspector on Amazon ECS and configure a custom assessment to evaluate containers that have port 5353 open. Update the NACLs to block port 5353 outbound.

C.

Create an Amazon CloudWatch custom metric on the VPC Flow Logs identifying egress traffic on port 5353. Update the NACLs to block port 5353 outbound.

D.

Use Amazon Athena to query AWS CloudTrail logs in Amazon S3 and look for any traffic on port 5353. Update the security groups to block port 5353 outbound.

Answer: C

Explanation:

QUESTION NO: 133

An Amazon EC2 instance is denied access to a newly created AWS KMS CMK used for decrypt actions. The environment has the following configuration:

The instance is allowed the kms:Decrypt action in its IAM role for all resources

The AWS KMS CMK status is set to enabled

The instance can communicate with the KMS API using a configured VPC endpoint

What is causing the issue?

A.

The kms:GenerateDataKey permission is missing from the EC2 instance's IAM role

B.

The ARN tag on the CMK contains the EC2 instance's ID instead of the instance's ARN

C.

The kms:Encrypt permission is missing from the EC2 IAM role

D.

The KMS CMK key policy that enables IAM user permissions is missing

Answer: D

Explanation:

In a key policy, you use "*" for the resource, which means "this CMK." A key policy applies only to the CMK it is attached to

Reference:

<https://docs.aws.amazon.com/kms/latest/developerguide/key-policies.html>

QUESTION NO: 134

A company has enabled Amazon GuardDuty in all Regions as part of its security monitoring strategy. In one of the VPCs, the company hosts an Amazon EC2 instance working as an FTP server that is contacted by a high number of clients from multiple locations. This is identified by GuardDuty as a brute force attack due to the high number of connections that happen every hour.

The finding has been flagged as a false positive. However, GuardDuty keeps raising the issue. A Security Engineer has been asked to improve the signal-to-noise ratio. The Engineer needs to ensure that changes do not compromise the visibility of potential anomalous behavior.

How can the Security Engineer address the issue?

A.

Disable the FTP rule in GuardDuty in the Region where the FTP server is deployed

B.

Add the FTP server to a trusted IP list and deploy it to GuardDuty to stop receiving the notifications

C.

Use GuardDuty filters with auto archiving enabled to close the findings

D.

Create an AWS Lambda function that closes the finding whenever a new occurrence is reported

Answer: B

Explanation:

Trusted IP lists consist of IP addresses that you have whitelisted for secure communication with your AWS infrastructure and applications. GuardDuty does not generate findings for IP addresses on trusted IP lists. At any given time, you can have only one uploaded trusted IP list per AWS account per region.

Reference:

https://docs.aws.amazon.com/guardduty/latest/ug/guardduty_upload_lists.html

QUESTION NO: 135

What are the MOST secure ways to protect the AWS account root user of a recently opened AWS account? (Choose two.)

A.
Use the AWS account root user access keys instead of the AWS Management Console

B.
Enable multi-factor authentication for the AWS IAM users with the AdministratorAccess managed policy attached to them

C.
Enable multi-factor authentication for the AWS account root user

D.
Use AWS KMS to encrypt all AWS account root user and AWS IAM access keys and set automatic rotation to 30 days

E.
Do not create access keys for the AWS account root user; instead, create AWS IAM users

Answer: B,D

Explanation:

QUESTION NO: 136

A company has decided to migrate sensitive documents from on-premises data centers to Amazon S3. Currently, the hard drives are encrypted to meet a compliance requirement regarding

data encryption. The CISO wants to improve security by encrypting each file using a different key instead of a single key. Using a different key would limit the security impact of a single exposed key.

Which of the following requires the LEAST amount of configuration when implementing this approach?

A.

Place each file into a different S3 bucket. Set the default encryption of each bucket to use a different AWS KMS customer managed key.

B.

Put all the files in the same S3 bucket. Using S3 events as a trigger, write an AWS Lambda function to encrypt each file as it is added using different AWS KMS data keys.

C.

Use the S3 encryption client to encrypt each file individually using S3-generated data keys.

D.

Place all the files in the same S3 bucket. Use server-side encryption with AWS KMS-managed keys (SSE-KMS) to encrypt the data.

Answer: D

Reference:

<https://docs.aws.amazon.com/kms/latest/developerguide/services-s3.html>

QUESTION NO: 137

A company has an encrypted Amazon S3 bucket. An Application Developer has an IAM policy that allows access to the S3 bucket, but the Application Developer is unable to access objects within the bucket.

What is a possible cause of the issue?

A.

The S3 ACL for the S3 bucket fails to explicitly grant access to the Application Developer

B.

The AWS KMS key for the S3 bucket fails to list the Application Developer as an administrator

C.

The S3 bucket policy fails to explicitly grant access to the Application Developer

D.

The S3 bucket policy explicitly denies access to the Application Developer

Answer: C

Reference:

<https://docs.aws.amazon.com/AmazonS3/latest/dev/example-bucket-policies.html>

QUESTION NO: 138

A Web Administrator for the website example.com has created an Amazon CloudFront distribution for dev.example.com, with a requirement to configure HTTPS using a custom TLS certificate imported to AWS Certificate Manager.

Which combination of steps is required to ensure availability of the certificate in the CloudFront console? (Choose two.)

A.

Call UploadServerCertificate with /cloudfront/dev/ in the path parameter.

B.

Import the certificate with a 4,096-bit RSA public key.

C.

Ensure that the certificate, private key, and certificate chain are PKCS #12-encoded.

D.

Import the certificate in the us-east-1 (N. Virginia) Region.

E.

Ensure that the certificate, private key, and certificate chain are PEM-encoded.

Answer: B,D

Explanation:

QUESTION NO: 139

A Security Engineer has discovered that, although encryption was enabled on the Amazon S3 bucket `examplebucket`, anyone who has access to the bucket has the ability to retrieve the files. The Engineer wants to limit access so each IAM user can access an assigned folder only.

What should the Security Engineer do to achieve this?

- A.**
Use envelope encryption with the AWS-managed CMK `aws/s3`.
- B.**
Create a customer-managed CMK with a key policy granting `kms:Decrypt` based on the `"${aws:username}"` variable.
- C.**
Create a customer-managed CMK for each user. Add each user as a key user in their corresponding key policy.
- D.**
Change the applicable IAM policy to grant S3 access to "Resource":
`"arn:aws:s3:::examplebucket/${aws:username}/*"`

Answer: D

Reference:

<https://aws.amazon.com/premiumsupport/knowledge-center/iam-s3-user-specific-folder/>

QUESTION NO: 140

A Security Engineer manages AWS Organizations for a company. The Engineer would like to restrict AWS usage to allow Amazon S3 only in one of the organizational units (OUs). The Engineer adds the following SCP to the OU:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowS3",
      "Effect": "Allow",
      "Action": "s3:*",
      "Resource": "*"
    }
  ]
}
```

The next day, API calls to AWS IAM appear in AWS CloudTrail logs in an account under that OU.

How should the Security Engineer resolve this issue?

A.

Move the account to a new OU and deny IAM:* permissions.

B.

Add a Deny policy for all non-S3 services at the account level.

C.

Change the policy to:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowS3",
      "Effect": "Allow",
      "Action": "s3:*",
      "Resource": "*/*"
    }
  ]
}
```

D.

Detach the default FullAWSAccess SCP.

Answer: B

Reference:

<https://docs.aws.amazon.com/organizations/latest/userguide/organizations-userguide.pdf> (22)

QUESTION NO: 141

A Developer is creating an AWS Lambda function that requires environment variables to store connection information and logging settings. The Developer is required to use an AWS KMS Customer Master Key (CMK) supplied by the Information Security department in order to adhere to company standards for securing Lambda environment variables.

Which of the following are required for this configuration to work? (Choose two.)

A.

The Developer must configure Lambda access to the VPC using the `--vpc-config` parameter.

B.

The Lambda function execution role must have the `kms:Decrypt` permission added in the AWS IAM policy.

C.

The KMS key policy must allow permissions for the Developer to use the KMS key.

D.

The AWS IAM policy assigned to the Developer must have the `kms:GenerateDataKey` permission added.

E.

The Lambda execution role must have the `kms:Encrypt` permission added in the AWS IAM policy.

Answer: D,E

Explanation:

QUESTION NO: 142

A Developer signed in to a new account within an AWS Organizations organizational unit (OU) containing multiple accounts. Access to the Amazon S3 service is restricted with the following SCP:


```
{  
  "Version": "2012-10-17",  
  "Statement": [  
    {  
      "Effect": "Deny",  
      "Action": "s3:*",  
      "Resource": "*"   
    }  
  ]  
}
```

How can the Security Engineer provide the Developer with Amazon S3 access without affecting other accounts?

- A.**
Move the SCP to the root OU of Organizations to remove the restriction to access Amazon S3.
- B.**
Add an IAM policy for the Developer, which grants S3 access.
- C.**
Create a new OU without applying the SCP restricting S3 access. Move the Developer account to this new OU.
- D.**
Add an allow list for the Developer account for the S3 service.

Answer: C

Explanation:

QUESTION NO: 143

A company has several workloads running on AWS. Employees are required to authenticate using on-premises ADFS and SSO to access the AWS Management Console. Developers migrated an existing legacy web application to an Amazon EC2 instance. Employees need to access this application from anywhere on the internet, but currently, there is no authentication system built into the application.

How should the Security Engineer implement employee-only access to this system without changing the application?

A.

Place the application behind an Application Load Balancer (ALB). Use Amazon Cognito as authentication for the ALB. Define a SAML-based Amazon Cognito user pool and connect it to ADFS.

B.

Implement AWS SSO in the master account and link it to ADFS as an identity provider. Define the EC2 instance as a managed resource, then apply an IAM policy on the resource.

C.

Define an Amazon Cognito identity pool, then install the connector on the Active Directory server. Use the Amazon Cognito SDK on the application instance to authenticate the employees using their Active Directory user names and passwords.

D.

Create an AWS Lambda custom authorizer as the authenticator for a reverse proxy on Amazon EC2. Ensure the security group on Amazon EC2 only allows access from the Lambda function.

Answer: C

Explanation:

QUESTION NO: 144

An Application Developer is using an AWS Lambda function that must use AWS KMS to perform encrypt and decrypt operations for API keys that are less than 2 KB.

Which key policy would allow the application to do this while granting least privilege?

A.

```
{
  "Sid": "AllowUserOfTheKey",
  "Effect": "Allow",
  "Principal": {"AWS": "arn:aws:iam::444455556666:role/EncryptionApp"},
  "Action": [
    "kms:*"
  ],
  "Resource": "*"
}
```

B.

```
{
  "Sid": "AllowUserOfTheKey",
  "Effect": "Allow",
  "Principal": {"AWS": "arn:aws:iam::444455556666:role/EncryptionApp"},
  "Action": [
    "kms:Encrypt",
    "kms:Decrypt"
  ],
  "Resource": "*"
}
```

C.

```
{
  "Sid": "AllowUserOfTheKey",
  "Effect": "Allow",
  "Principal": {"AWS": "arn:aws:iam::444455556666:role/EncryptionApp"},
  "Action": [
    "kms:DescribeKey",
    "kms:GenerateDataKey*",
    "kms:Encrypt",
    "kms:ReEncrypt*",
    "kms:Decrypt"
  ],
  "Resource": "*"
}
```

D.

```
{
  "Sid": "AllowUserOfTheKey",
  "Effect": "Allow",
  "Principal": {"AWS": "arn:aws:iam::444455556666:role/EncryptionApp"},
  "Action": [
    "kms:DescribeKey",
    "kms:GenerateDataKey*",
    "kms:Encrypt",
    "kms:ReEncrypt*",
    "kms:Disable*",
    "kms:Decrypt"
  ],
  "Resource": "*"
}
```

Answer: C

Explanation:

QUESTION NO: 145

A company is migrating its legacy workloads to AWS. The current security information events management (SIEM) system that analyzes logs is aging, and different SIEM systems are being

evaluated to replace it. The company wants to change SIEMs without re-architecture the solution.

What should the Security Engineer do to accomplish this with minimal operational impact?

A.

Prepare an AMI with the SIEM log forwarder agent for each workload, and configure it to send logs to a centralized SIEM located in the Security team AWS account. Configure an Amazon EC2 instance base AMI to forward logs to its local log forwarder agent. Deploy an AMI in each workload.

B.

Configure an Amazon EC2 base AMI with an Amazon Kinesis Agent, and configure it to send to Amazon Kinesis Data Streams in the Security team AWS account. Add an AWS Lambda function at Kinesis Data Streams to push streamed logs to the SIEM.

C.

Configure an Amazon EC2 base AMI to send logs to a local AWS CloudTrail log file. Configure CloudTrail to send logs to Amazon CloudWatch. Set up a central SIEM in the Security team AWS account and configure a puller to get information on CloudWatch.

D.

Select a pay-per-use SIEM in the AWS Marketplace. Deploy the AMI in each workload to provide elasticity when required. Use Amazon Athena to send real-time alerts.

Answer: B

Explanation:

QUESTION NO: 146

An Application team has requested a new AWS KMS master key for use with Amazon S3, but the organizational security policy requires separate master keys for different AWS services to limit blast radius.

How can an AWS KMS customer master key (CMK) be constrained to work with only Amazon S3?

A.

Configure the CMK key policy to allow only the Amazon S3 service to use the kms:Encrypt action.

B.

Configure the CMK key policy to allow AWS KMS actions only when the kms:ViaService condition matches the Amazon S3 service name.

C.

Configure the IAM user's policy to allow KMS to pass a role to Amazon S3.

D.

Configure the IAM user's policy to allow only Amazon S3 operations when they are combined with the CMK.

Answer: B

Reference:

<https://www.slideshare.net/AmazonWebServices/protecting-your-data-with-aws-kms-and-aws-cloudhsm> (17)

QUESTION NO: 147

A company is developing a highly resilient application to be hosted on multiple Amazon EC2 instances. The application will store highly sensitive user data in Amazon RDS tables.

The application must:

- Include migration to a different AWS Region in the application disaster recovery plan.

- Provide a full audit trail of encryption key administration events.

- Allow only company administrators to administer keys.

- Protect data at rest using application layer encryption.

A Security Engineer is evaluating options for encryption key management.

Why should the Security Engineer choose AWS CloudHSM over AWS KMS for encryption key management in this situation?

A.

The key administration event logging generated by CloudHSM is significantly more extensive than AWS KMS.

B.

CloudHSM ensures that only company support staff can administer encryption keys, whereas AWS KMS allows AWS staff to administer keys.

C.

The ciphertext produced by CloudHSM provides more robust protection against brute force

decryption attacks than the ciphertext produced by AWS KMS.

D.

CloudHSM provides the ability to copy keys to a different Region, whereas AWS KMS does not.

Answer: B

Explanation:

QUESTION NO: 148

A global company must mitigate and respond to DDoS attacks at Layers 3, 4 and 7. All of the company's AWS applications are serverless with static content hosted on Amazon S3 using Amazon CloudFront and Amazon Route 53.

Which solution will meet these requirements?

A.

Use AWS WAF with an upgrade to the AWS Business support plan.

B.

Use AWS Certificate Manager with an Application Load Balancer configured with an origin access identity.

C.

Use AWS Shield Advanced.

D.

Use AWS WAF to protect AWS Lambda functions encrypted with AWS KMS, and a NACL restricting all ingress traffic.

Answer: C

Reference:

<https://aws.amazon.com/shield/faqs/>

QUESTION NO: 149

A Security Engineer signed in to the AWS Management Console as an IAM user and switched to the security role IAM role. To perform a maintenance operation, the Security Engineer needs to

switch to the maintainer role IAM role, which lists the security role as a trusted entity. The Security Engineer attempts to switch to the maintainer role, but it fails.

What is the likely cause of the failure?

A.

The security role and the maintainer role are not assigned to the IAM user that the Security Engineer used to sign in to the account.

B.

The Security Engineer should have logged in as the AWS account root user, which is allowed to assume any role directly.

C.

The maintainer role does not include the IAM user as a trusted entity.

D.

The security role does not include a statement in its policy to allow an sts:AssumeRole action.

Answer: D

Reference:

<https://aws.amazon.com/premiumsupport/knowledge-center/troubleshoot-iam-policy-issues/>

QUESTION NO: 150

A company is configuring three Amazon EC2 instances with each instance in a separate Availability Zone. The EC2 instances will be used as transparent proxies for outbound internet traffic for ports 80 and 443 so the proxies can block traffic to certain internet destinations as required by the company's security policies. A Security Engineer completed the following:

Set up the proxy software on the EC2 instances.

Modified the route tables on the private subnets to use the proxy EC2 instances as the default route.

Created a security group rule opening inbound port 80 and 443 TCP protocols on the proxy EC2 instance security group.

However, the proxy EC2 instances are not successfully forwarding traffic to the internet.

What should the Security Engineer do to make the proxy EC2 instances route traffic to the

internet?

A.

Put all the proxy EC2 instances in a cluster placement group.

B.

Disable source and destination checks on the proxy EC2 instances.

C.

Open all inbound ports on the proxy EC2 instance security group.

D.

Change the VPC's DHCP domain-name-servers options set to the IP addresses of proxy EC2 instances.

Answer: B

Reference:

https://docs.aws.amazon.com/vpc/latest/userguide/VPC_NAT_Instance.html

QUESTION NO: 151

For compliance reasons, a Security Engineer must produce a weekly report that lists any instance that does not have the latest approved patches applied. The Engineer must also ensure that no system goes more than 30 days without the latest approved updates being applied.

What would be the MOST efficient way to achieve these goals?

A.

Use Amazon Inspector to determine which systems do not have the latest patches applied, and after 30 days, redeploy those instances with the latest AMI version.

B.

Configure Amazon EC2 Systems Manager to report on instance patch compliance, and enforce updates during the defined maintenance windows.

C.

Examine AWS CloudTrail logs to determine whether any instances have not restarted in the last 30 days, and redeploy those instances.

D.

Update the AMIs with the latest approved patches, and redeploy each instance during the defined maintenance window.

Answer: D

Explanation:

QUESTION NO: 152

A company is operating an open-source software platform that is internet facing. The legacy software platform no longer receives security updates. The software platform operates using Amazon Route 53 weighted load balancing to send traffic to two Amazon EC2 instances that connect to an Amazon RDS cluster. A recent report suggests this software platform is vulnerable to SQL injection attacks, with samples of attacks provided. The company's Security Engineer must secure this system against SQL injection attacks within 24 hours. The Security Engineer's solution must involve the least amount of effort and maintain normal operations during implementation.

What should the Security Engineer do to meet these requirements?

A.

Create an Application Load Balancer with the existing EC2 instances as a target group. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the ALB. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to the ALB. Update security groups on the EC2 instances to prevent direct access from the internet.

B.

Create an Amazon CloudFront distribution specifying one EC2 instance as an origin. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the distribution. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to CloudFront.

C.

Obtain the latest source code for the platform and make the necessary updates. Test the updated code to ensure that the vulnerability has been mitigated, then deploy the patched version of the platform to the EC2 instances.

D.

Update the security group that is attached to the EC2 instances, removing access from the internet to the TCP port used by the SQL database. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the EC2 instances. Test to ensure the vulnerability has been mitigated, then restore the security group to the original setting.

Answer: A

Explanation:

QUESTION NO: 153

A recent security audit found that AWS CloudTrail logs are insufficiently protected from tampering and unauthorized access.

Which actions must the Security Engineer take to address these audit findings? (Choose three.)

- A.**
Ensure CloudTrail log file validation is turned on.
- B.**
Configure an S3 lifecycle rule to periodically archive CloudTrail logs into Glacier for long-term storage.
- C.**
Use an S3 bucket with tight access controls that exists in a separate account.
- D.**
Use Amazon Inspector to monitor the file integrity of CloudTrail log files.
- E.**
Request a certificate through ACM and use a generated certificate private key to encrypt CloudTrail log files.
- F.**
Encrypt the CloudTrail log files with server-side encryption AWS KMS-managed keys (SSE-KMS).

Answer: A,B,F

Reference:

<https://docs.aws.amazon.com/awscloudtrail/latest/userguide/best-practices-security.html>

QUESTION NO: 154

A company's Developers plan to migrate their on-premises applications to Amazon EC2 instances running Amazon Linux AMIs. The applications are accessed by a group of partner companies. The Security Engineer needs to implement the following host-based security measures for these instances:

Block traffic from documented known bad IP addresses.

Detect known software vulnerabilities and CIS Benchmarks compliance.

Which solution addresses these requirements?

A.

Launch the EC2 instances with an IAM role attached. Include a user data script that uses the AWS CLI to retrieve the list of bad IP addresses from AWS Secrets Manager, and uploads it as a threat list in Amazon GuardDuty. Use Amazon Inspector to scan the instances for known software vulnerabilities and CIS Benchmarks compliance.

B.

Launch the EC2 instances with an IAM role attached. Include a user data script that uses the AWS CLI to create NACLs blocking ingress traffic from the known bad IP addresses in the EC2 instance's subnets. Use AWS Systems Manager to scan the instances for known software vulnerabilities, and AWS Trusted Advisor to check instances for CIS Benchmarks compliance.

C.

Launch the EC2 instances with an IAM role attached. Include a user data script that uses the AWS CLI to create and attach security groups that only allow an allow listed source IP address range inbound. Use Amazon Inspector to scan the instances for known software vulnerabilities, and AWS Trusted Advisor to check instances for CIS Benchmarks compliance.

D.

Launch the EC2 instances with an IAM role attached. Include a user data script that creates a cron job to periodically retrieve the list of bad IP addresses from Amazon S3, and configures iptables on the instances blocking the list of bad IP addresses. Use Amazon Inspector to scan the instances for known software vulnerabilities and CIS Benchmarks compliance.

Answer: C

Explanation:

QUESTION NO: 155

A Security Architect has been asked to review an existing security architecture and identify why the application servers cannot successfully initiate a connection to the database servers. The following summary describes the architecture:

1. An Application Load Balancer, an internet gateway and a NAT gateway are configured in the public subnet.
2. Database, application, and web servers are configured on three different private subnets.
3. The VPC has two route tables: one for the public subnet and one for all other subnets. The

route table for the public subnet has a 0.0.0.0/0 route to the internet gateway. The route table for all other subnets has a 0.0.0.0/0 route to the NAT gateway. All private subnets can route to each other.

4. Each subnet has a network ACL implemented that limits all inbound and outbound connectivity to only the required ports and protocols.

5. There are 3 Security Groups (SGs): database, application, and web. Each group limits all inbound and outbound connectivity to the minimum required.

Which of the following accurately reflects the access control mechanisms the Architect should verify?

A.

Outbound SG configuration on database servers

Inbound SG configuration on application servers

Inbound and outbound network ACL configuration on the database subnet

Inbound and outbound network ACL configuration on the application server subnet

B.

Inbound SG configuration on database servers

Outbound SG configuration on application servers

Inbound and outbound network ACL configuration on the database subnet

Inbound and outbound network ACL configuration on the application server subnet

C.

Inbound and outbound SG configuration on database servers

Inbound and outbound SG configuration on application servers

Inbound network ACL configuration on the database subnet

Outbound network ACL configuration on the application server subnet

D.

Inbound SG configuration on database servers

Outbound SG configuration on application servers

Inbound network ACL configuration on the database subnet

Outbound network ACL configuration on the application server subnet

Answer: C

Explanation:

QUESTION NO: 156

Developers in an organization have moved from a standard application deployment to containers. The Security Engineer is tasked with ensuring that containers are secure.

Which strategies will reduce the attack surface and enhance the security of the containers? (Choose two.)

- A.**
Use the containers to automate security deployments.
- B.**
Limit resource consumption (CPU, memory), networking connections, ports, and unnecessary container libraries.
- C.**
Segregate container by host, function, and data classification.
- D.**
Use Docker Notary framework to sign task definitions.
- E.**
Enable container breakout at the host kernel.

Answer: B,D

Explanation:

QUESTION NO: 157

Auditors for a health care company have mandated that all data volumes be encrypted at rest. Infrastructure is deployed mainly via AWS CloudFormation; however, third-party frameworks and manual deployment are required on some legacy systems.

What is the BEST way to monitor, on a recurring basis, whether all EBS volumes are encrypted?

- A.**
On a recurring basis, update all IAM user policies to require that EC2 instances are created with

an encrypted volume.

B.

Configure an AWS Config rule to run on a recurring basis for volume encryption.

C.

Set up Amazon Inspector rules for volume encryption to run on a recurring schedule.

D.

Use CloudWatch Logs to determine whether instances were created with an encrypted volume.

Answer: B

Explanation:

Using AWS Config Rules, you can run continuous assessment checks on your resources to verify that they comply with your own security policies, industry best practices, and compliance regimes such as PCI/HIPAA. For example, AWS Config provides a managed AWS Config Rules to ensure that encryption is turned on for all EBS volumes in your account. You can also write a custom AWS Config Rule to essentially “codify” your own corporate security policies. AWS Config alerts you in real time when a resource is misconfigured, or when a resource violates a particular security policy.

Reference:

<https://d1.awsstatic.com/whitepapers/aws-security-whitepaper.pdf>

QUESTION NO: 158

A company became aware that one of its access keys was exposed on a code sharing website 11 days ago. A Security Engineer must review all use of the exposed keys to determine the extent of the exposure. The company enabled AWS CloudTrail in all regions when it opened the account.

Which of the following will allow the Security Engineer to complete the task?

A.

Filter the event history on the exposed access key in the CloudTrail console. Examine the data from the past 11 days.

B.

Use the AWS CLI to generate an IAM credential report. Extract all the data from the past 11 days.

C.

Use Amazon Athena to query the CloudTrail logs from Amazon S3. Retrieve the rows for the

exposed access key for the past 11 days.

D.

Use the Access Advisor tab in the IAM console to view all of the access key activity for the past 11 days.

Answer: A

Reference:

<https://aws.amazon.com/premiumsupport/knowledge-center/cloudtrail-search-for-activity/>

QUESTION NO: 159

A Development team has built an experimental environment to test a simple static web application. It has built an isolated VPC with a private and a public subnet. The public subnet holds only an Application Load Balancer, a NAT gateway, and an internet gateway. The private subnet holds all of the Amazon EC2 instances.

There are 3 different types of servers. Each server type has its own Security Group that limits access to only required connectivity. The Security Groups have both inbound and outbound rules applied. Each subnet has both inbound and outbound network ACLs applied to limit access to only required connectivity.

Which of the following should the team check if a server cannot establish an outbound connection to the internet? (Choose three.)

A.

The route tables and the outbound rules on the appropriate private subnet security group.

B.

The outbound network ACL rules on the private subnet and the inbound network ACL rules on the public subnet.

C.

The outbound network ACL rules on the private subnet and both the inbound and outbound rules on the public subnet.

D.

The rules on any host-based firewall that may be applied on the Amazon EC2 instances.

E.

The Security Group applied to the Application Load Balancer and NAT gateway.

F.

That the 0.0.0.0/0 route in the private subnet route table points to the Internet gateway in the public subnet.

Answer: C,D,E

Explanation:

QUESTION NO: 160

Example.com is hosted on Amazon EC2 instance behind an Application Load Balancer (ALB). Third-party host intrusion detection system (HIDS) agents that capture the traffic of the EC2 instance are running on each host. The company must ensure they are using privacy enhancing technologies for users, without losing the assurance the third-party solution offers.

What is the MOST secure way to meet these requirements?

A.

Enable TLS pass through on the ALB, and handle decryption at the server using Elliptic Curve Diffie-Hellman (ECDHE) cipher suites.

B.

Create a listener on the ALB that uses encrypted connections with Elliptic Curve Diffie-Hellman (ECDHE) cipher suites, and pass the traffic in the clear to the server.

C.

Create a listener on the ALB that uses encrypted connections with Elliptic Curve Diffie-Hellman (ECDHE) cipher suites, and use encrypted connections to the servers that do not enable Perfect Forward Secrecy (PFS).

D.

Create a listener on the ALB that does not enable Perfect Forward Secrecy (PFS) cipher suites, and use encrypted connections to the servers using Elliptic Curve Diffie-Hellman (ECDHE) cipher suites.

Answer: C

Explanation:

QUESTION NO: 161

A Website currently runs on Amazon EC2, with mostly static content on the site. Recently, the site was subjected to a DDoS attack, and a Security Engineer was tasked with redesigning the edge security to help mitigate this risk in the future.

What are some ways the Engineer could achieve this? (Choose three.)

- A.**
Use AWS X-Ray to inspect the traffic going to the EC2 instances.
- B.**
Move the static content to Amazon S3, and front this with an Amazon CloudFront distribution.
- C.**
Change the security group configuration to block the source of the attack traffic.
- D.**
Use AWS WAF security rules to inspect the inbound traffic.
- E.**
Use Amazon Inspector assessment templates to inspect the inbound traffic.
- F.**
Use Amazon Route 53 to distribute traffic.

Answer: A,B,E

Explanation:

QUESTION NO: 162

A company manages three separate AWS accounts for its production, development, and test environments. Each Developer is assigned a unique IAM user under the development account. A new application hosted on an Amazon EC2 instance in the development account requires read access to the archived documents stored in an Amazon S3 bucket in the production account.

How should access be granted?

- A.**
Create an IAM role in the production account and allow EC2 instance in the development account to assume that role using the trust policy. Provide read access for the required S3 bucket to this role.
- B.**
Use a custom identity broker to allow Developer IAM users to temporarily access the S3 bucket.

C.

Create a temporary IAM user for the application to use in the production account.

D.

Create a temporary IAM user in the production account and provide read access to Amazon S3. Generate the temporary IAM user's access key and secret key and store these keys on the EC2 instance used by the application in the development account.

Answer: A

Explanation:

QUESTION NO: 163

A company requires that SSH commands used to access its AWS instance be traceable to the user who executed each command.

How should a Security Engineer accomplish this?

A.

Allow inbound access on port 22 at the security group attached to the instance. Use AWS Systems Manager Session Manager for shell access to Amazon EC2 instances with the user tag defined. Enable Amazon CloudWatch logging for Systems Manager sessions.

B.

Use Amazon S3 to securely store one Privacy Enhanced Mail Certificate (PEM file) for each user. Allow Amazon EC2 to read from Amazon S3 and import every user that wants to use SSH to access EC2 instances. Allow inbound access on port 22 at the security group attached to the instance. Install the Amazon CloudWatch agent on the EC2 instance and configure it to ingest audit logs for the instance.

C.

Deny inbound access on port 22 at the security group attached to the instance. Use AWS Systems Manager Session Manager for shell access to Amazon EC2 instances with the user tag defined. Enable Amazon CloudWatch logging for Systems Manager sessions.

D.

Use Amazon S3 to securely store one Privacy Enhanced Mail Certificate (PEM file) for each team or group. Allow Amazon EC2 to read from Amazon S3 and import every user that wants to use SSH to access EC2 instances. Allow inbound access on port 22 at the security group attached to the instance. Install the Amazon CloudWatch agent on the EC2 instance and configure it to ingest audit logs for the instance.

Answer: D

Explanation:

QUESTION NO: 164

An organization must establish the ability to delete an AWS KMS Customer Master Key (CMK) within a 24-hour timeframe to keep it from being used for encrypt or decrypt operations.

Which of the following actions will address this requirement?

- A.**
Manually rotate a key within KMS to create a new CMK immediately.
- B.**
Use the KMS import key functionality to execute a delete key operation.
- C.**
Use the schedule key deletion function within KMS to specify the minimum wait period for deletion.
- D.**
Change the KMS CMK alias to immediately prevent any services from using the CMK.

Answer: C

Reference:

<https://docs.aws.amazon.com/kms/latest/developerguide/deleting-keys.html>

QUESTION NO: 165

A company uses Microsoft Active Directory for access management for on-premises resources, and wants to use the same mechanism for accessing its AWS accounts. Additionally, the Development team plans to launch a public-facing application for which they need a separate authentication solution.

Which combination of the following would satisfy these requirements? (Choose two.)

- A.**
Set up domain controllers on Amazon EC2 to extend the on-premises directory to AWS.

B.

Establish network connectivity between on-premises and the user's VPC.

C.

Use Amazon Cognito user pools for application authentication.

D.

Use AD Connector for application authentication.

E.

Set up federated sign-in to AWS through ADFS and SAML.

Answer: A,B

Explanation:

QUESTION NO: 166

A company wants to encrypt the private network between its on-premises environment and AWS. The company also wants a consistent network experience for its employees.

What should the company do to meet these requirements?

A.

Establish an AWS Direct Connect connection with AWS and set up a Direct Connect gateway. In the Direct Connect gateway configuration, enable IPsec and BGP, and then leverage native AWS network encryption between Availability Zones and Regions.

B.

Establish an AWS Direct Connect connection with AWS and set up a Direct Connect gateway. Using the Direct Connect gateway, create a private virtual interface and advertise the customer gateway private IP addresses. Create a VPN connection using the customer gateway and the virtual private gateway.

C.

Establish a VPN connection with the AWS virtual private cloud over the Internet.

D.

Establish an AWS Direct Connect connection with AWS and establish a public virtual interface. For prefixes that need to be advertised, enter the customer gateway public IP addresses. Create a VPN connection over Direct Connect using the customer gateway and the virtual private gateway.

Answer: C

Explanation:

QUESTION NO: 167

A company's Security Engineer has been tasked with restricting a contractor's IAM account access to the company's Amazon EC2 console without providing access to any other AWS services. The contractor's IAM account must not be able to gain access to any other AWS service, even if the IAM account is assigned additional permissions based on IAM group membership.

What should the Security Engineer do to meet these requirements?

- A.**
Create an Inline IAM user policy that allows for Amazon EC2 access for the contractor's IAM user.
- B.**
Create an IAM permissions boundary policy that allows Amazon EC2 access. Associate the contractor's IAM account with the IAM permissions boundary policy.
- C.**
Create an IAM group with an attached policy that allows for Amazon EC2 access. Associate the contractor's IAM account with the IAM group.
- D.**
Create an IAM role that allows for EC2 and explicitly denies all other services. Instruct the contractor to always assume this role.

Answer: B

Explanation:

QUESTION NO: 168

A company recently performed an annual security assessment of its AWS environment. The assessment showed the audit logs are not available beyond 90 days and that unauthorized changes to IAM policies are made without detection.

How should a Security Engineer resolve these issues?

- A.**
Create an Amazon S3 lifecycle policy that archives AWS CloudTrail trail logs to Amazon S3

Glacier after 90 days. Configure Amazon Inspector to provide a notification when a policy change is made to resources.

B.

Configure AWS Artifact to archive AWS CloudTrail logs. Configure AWS Trusted Advisor to provide a notification when a policy change is made to resources.

C.

Configure Amazon CloudWatch to export log groups to Amazon S3. Configure AWS CloudTrail to provide a notification when a policy change is made to resources.

D.

Create an AWS CloudTrail trail that stores audit logs in Amazon S3. Configure an AWS Config rule to provide a notification when a policy change is made to resources.

Answer: A

Explanation:

QUESTION NO: 169

A Security Engineer is asked to update an AWS CloudTrail log file prefix for an existing trail. When attempting to save the change in the CloudTrail console, the Security Engineer receives the following error message: "There is a problem with the bucket policy."

What will enable the Security Engineer to save the change?

A.

Create a new trail with the updated log file prefix, and then delete the original trail. Update the existing bucket policy in the Amazon S3 console with the new log file prefix, and then update the log file prefix in the CloudTrail console.

B.

Update the existing bucket policy in the Amazon S3 console to allow the Security Engineer's Principal to perform PutBucketPolicy, and then update the log file prefix in the CloudTrail console.

C.

Update the existing bucket policy in the Amazon S3 console with the new log file prefix, and then update the log file prefix in the CloudTrail console.

D.

Update the existing bucket policy in the Amazon S3 console to allow the Security Engineer's Principal to perform GetBucketPolicy, and then update the log file prefix in the CloudTrail console.

Answer: C

Reference:

<https://docs.aws.amazon.com/awscloudtrail/latest/userguide/create-s3-bucket-policy-for-cloudtrail.html>

QUESTION NO: 170

A company needs a forensic-logging solution for hundreds of applications running in Docker on Amazon EC2. The solution must perform real-time analytics on the logs, must support the replay of messages, and must persist the logs.

Which AWS services should be used to meet these requirements? (Choose two.)

- A.**
Amazon Athena
- B.**
Amazon Kinesis
- C.**
Amazon SQS
- D.**
Amazon Elasticsearch
- E.**
Amazon EMR

Answer: B,D

Explanation:

QUESTION NO: 171

A company's architecture requires that its three Amazon EC2 instances run behind an Application Load Balancer (ALB). The EC2 instances transmit sensitive data between each other. Developers use SSL certificates to encrypt the traffic between the public users and the ALB. However, the Developers are unsure of how to encrypt the data in transit between the ALB and the EC2 instances and the traffic between the EC2 instances.

Which combination of activities must the company implement to meet its encryption requirements? (Choose two.)

A.

Configure SSL/TLS on the EC2 instances and configure the ALB target group to use HTTPS.

B.

Ensure that all resources are in the same VPC so the default encryption provided by the VPC is used to encrypt the traffic between the EC2 instances.

C.

In the ALB, select the default encryption to encrypt the traffic between the ALB and the EC2 instances.

D.

In the code for the application, include a cryptography library and encrypt the data before sending it between the EC2 instances.

E.

Configure AWS Direct Connect to provide an encrypted tunnel between the EC2 instances.

Answer: A,E

Explanation:

QUESTION NO: 172

A Security Engineer has launched multiple Amazon EC2 instances from a private AMI using an AWS CloudFormation template. The Engineer notices instances terminating right after they are launched.

What could be causing these terminations?

A.

The IAM user launching those instances is missing ec2:RunInstances permissions

B.

The AMI used was encrypted and the IAM user does not have the required AWS KMS permissions

C.

The instance profile used with the EC2 instances is unable to query instance metadata

D.

AWS currently does not have sufficient capacity in the Region

Answer: B

Reference:

<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/troubleshooting-launch.html>

QUESTION NO: 173

Authorized Administrators are unable to connect to an Amazon EC2 Linux bastion host using SSH over the Internet. The connection either fails to respond or generates the following error message:

Network error: Connection timed out.

What could be responsible for the connection failure? (Choose three.)

A.

The NAT gateway in the subnet where the EC2 instance is deployed has been misconfigured.

B.

The internet gateway of the VPC has been misconfigured.

C.

The security group denies outbound traffic on ephemeral ports.

D.

The route table is missing a route to the internet gateway.

E.

The NACL denies outbound traffic on ephemeral ports.

F.

The host-based firewall is denying SSH traffic.

Answer: B,D,F

Reference:

<https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/TroubleshootingInstancesConnecting.html>

QUESTION NO: 174

After multiple compromises of its Amazon EC2 instances, a company's Security Officer is mandating that memory dumps of compromised instances be captured for further analysis. A Security Engineer just received an EC2 abuse notification report from AWS stating that an EC2 instance running the most recent Windows Server 2019 Base AMI is compromised.

How should the Security Engineer collect a memory dump of the EC2 instance for forensic analysis?

- A.**
Give consent to the AWS Security team to dump the memory core on the compromised instance and provide it to AWS Support for analysis.
- B.**
Review memory dump data that the AWS Systems Manager Agent sent to Amazon CloudWatch Logs.
- C.**
Download and run the EC2Rescue for Windows Server utility from AWS.
- D.**
Reboot the EC2 Windows Server, enter safe mode, and select memory dump.

Answer: B

Reference:

<https://www.giac.org/paper/gcfa/13310/digital-forensic-analysis-amazon-linux-ec2-instances/123500>

QUESTION NO: 175

A company's Information Security team wants to analyze Amazon EC2 performance and utilization data in near-real time for anomalies. A Security Engineer is responsible for log aggregation. The Engineer must collect logs from all of the company's AWS accounts in a centralized location to perform the analysis.

How should the Security Engineer do this?

- A.**
Log in to each account four times a day and filter the AWS CloudTrail log data, then copy and paste the logs in to the Amazon S3 bucket in the destination account.
- B.**

Set up Amazon CloudWatch to stream data to an Amazon S3 bucket in each source account. Set up bucket replication for each source account into a centralized bucket owned by the Security Engineer.

C.

Set up an AWS Config aggregator to collect AWS configuration data from multiple sources.

D.

Set up Amazon CloudWatch cross-account log data sharing with subscriptions in each account. Send the logs to Amazon Kinesis Data Firehose in the Security Engineer's account.

Answer: C

Reference:

<https://docs.aws.amazon.com/organizations/latest/userguide/services-that-can-integrate-config.html>

QUESTION NO: 176

Two Amazon EC2 instances in different subnets should be able to connect to each other but cannot. It has been confirmed that other hosts in the same subnets are able to communicate successfully, and that security groups have valid ALLOW rules in place to permit this traffic.

Which of the following troubleshooting steps should be performed?

A.

Check inbound and outbound security groups, looking for DENY rules

B.

Check inbound and outbound Network ACL rules, looking for DENY rules

C.

Review the rejected packet reason codes in the VPC Flow Logs

D.

Use AWS X-Ray to trace the end-to-end application flow

Answer: C

Explanation:

QUESTION NO: 177

A Security Engineer creates an Amazon S3 bucket policy that denies access to all users. A few days later, the Security Engineer adds an additional statement to the bucket policy to allow read-only access to one other employee. Even after updating the policy, the employee still receives an access denied message.

What is the likely cause of this access denial?

A.

The ACL in the bucket needs to be updated

B.

The IAM policy does not allow the user to access the bucket

C.

It takes a few minutes for a bucket policy to take effect

D.

The allow permission is being overridden by the deny

Answer: B

Reference:

<https://aws.amazon.com/premiumsupport/knowledge-center/s3-access-denied-bucket-policy/>

QUESTION NO: 178

A company plans to use custom AMIs to launch Amazon EC2 instances across multiple AWS accounts in a single Region to perform security monitoring and analytics tasks. The EC2 instances are launched in EC2 Auto Scaling groups. To increase the security of the solution, a Security Engineer will manage the lifecycle of the custom AMIs in a centralized account and will encrypt them with a centrally managed AWS KMS CMK. The Security Engineer configured the KMS key policy to allow cross-account access. However, the EC2 instances are still not being properly launched by the EC2 Auto Scaling groups.

Which combination of configuration steps should the Security Engineer take to ensure the EC2 Auto Scaling groups have been granted the proper permissions to execute tasks?

A.

Create a customer-managed CMK in the centralized account. Allow other applicable accounts to

use that key for cryptographic operations by applying proper cross-account permissions in the key policy. Create an IAM role in all applicable accounts and configure its access policy to allow the use of the centrally managed CMK for cryptographic operations. Configure EC2 Auto Scaling groups within each applicable account to use the created IAM role to launch EC2 instances.

B.

Create a customer-managed CMK in the centralized account. Allow other applicable accounts to use that key for cryptographic operations by applying proper cross-account permissions in the key policy. Create an IAM role in all applicable accounts and configure its access policy with permissions to create grants for the centrally managed CMK. Use this IAM role to create a grant for the centrally managed CMK with permissions to perform cryptographic operations and with the EC2 Auto Scaling service-linked role defined as the grantee principal.

C.

Create a customer-managed CMK or an AWS managed CMK in the centralized account. Allow other applicable accounts to use that key for cryptographic operations by applying proper cross-account permissions in the key policy. Use the CMK administrator to create a CMK grant that includes permissions to perform cryptographic operations that define EC2 Auto Scaling service-linked roles from all other accounts as the grantee principal.

D.

Create a customer-managed CMK or an AWS managed CMK in the centralized account. Allow other applicable accounts to use that key for cryptographic operations by applying proper cross-account permissions in the key policy. Modify the access policy for the EC2 Auto Scaling roles to perform cryptographic operations against the centrally managed CMK.

Answer: D

Reference:

<https://docs.aws.amazon.com/kms/latest/developerguide/key-policy-modifying-external-accounts.html>

QUESTION NO: 179

An organization wants to log all AWS API calls made within all of its AWS accounts, and must have a central place to analyze these logs.

What steps should be taken to meet these requirements in the MOST secure manner? (Choose two.)

A.

Turn on AWS CloudTrail in each AWS account.

B.

Turn on CloudTrail in only the account that will be storing the logs.

C.

Update the bucket ACL of the bucket in the account that will be storing the logs so that other accounts can log to it.

D.

Create a service-based role for CloudTrail and associate it with CloudTrail in each account.

E.

Update the bucket policy of the bucket in the account that will be storing the logs so that other accounts can log to it.

Answer: B,E

Explanation:

QUESTION NO: 180

A company uses HTTP Live Streaming (HLS) to stream live video content to paying subscribers by using Amazon CloudFront. HLS splits the video content into chunks so that the user can request the right chunk based on different conditions. Because the video events last for several hours, the total video is made up of thousands of chunks.

The origin URL is not disclosed, and every user is forced to access the CloudFront URL. The company has a web application that authenticates the paying users against an internal repository and a CloudFront key pair that is already issued.

What is the simplest and MOST effective way to protect the content?

A.

Develop the application to use the CloudFront key pair to create signed URLs that users will use to access the content.

B.

Develop the application to use the CloudFront key pair to set the signed cookies that users will use to access the content.

C.

Develop the application to issue a security token that Lambda@Edge will receive to authenticate and authorize access to the content.

D.

Keep the CloudFront URL encrypted inside the application, and use AWS KMS to resolve the URL on-the-fly after the user is authenticated.

Answer: A

Reference:

<https://docs.aws.amazon.com/AmazonCloudFront/latest/DeveloperGuide/private-content-signed-urls.html>

QUESTION NO: 181

A company's web application is hosted on Amazon EC2 instances running behind an Application Load Balancer (ALB) in an Auto Scaling group. An AWS WAF web ACL is associated with the ALB. AWS CloudTrail is enabled, and stores logs in Amazon S3 and Amazon CloudWatch Logs.

The Operations team has observed some EC2 instances reboot at random. After rebooting, all access logs on the instances have been deleted. During an investigation, the Operations team found that each reboot happened just after a PHP error occurred on the new-user-creation.php file. The Operations team needs to view log information to determine if the company is being attacked.

Which set of actions will identify the suspect attacker's IP address for future occurrences?

A.

Configure VPC Flow Logs on the subnet where the ALB is located, and stream the data CloudWatch. Search for the new-user-creation.php occurrences in CloudWatch.

B.

Configure the CloudWatch agent on the ALB. Configure the agent to send application logs to CloudWatch. Update the instance role to allow CloudWatch Logs access. Export the logs to CloudWatch. Search for the new-user-creation.php occurrences in CloudWatch.

C.

Configure the ALB to export access logs to an Amazon Elasticsearch Service cluster, and use the service to search for the new-user-creation.php occurrences.

D.

Configure the web ACL to send logs to Amazon Kinesis Data Firehose, which delivers the logs to an S3 bucket. Use Amazon Athena to query the logs and find the new-user-creation.php occurrences.

Answer: A

Explanation:**QUESTION NO: 182**

A company has hundreds of AWS accounts, and a centralized Amazon S3 bucket used to collect AWS CloudTrail logs for all of these accounts. A Security Engineer wants to create a solution that will enable the company to run ad hoc queries against its CloudTrail logs dating back 3 years from when the trails were first enabled in the company's AWS account.

How should the company accomplish this with the least amount of administrative overhead?

A.

Run an Amazon EMR cluster that uses a MapReduce job to examine the CloudTrail trails.

B.

Use the events history feature of the CloudTrail console to query the CloudTrail trails.

C.

Write an AWS Lambda function to query the CloudTrail trails. Configure the Lambda function to be executed whenever a new file is created in the CloudTrail S3 bucket.

D.

Create an Amazon Athena table that looks at the S3 bucket the CloudTrail trails are being written to. Use Athena to run queries against the trails.

Answer: B

Explanation:

QUESTION NO: 183

A Security Engineer is troubleshooting a connectivity issue between a web server that is writing log files to the logging server in another VPC. The Engineer has confirmed that a peering relationship exists between the two VPCs. VPC flow logs show that requests sent from the web server are accepted by the logging server, but the web server never receives a reply.

Which of the following actions could fix this issue?

A.

Add an inbound rule to the security group associated with the logging server that allows requests

from the web server.

B.

Add an outbound rule to the security group associated with the web server that allows requests to the logging server.

C.

Add a route to the route table associated with the subnet that hosts the logging server that targets the peering connection.

D.

Add a route to the route table associated with the subnet that hosts the web server that targets the peering connection.

Answer: A

Reference:

https://docs.aws.amazon.com/vpc/latest/userguide/VPC_SecurityGroups.html

QUESTION NO: 184

A Security Engineer accidentally deleted the imported key material in an AWS KMS CMK.

What should the Security Engineer do to restore the deleted key material?

A.

Create a new CMK. Download a new wrapping key and a new import token to import the original key material.

B.

Create a new CMK. Use the original wrapping key and import token to import the original key material.

C.

Download a new wrapping key and a new import token. Import the original key material into the existing CMK.

D.

Use the original wrapping key and import token. Import the original key material into the existing CMK.

Answer: B

Reference:

QUESTION NO: 185

A company's Security Engineer is copying all application logs to centralized Amazon S3 buckets. Currently, each of the company's application is in its own AWS account, and logs are pushed into S3 buckets associated with each account. The Engineer will deploy an AWS Lambda function into each account that copies the relevant log files to the centralized S3 bucket.

The Security Engineer is unable to access the log files in the centralized S3 bucket. The Engineer's IAM user policy from the centralized account looks like this:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": "s3:Put*",
      "Resource": "arn:aws:s3:::centralizedbucket/*",
      "Effect": "Deny"
    },
    {
      "Action": ["s3:Get*", "s3:List*"],
      "Resource": [
        "arn:aws:s3:::centralizedbucket/*",
        "arn:aws:s3:::centralizedbucket/"
      ],
      "Effect": "Allow"
    }
  ]
}
```

The centralized S3 bucket policy looks like this:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "AWS": [
          "arn:aws:iam::111122223333:role/LogCopier",
          "arn:aws:iam::444455556666:role/LogCopier"
        ]
      },
      "Action": ["s3:PutObject", "s3:PutObjectAcl"],
      "Resource": "arn:aws:s3:::centralizedbucket/*"
    }
  ]
}
```

Why is the Security Engineer unable to access the log files?

A.

The S3 bucket policy does not explicitly allow the Security Engineer access to the objects in the bucket.

B.

The object ACLs are not being updated to allow the users within the centralized account to access the objects.

C.

The Security Engineer's IAM policy does not grant permissions to read objects in the S3 bucket.

D.

The s3:PutObject and s3:PutObjectAcl permissions should be applied at the S3 bucket level.

Answer: D

Explanation:

QUESTION NO: 186

An application running on Amazon EC2 instances generates log files in a folder on a Linux file system. The instances block access to the console and file transfer utilities, such as Secure Copy Protocol (SCP) and Secure File Transfer Protocol (SFTP). The Application Support team wants to automatically monitor the application log files so the team can set up notifications in the future.

A Security Engineer must design a solution that meets the following requirements:

Make the log files available through an AWS managed service.

Allow for automatic monitoring of the logs.

Provide an interface for analyzing logs.

Minimize effort.

Which approach meets these requirements?

A.

Modify the application to use the AWS SDK. Write the application logs to an Amazon S3 bucket.

B.

Install the unified Amazon CloudWatch agent on the instances. Configure the agent to collect the application log files on the EC2 file system and send them to Amazon CloudWatch Logs.

C.

Install AWS Systems Manager Agent on the instances. Configure an automation document to copy the application log files to AWS DeepLens.

D.

Install Amazon Kinesis Agent on the instances. Stream the application log files to Amazon Kinesis Data Firehose and set the destination to Amazon Elasticsearch Service.

Answer: B

Reference:

<https://docs.aws.amazon.com/systems-manager/latest/userguide/monitoring-cloudwatch-agent.html>

QUESTION NO: 187

A company has multiple AWS accounts that are part of AWS Organizations. The company's Security team wants to ensure that even those Administrators with full access to the company's AWS accounts are unable to access the company's Amazon S3 buckets.

How should this be accomplished?

A.

Use SCPs.

- B.**
Add a permissions boundary to deny access to Amazon S3 and attach it to all roles.
- C.**
Use an S3 bucket policy.
- D.**
Create a VPC endpoint for Amazon S3 and deny statements for access to Amazon S3.

Answer: A

Reference:

https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps.html

QUESTION NO: 188

A Security Engineer has several thousand Amazon EC2 instances split across production and development environments. Each instance is tagged with its environment. The Engineer needs to analyze and patch all the development EC2 instances to ensure they are not currently exposed to any common vulnerabilities or exposures (CVEs).

Which combination of steps is the MOST efficient way for the Engineer to meet these requirements? (Choose two.)

- A.**
Log on to each EC2 instance, check and export the different software versions installed, and verify this against a list of current CVEs.
- B.**
Install the Amazon Inspector agent on all development instances. Build a custom rule package, and configure Inspector to perform a scan using this custom rule on all instances tagged as being in the development environment.
- C.**
Install the Amazon Inspector agent on all development instances. Configure Inspector to perform a scan using this CVE rule package on all instances tagged as being in the development environment.
- D.**
Install the Amazon EC2 System Manager agent on all development instances. Issue the Run command to EC2 System Manager to update all instances.

E.

Use AWS Trusted Advisor to check that all EC2 instances have been patched to the most recent version of operating system and installed software.

Answer: C,D

Explanation:

QUESTION NO: 189

A company has decided to use encryption in its AWS account to secure the objects in Amazon S3 using server-side encryption. Object sizes range from 16,000 B to 5 MB. The requirements are as follows:

The key material must be generated and stored in a certified Federal Information Processing Standard (FIPS) 140-2 Level 3 machine.

The key material must be available in multiple Regions.

Which option meets these requirements?

A.

Use an AWS KMS customer managed key and store the key material in AWS with replication across Regions.

B.

Use an AWS customer managed key, import the key material into AWS KMS using in-house AWS CloudHSM, and store the key material securely in Amazon S3.

C.

Use an AWS KMS custom key store backed by AWS CloudHSM clusters, and copy backups across Regions.

D.

Use AWS CloudHSM to generate the key material and backup keys across Regions. Use the Java Cryptography Extension (JCE) and Public Key Cryptography Standards #11 (PKCS #11) encryption libraries to encrypt and decrypt the data.

Answer: C

Explanation:

QUESTION NO: 190

An organization has a multi-petabyte workload that it is moving to Amazon S3, but the CISO is concerned about cryptographic wear-out and the blast radius if a key is compromised.

How can the CISO be assured that AWS KMS and Amazon S3 are addressing the concerns? (Choose two.)

- A.**
There is no API operation to retrieve an S3 object in its encrypted form.
- B.**
Encryption of S3 objects is performed within the secure boundary of the KMS service.
- C.**
S3 uses KMS to generate a unique data key for each individual object.
- D.**
Using a single master key to encrypt all data includes having a single place to perform audits and usage validation.
- E.**
The KMS encryption envelope digitally signs the master key during encryption to prevent cryptographic wear-out.

Answer: C,D

Explanation:

QUESTION NO: 191

A company has a compliance requirement to rotate its encryption keys on an annual basis. A Security Engineer needs a process to rotate the KMS Customer Master Keys (CMKs) that were created using imported key material.

How can the Engineer perform the key rotation process MOST efficiently?

- A.**
Create a new CMK, and redirect the existing Key Alias to the new CMK.
- B.**
Select the option to auto-rotate the key.

C.

Upload new key material into the existing CMK.

D.

Create a new CMK, and change the application to point to the new CMK.

Answer: D

Explanation:

QUESTION NO: 192

A company's Chief Security Officer has requested that a Security Analyst review and improve the security posture of each company AWS account. The Security Analyst decides to do this by improving AWS account root user security.

Which actions should the Security Analyst take to meet these requirements? (Choose three.)

A.

Delete the access keys for the account root user in every account.

B.

Create an admin IAM user with administrative privileges and delete the account root user in every account.

C.

Implement a strong password to help protect account-level access to the AWS Management Console by the account root user.

D.

Enable multi-factor authentication (MFA) on every account root user in all accounts.

E.

Create a custom IAM policy to limit permissions to required actions for the account root user and attach the policy to the account root user.

F.

Attach an IAM role to the account root user to make use of the automated credential rotation in AWS STS.

Answer: C,D,E

Explanation:

QUESTION NO: 193

A large company wants its Compliance team to audit its Amazon S3 buckets to identify if personally identifiable information (PII) is stored in them. The company has hundreds of S3 buckets and has asked the Security Engineers to scan every bucket.

How can this task be accomplished?

A.

Configure Amazon CloudWatch Events to trigger Amazon Inspector to scan the S3 buckets daily for PII. Configure Amazon Inspector to publish Amazon SNS notifications to the Compliance team if PII is detected.

B.

Configure Amazon Macie to classify data in the S3 buckets and check the dashboard for PII findings. Configure Amazon CloudWatch Events to capture Macie alerts and target an Amazon SNS topic to be notified if PII is detected.

C.

Check the AWS Trusted Advisor data loss prevention page in the AWS Management Console. Download the Amazon S3 data confidentiality report and send it to the Compliance team. Configure Amazon CloudWatch Events to capture Trusted Advisor alerts and target an Amazon SNS topic to be notified if PII is detected.

D.

Enable Amazon GuardDuty in multiple Regions to scan the S3 buckets. Configure Amazon CloudWatch Events to capture GuardDuty alerts and target an Amazon SNS topic to be notified if PII is detected.

Answer: B

Explanation:

QUESTION NO: 194

During a manual review of system logs from an Amazon Linux EC2 instance, a Security Engineer noticed that there are sudo commands that were never properly alerted or reported on the Amazon CloudWatch Logs agent.

Why were there no alerts on the sudo commands?

A.

There is a security group blocking outbound port 80 traffic that is preventing the agent from

sending the logs.

B.

The IAM instance profile on the EC2 instance was not properly configured to allow the CloudWatch Logs agent to push the logs to CloudWatch.

C.

CloudWatch Logs status is set to ON versus SECURE, which prevents it from pulling in OS security event logs.

D.

The VPC requires that all traffic go through a proxy, and the CloudWatch Logs agent does not support a proxy configuration.

Answer: B

Explanation:

QUESTION NO: 195

A company has an AWS account and allows a third-party contractor, who uses another AWS account, to assume certain IAM roles. The company wants to ensure that IAM roles can be assumed by the contractor only if the contractor has multi-factor authentication enabled on their IAM user accounts.

What should the company do to accomplish this?

A.

Add the following condition to the IAM policy attached to all IAM roles:

"Effect": "Deny",

"Condition": { "BoolIfExists": { "aws:MultiFactorAuthPresent": false } }

B.

Add the following condition to the IAM policy attached to all IAM roles:

"Effect": "Deny",

"Condition": { "Bool": { "aws:MultiFactorAuthPresent": false } }

C.

Add the following condition to the IAM policy attached to all IAM roles:

"Effect": "Allow",

```
"Condition" : { "Null" : { "aws:MultiFactorAuthPresent" : false } }
```

D.

Add the following condition to the IAM policy attached to all IAM roles:

```
"Effect": "Allow",
```

```
"Condition" : { "BoolIfExists" : { "aws:MultiFactorAuthPresent" : false } }
```

Answer: A

Reference:

https://aws-orgs.readthedocs.io/_/downloads/en/latest/pdf/ (18)

QUESTION NO: 196

A large corporation is creating a multi-account strategy and needs to determine how its employees should access the AWS Infrastructure.

Which of the following solutions would provide the MOST scalable solution?

A.

Create dedicated IAM users within each AWS account that employees can assume through federation based upon group membership in their existing identity provider.

B.

Use a centralized account with IAM roles that employees can assume through federation with their existing identity provider. Use cross-account roles to allow the federated users to assume their target role in the resource accounts.

C.

Configure the AWS Security Token Service to use Kerberos tokens so that users can use their existing corporate user names and passwords to access AWS resources directly.

D.

Configure the IAM trust policies within each account's role to set up a trust back to the corporation's existing identity provider, allowing users to assume the role based off their SAML token.

Answer: A

Explanation:

QUESTION NO: 197

A company wants to deploy a distributed web application on a fleet of EC2 instances. The fleet will be fronted by a Classic Load Balancer that will be configured to terminate the TLS connection. The company wants to make sure that all past and current TLS traffic to the Classic Load Balancer stays secure, even if the certificate private key is leaked.

To ensure the company meets these requirements, a Security Engineer can configure a Classic Load Balancer with:

A.

An HTTPS listener that uses a certificate that is managed by Amazon Certification Manager.

B.

An HTTPS listener that uses a custom security policy that allows only perfect forward secrecy cipher suites.

C.

An HTTPS listener that uses the latest AWS predefined ELBSecurityPolicy-TLS-1-2-2017-01 security policy.

D.

A TCP listener that uses a custom security policy that allows only perfect forward secrecy cipher suites.

Answer: B

Explanation:

QUESTION NO: 198

Users report intermittent availability of a web application hosted on AWS. Monitoring systems report an excess of abnormal network traffic followed by high CPU utilization on the application web tier.

Which of the following techniques will improve the availability of the application? (Choose two.)

A.

Deploy AWS WAF to block all unsecured web applications from accessing the internet.

B.

Deploy an Intrusion Detection/Prevention Systems (IDS/IPS) to monitor or block unusual incoming network traffic.

C.

Configure security groups to allow outgoing network traffic only from hosts that are protected with up-to-date antivirus software.

D.

Create Amazon CloudFront distribution and configure AWS WAF rules to protect the web applications from malicious traffic.

E.

Use the default Amazon VPC for external-facing systems to allow AWS to actively block malicious network traffic affecting Amazon EC2 instances.

Answer: A,B

Explanation:

QUESTION NO: 199

A company has an application hosted in an Amazon EC2 instance and wants the application to access secure strings stored in AWS Systems Manager Parameter Store. When the application tries to access the secure string key value, it fails.

Which factors could be the cause of this failure? (Choose two.)

A.

The EC2 instance role does not have decrypt permissions on the AWS Key Management Service (AWS KMS) key used to encrypt the secret.

B.

The EC2 instance role does not have read permissions to read the parameters in Parameter Store.

C.

Parameter Store does not have permission to use AWS Key Management Service (AWS KMS) to decrypt the parameter.

D.

The EC2 instance role does not have encrypt permissions on the AWS Key Management Service (AWS KMS) key associated with the secret.

E.

The EC2 instance does not have any tags associated.

Answer: B,C

Explanation:

QUESTION NO: 200

A security engineer received an Amazon GuardDuty alert indicating a finding involving the Amazon EC2 instance that hosts the company's primary website. The GuardDuty finding received read:

UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.

The security engineer confirmed that a malicious actor used API access keys intended for the EC2 instance from a country where the company does not operate. The security engineer needs to deny access to the malicious actor.

What is the first step the security engineer should take?

A.

Open the EC2 console and remove any security groups that allow inbound traffic from 0.0.0.0/0.

B.

Install the AWS Systems Manager Agent on the EC2 instance and run an inventory report.

C.

Install the Amazon Inspector agent on the host and run an assessment with the CVE rules package.

D.

Open the IAM console and revoke all IAM sessions that are associated with the instance profile.

Answer: B

Explanation:

QUESTION NO: 201

A company manages multiple AWS accounts using AWS Organizations. The company's security

team notices that some member accounts are not sending AWS CloudTrail logs to a centralized Amazon S3 logging bucket. The security team wants to ensure there is at least one trail configured for all existing accounts and for any account that is created in the future.

Which set of actions should the security team implement to accomplish this?

A.

Create a new trail and configure it to send CloudTrail logs to Amazon S3. Use Amazon EventBridge (Amazon CloudWatch Events) to send notification if a trail is deleted or stopped.

B.

Deploy an AWS Lambda function in every account to check if there is an existing trail and create a new trail, if needed.

C.

Edit the existing trail in the Organizations master account and apply it to the organization.

D.

Create an SCP to deny the cloudtrail:Delete* and cloudtrail:Stop* actions. Apply the SCP to all accounts.

Answer: C

Explanation:

QUESTION NO: 202

A security engineer is setting up a new AWS account. The engineer has been asked to continuously monitor the company's AWS account using automated compliance checks based on AWS best practices and Center for Internet Security (CIS) AWS Foundations Benchmarks.

How can the security engineer accomplish this using AWS services?

A.

Enable AWS Config and set it to record all resources in all Regions and global resources. Then enable AWS Security Hub and confirm that the CIS AWS Foundations compliance standard is enabled.

B.

Enable Amazon Inspector and configure it to scan all Regions for the CIS AWS Foundations Benchmarks. Then enable AWS Security Hub and configure it to ingest the Amazon Inspector findings.

C.

Enable Amazon Inspector and configure it to scan all Regions for the CIS AWS Foundations Benchmarks. Then enable AWS Shield in all Regions to protect the account from DDoS attacks.

D.

Enable AWS Config and set it to record all resources in all Regions and global resources. Then enable Amazon Inspector and configure it to enforce CIS AWS Foundations Benchmarks using AWS Config rules.

Answer: D

Reference:

<https://docs.aws.amazon.com/securityhub/latest/userguide/securityhub.pdf>

QUESTION NO: 203

A company has a VPC with several Amazon EC2 instances behind a NAT gateway. The company's security policy states that all network traffic must be logged and must include the original source and destination IP addresses. The existing VPC Flow Logs do not include this information. A security engineer needs to recommend a solution.

Which combination of steps should the security engineer recommend? (Choose two.)

A.

Edit the existing VPC Flow Logs. Change the log format of the VPC Flow Logs from the Amazon default format to a custom format.

B.

Delete and recreate the existing VPC Flow Logs. Change the log format of the VPC Flow Logs from the Amazon default format to a custom format.

C.

Change the destination to Amazon CloudWatch Logs.

D.

Include the pkt-srcaddr and pkt-dstaddr fields in the log format.

E.

Include the subnet-id and instance-id fields in the log format.

Answer: B,D

Reference:

<https://docs.aws.amazon.com/vpc/latest/userguide/flow-logs.html>

QUESTION NO: 204

A company has a VPC with an IPv6 address range and a public subnet with an IPv6 address block. The VPC currently hosts some public Amazon EC2 instances, but a security engineer needs to migrate a second application into the VPC that also requires IPv6 connectivity.

This new application will occasionally make API requests to an external, internet-accessible endpoint to receive updates. However, the security team does not want the application's EC2 instance exposed directly to the internet. The security engineer intends to create a private subnet with a custom route table and to associate the route table with the private subnet.

What else does the security engineer need to do to ensure the application will not be exposed directly to the internet, but can still communicate as required?

- A.**
Launch a NAT instance in the public subnet. Update the custom route table with a new route to the NAT instance.
- B.**
Remove the internet gateway, and add AWS PrivateLink to the VPC. Then update the custom route table with a new route to AWS PrivateLink.
- C.**
Add a managed NAT gateway to the VPC. Update the custom route table with a new route to the gateway.
- D.**
Add an egress-only internet gateway to the VPC. Update the custom route table with a new route to the gateway.

Answer: D

Explanation:

QUESTION NO: 205

An ecommerce website was down for 1 hour following a DDoS attack. Users were unable to connect to the website during the attack period. The ecommerce company's security team is worried about future potential attacks and wants to prepare for such events. The company needs to minimize downtime in its response to similar attacks in the future.

Which steps would help achieve this? (Choose two.)

A.

Enable Amazon GuardDuty to automatically monitor for malicious activity and block unauthorized access.

B.

Subscribe to AWS Shield Advanced and reach out to AWS Support in the event of an attack.

C.

Use VPC Flow Logs to monitor network traffic and an AWS Lambda function to automatically block an attacker's IP using security groups.

D.

Set up an Amazon CloudWatch Events rule to monitor the AWS CloudTrail events in real time, use AWS Config rules to audit the configuration, and use AWS Systems Manager for remediation.

E.

Use AWS WAF to create rules to respond to such attacks.

Answer: A,E

Explanation:

QUESTION NO: 206

A company's on-premises data center forwards DNS logs to a third-party security incident events management (SIEM) solution that alerts on suspicious behavior.

The company wants to introduce a similar capability to its AWS accounts that includes automatic remediation. The company expects to double in size within the next few months.

Which solution meets the company's current and future logging requirements?

A.

Enable Amazon GuardDuty and AWS Security Hub in all Regions and all accounts. Designate a master security account to receive all alerts from the child accounts. Set up specific rules within Amazon EventBridge to trigger an AWS Lambda function for remediation steps.

B.

Ingest all AWS CloudTrail logs, VPC Flow Logs, and DNS logs into a single Amazon S3 bucket in a designated security account. Use the current on-premises SIEM to monitor the logs and send a notification to an Amazon SNS topic to alert the security team of remediation steps.

C.

Ingest all AWS CloudTrail logs, VPC Flow Logs, and DNS logs into a single Amazon S3 bucket in a designated security account. Launch an Amazon EC2 instance and install the current SIEM to monitor the logs and send a notification to an Amazon SNS topic to alert the security team of remediation steps.

D.

Enable Amazon GuardDuty and AWS Security Hub in all Regions and all accounts. Designate a master security account to receive all alerts from the child accounts. Create an AWS Organizations SCP that denies access to certain API calls that are on an ignore list.

Answer: D

Explanation:

QUESTION NO: 207

A company has a serverless application for internal users deployed on AWS. The application uses AWS Lambda for the front end and for business logic. The Lambda function accesses an Amazon RDS database inside a VPC. The company uses AWS Systems Manager Parameter Store for storing database credentials.

A recent security review highlighted the following issues:

The Lambda function has internet access.

The relational database is publicly accessible.

The database credentials are not stored in an encrypted state.

Which combination of steps should the company take to resolve these security issues? (Choose three.)

A.

Disable public access to the RDS database inside the VPC.

B.

Move all the Lambda functions inside the VPC.

C.

Edit the IAM role used by Lambda to restrict internet access.

D.

Create a VPC endpoint for Systems Manager. Store the credentials as a string parameter. Change

the parameter type to an advanced parameter.

E.

Edit the IAM role used by RDS to restrict internet access.

F.

Create a VPC endpoint for Systems Manager. Store the credentials as a SecureString parameter.

Answer: B,D,E

Reference:

https://docs.amazonaws.cn/en_us/config/latest/developerguide/operational-best-practices-for-hipaa_security.html (guidance)

QUESTION NO: 208

A company wants to deploy an application in a private VPC that will not be connected to the internet. The company's security team will not allow bastion hosts or methods using SSH to log in to Amazon EC2 instances. The application team plans to use AWS Systems Manager Session Manager to connect to and manage the EC2 instances.

Which combination of steps should the security team take? (Choose three.)

A.

Make sure the Systems Manager Agent is installed and running on all EC2 instances inside the VPC.

B.

Ensure the IAM role attached to the EC2 instances in the VPC allows access to Systems Manager.

C.

Create an SCP that prevents the creation of SSH key pairs.

D.

Launch a NAT gateway in the VPC. Update the routing policies to forward traffic to this NAT gateway.

E.

Ensure proper VPC endpoints are in place for Systems Manager and Amazon EC2.

F.

Ensure the VPC has a transit gateway attachment. Update the routing policies to forward traffic to this transit gateway.

Answer: A,B,E

Reference:

<https://aws.amazon.com/blogs/mt/replacing-a-bastion-host-with-amazon-ec2-systems-manager/>

QUESTION NO: 209

A company uses multiple AWS accounts managed with AWS Organizations. Security engineers have created a standard set of security groups for all these accounts. The security policy requires that these security groups be used for all applications and delegates modification authority to the security team only.

A recent security audit found that the security groups are inconsistently implemented across accounts and that unauthorized changes have been made to the security groups. A security engineer needs to recommend a solution to improve consistency and to prevent unauthorized changes in the individual accounts in the future.

Which solution should the security engineer recommend?

A.

Use AWS Resource Access Manager to create shared resources for each required security group and apply an IAM policy that permits read-only access to the security groups only.

B.

Create an AWS CloudFormation template that creates the required security groups. Execute the template as part of configuring new accounts. Enable Amazon Simple Notification Service (Amazon SNS) notifications when changes occur.

C.

Use AWS Firewall Manager to create a security group policy, enable the policy feature to identify and revert local changes, and enable automatic remediation.

D.

Use AWS Control Tower to edit the account factory template to enable the share security groups option. Apply an SCP to the OU or individual accounts that prohibits security group modifications from local account users.

Answer: A

Explanation:

QUESTION NO: 210

A developer reported that AWS CloudTrail was disabled on their account. A security engineer investigated the account and discovered the event was undetected by the current security solution. The security engineer must recommend a solution that will detect future changes to the CloudTrail configuration and send alerts when changes occur.

What should the security engineer do to meet these requirements?

A.

Use AWS Resource Access Manager (AWS RAM) to monitor the AWS CloudTrail configuration. Send notifications using Amazon SNS.

B.

Create an Amazon CloudWatch Events rule to monitor Amazon GuardDuty findings. Send email notifications using Amazon SNS.

C.

Update security contact details in AWS account settings for AWS Support to send alerts when suspicious activity is detected.

D.

Use Amazon Inspector to automatically detect security issues. Send alerts using Amazon SNS.

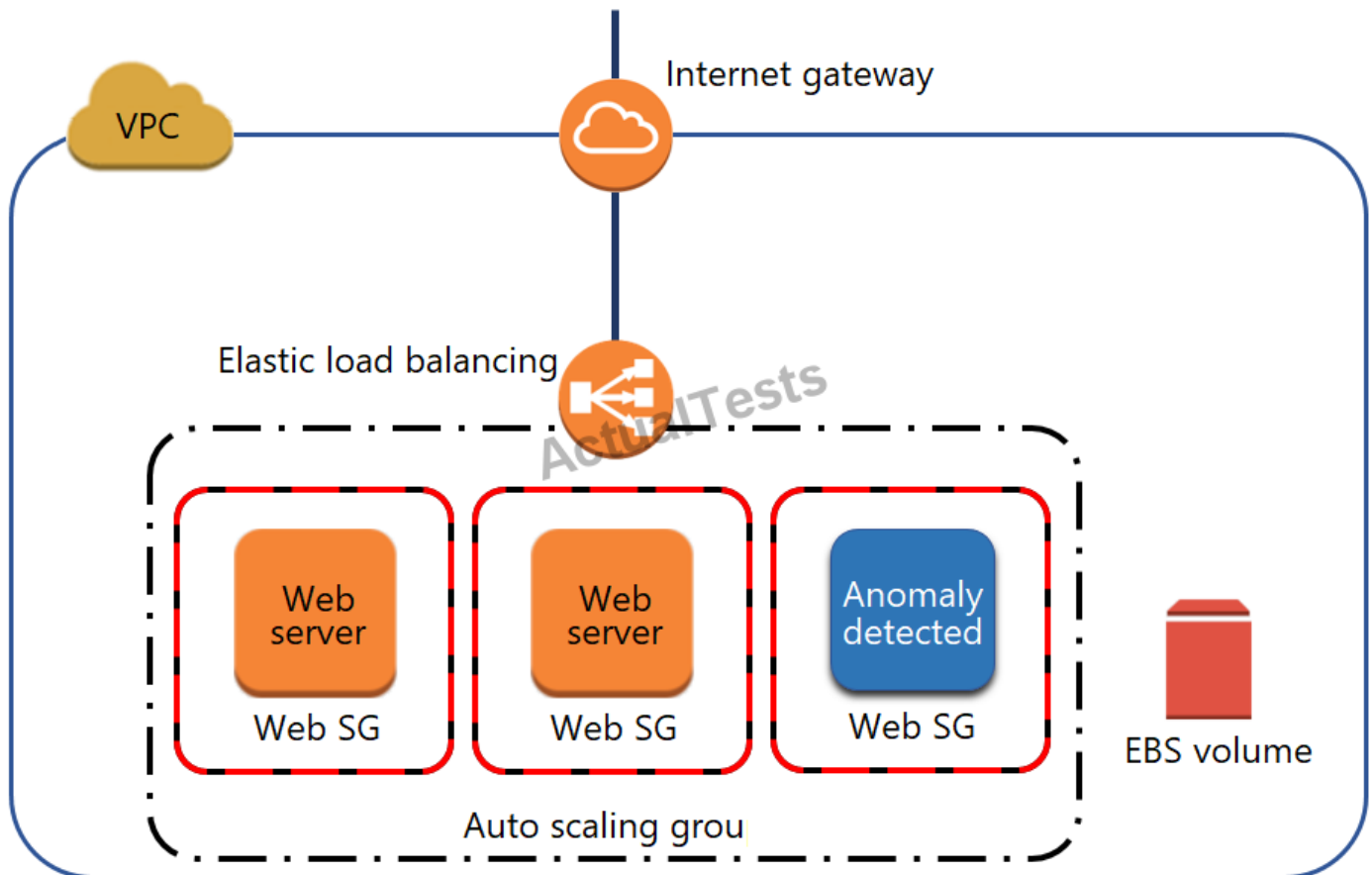
Answer: A

Reference:

<https://docs.aws.amazon.com/ram/latest/userguide/ram-ug.pdf>

QUESTION NO: 211

A security engineer noticed an anomaly within a company EC2 instance as shown in the image. The engineer must now investigate what is causing the anomaly.



What are the MOST effective steps to take to ensure that the instance is not further manipulated, while allowing the engineer to understand what happened?

- A.**
Remove the instance from the Auto Scaling group. Place the instance within an isolation security group, detach the EBS volume, launch an EC2 instance with a forensic toolkit, and attach the EBS volume to investigate.
- B.**
Remove the instance from the Auto Scaling group and the Elastic Load Balancer. Place the instance within an isolation security group, launch an EC2 instance with a forensic toolkit, and allow the forensic toolkit image to connect to the suspicious instance to perform the investigation.
- C.**
Remove the instance from the Auto Scaling group. Place the instance within an isolation security group, launch an EC2 instance with a forensic toolkit, and use the forensic toolkit image to deploy an ENI as a network span port to inspect all traffic coming from the suspicious instance.
- D.**
Remove the instance from the Auto Scaling group and the Elastic Load Balancer. Place the instance within an isolation security group, make a copy of the EBS volume from a new snapshot, launch an EC2 instance with a forensic toolkit, and attach the copy of the EBS volume to investigate.

Answer: D

Explanation:

QUESTION NO: 212

An external auditor finds that a company's user passwords have no minimum length. The company is currently using two identity providers:

AWS IAM federated with on-premises Active Directory

Amazon Cognito user pools to accessing an AWS Cloud application developed by the company

Which combination of actions should the security engineer take to solve this issue? (Choose two.)

A.

Update the password length policy in the on-premises Active Directory configuration.

B.

Update the password length policy in the IAM configuration.

C.

Enforce an IAM policy in Amazon Cognito and AWS IAM with a minimum password length condition.

D.

Update the password length policy in the Amazon Cognito configuration.

E.

Create an SCP with AWS Organizations that enforces a minimum password length for AWS IAM and Amazon Cognito.

Answer: B,D

Explanation:

QUESTION NO: 213

A company's data lake uses Amazon S3 and Amazon Athena. The company's security engineer has been asked to design an encryption solution that meets the company's data protection requirements. The encryption solution must work with Amazon S3 and keys managed by the

company. The encryption solution must be protected in a hardware security module that is validated to Federal Information Processing Standards (FIPS) 140-2 Level 3.

Which solution meets these requirements?

- A.**
Use client-side encryption with an AWS KMS customer-managed key implemented with the AWS Encryption SDK.
- B.**
Use AWS CloudHSM to store the keys and perform cryptographic operations. Save the encrypted text in Amazon S3.
- C.**
Use an AWS KMS customer-managed key that is backed by a custom key store using AWS CloudHSM.
- D.**
Use an AWS KMS customer-managed key with the bring your own key (BYOK) feature to import a key stored in AWS CloudHSM.

Answer: A

Explanation:

QUESTION NO: 214

A company's security engineer has been asked to monitor and report all AWS account root user activities.

Which of the following would enable the security engineer to monitor and report all root user activities? (Choose two.)

- A.**
Configuring AWS Organizations to monitor root user API calls on the paying account
- B.**
Creating an Amazon CloudWatch Events rule that will trigger when any API call from the root user is reported
- C.**
Configuring Amazon Inspector to scan the AWS account for any root user activity
- D.**

Configuring AWS Trusted Advisor to send an email to the security team when the root user logs in to the console

E.

Using Amazon SNS to notify the target group

Answer: B,E

Explanation:

QUESTION NO: 215

A security engineer needs to ensure their company's use of AWS meets AWS security best practices. As part of this, the AWS account root user must not be used for daily work. The root user must be monitored for use, and the security team must be alerted as quickly as possible if the root user is used.

Which solution meets these requirements?

A.

Set up an Amazon CloudWatch Events rule that triggers an Amazon SNS notification.

B.

Create root user access keys. Use an AWS Lambda function to parse AWS CloudTrail logs from Amazon S3 and generate notifications using Amazon SNS.

C.

Set up a rule in AWS Config to trigger root user events. Trigger an AWS Lambda function and generate notifications using Amazon SNS.

D.

Use Amazon Inspector to monitor the usage of the root user and generate notifications using Amazon SNS.

Answer: C

Explanation:

QUESTION NO: 216

A security engineer is designing an incident response plan to address the risk of a compromised

Amazon EC2 instance. The plan must recommend a solution to meet the following requirements:

A trusted forensic environment must be provisioned.

Automated response processes must be orchestrated.

Which AWS services should be included in the plan? (Choose two.)

- A.**
AWS CloudFormation
- B.**
Amazon GuardDuty
- C.**
Amazon Inspector
- D.**
Amazon Macie
- E.**
AWS Step Functions

Answer: A,B

Reference:

<https://aws.amazon.com/blogs/security/how-to-automate-incident-response-in-aws-cloud-for-ec2-instances/>

QUESTION NO: 217

A company's security information events management (SIEM) tool receives new AWS CloudTrail logs from an Amazon S3 bucket that is configured to send all object created event notifications to an Amazon SNS topic. An Amazon SQS queue is subscribed to this SNS topic. The company's SIEM tool then polls this SQS queue for new messages using an IAM role and fetches new log events from the S3 bucket based on the SQS messages.

After a recent security review that resulted in restricted permissions, the SIEM tool has stopped receiving new CloudTrail logs.

Which of the following are possible causes of this issue? (Choose three.)

- A.**
The SQS queue does not allow the SQS:SendMessage action from the SNS topic.
- B.**
The SNS topic does not allow the SNS:Publish action from Amazon S3.
- C.**
The SNS topic is not delivering raw messages to the SQS queue.
- D.**
The S3 bucket policy does not allow CloudTrail to perform the PutObject action.
- E.**
The IAM role used by the SIEM tool does not have permission to subscribe to the SNS topic.
- F.**
The IAM role used by the SIEM tool does not allow the SQS:DeleteMessage action.

Answer: B,D,E

Explanation:

QUESTION NO: 218

A security engineer has noticed that VPC Flow Logs are getting a lot of REJECT traffic originating from a single Amazon EC2 instance in an Auto Scaling group. The security engineer is concerned that this EC2 instance may be compromised.

What immediate action should the security engineer take?

- A.**
Remove the instance from the Auto Scaling group. Close the security group with ingress only from a single forensic IP address to perform an analysis.
- B.**
Remove the instance from the Auto Scaling group. Change the network ACL rules to allow traffic only from a single forensic IP address to perform an analysis. Add a rule to deny all other traffic.
- C.**
Remove the instance from the Auto Scaling group. Enable Amazon GuardDuty in that AWS account. Install the Amazon Inspector agent on the suspicious EC2 instance to perform a scan.
- D.**
Take a snapshot of the suspicious EC2 instance. Create a new EC2 instance from the snapshot in a closed security group with ingress only from a single forensic IP address to perform an analysis.

Answer: B

Explanation:

QUESTION NO: 219

A company's director of information security wants a daily email report from AWS that contains recommendations for each company account to meet AWS Security best practices.

Which solution would meet these requirements?

A.

In every AWS account, configure AWS Lambda to query the AWS Support API for AWS Trusted Advisor security checks. Send the results from Lambda to an Amazon SNS topic to send reports.

B.

Configure Amazon GuardDuty in a master account and invite all other accounts to be managed by the master account. Use GuardDuty's integration with Amazon SNS to report on findings.

C.

Use Amazon Athena and Amazon QuickSight to build reports off of AWS CloudTrail. Create a daily Amazon CloudWatch trigger to run the report daily and email it using Amazon SNS.

D.

Use AWS Artifact's prebuilt reports and subscriptions. Subscribe the director of information security to the reports by adding the director as the security alternate contact for each account.

Answer: D

Explanation:

QUESTION NO: 220

A company is using AWS Organizations to manage multiple AWS member accounts. All of these accounts have Amazon GuardDuty enabled in all Regions. The company's AWS Security Operations Center has a centralized security account for logging and monitoring. One of the member accounts has received an excessively high bill. A security engineer discovers that a compromised Amazon EC2 instance is being used to mine cryptocurrency. The Security Operations Center did not receive a GuardDuty finding in the central security account, but there was a GuardDuty finding in the account containing the compromised EC2 instance. The security engineer needs to ensure all GuardDuty findings are available in the security account.

What should the security engineer do to resolve this issue?

A.

Set up an Amazon CloudWatch Events rule to forward all GuardDuty findings to the security account. Use an AWS Lambda function as a target to raise findings.

B.

Set up an Amazon CloudWatch Events rule to forward all GuardDuty findings to the security account. Use an AWS Lambda function as a target to raise findings in AWS Security Hub.

C.

Check that GuardDuty in the security account is able to assume a role in the compromised account using the `guardduty:listfindings` permission. Schedule an Amazon CloudWatch Events rule and an AWS Lambda function to periodically check for GuardDuty findings.

D.

Use the `aws guardduty get-members` AWS CLI command in the security account to see if the account is listed. Send an invitation from GuardDuty in the security account to GuardDuty in the compromised account. Accept the invitation to forward all future GuardDuty findings.

Answer: B

Explanation:

QUESTION NO: 221

A company is designing the security architecture for a global latency-sensitive web application it plans to deploy to AWS. A security engineer needs to configure a highly available and secure two-tier architecture. The security design must include controls to prevent common attacks such as DDoS, cross-site scripting, and SQL injection.

Which solution meets these requirements?

A.

Create an Application Load Balancer (ALB) that uses public subnets across multiple Availability Zones within a single Region. Point the ALB to an Auto Scaling group with Amazon EC2 instances in private subnets across multiple Availability Zones within the same Region. Create an Amazon CloudFront distribution that uses the ALB as its origin. Create appropriate AWS WAF ACLs and enable them on the CloudFront distribution.

B.

Create an Application Load Balancer (ALB) that uses private subnets across multiple Availability Zones within a single Region. Point the ALB to an Auto Scaling group with Amazon EC2 instances in private subnets across multiple Availability Zones within the same Region. Create an Amazon

CloudFront distribution that uses the ALB as its origin. Create appropriate AWS WAF ACLs and enable them on the CloudFront distribution.

C.

Create an Application Load Balancer (ALB) that uses public subnets across multiple Availability Zones within a single Region. Point the ALB to an Auto Scaling group with Amazon EC2 instances in private subnets across multiple Availability Zones within the same Region. Create appropriate AWS WAF ACLs and enable them on the ALB.

D.

Create an Application Load Balancer (ALB) that uses private subnets across multiple Availability Zones within a single Region. Point the ALB to an Auto Scaling group with Amazon EC2 instances in private subnets across multiple Availability Zones within the same Region. Create appropriate AWS WAF ACLs and enable them on the ALB.

Answer: B

Explanation:

QUESTION NO: 222

A company is using AWS Organizations to manage multiple AWS accounts. The company has an application that allows users to assume the AppUser IAM role to download files from an Amazon S3 bucket that is encrypted with an AWS KMS CMK. However, when users try to access the files in the S3 bucket, they get an access denied error.

What should a security engineer do to troubleshoot this error? (Choose three.)

A.

Ensure the KMS policy allows the AppUser role to have permission to decrypt for the CMK.

B.

Ensure the S3 bucket policy allows the AppUser role to have permission to get objects for the S3 bucket.

C.

Ensure the CMK was created before the S3 bucket.

D.

Ensure the S3 block public access feature is enabled for the S3 bucket.

E.

Ensure that automatic key rotation is disabled for the CMK.

F.

Ensure the SCPs within Organizations allow access to the S3 bucket.

Answer: B,D,E

Explanation:

QUESTION NO: 223

A city is implementing an election results reporting website that will use Amazon CloudFront. The website runs on a fleet of Amazon EC2 instances behind an Application Load Balancer (ALB) in an Auto Scaling group. Election results are updated hourly and are stored as .pdf files in an Amazon S3 bucket. A security engineer needs to ensure that all external access to the website goes through CloudFront.

Which solution meets these requirements?

A.

Create an IAM role that allows CloudFront to access the specific S3 bucket. Modify the S3 bucket policy to allow only the new IAM role to access its contents. Create an interface VPC endpoint for CloudFront to securely communicate with the ALB.

B.

Create an IAM role that allows CloudFront to access the specific S3 bucket. Modify the S3 bucket policy to allow only the new IAM role to access its contents. Associate the ALB with a security group that allows only incoming traffic from the CloudFront service to communicate with the ALB.

C.

Create an origin access identity (OAI) in CloudFront. Modify the S3 bucket policy to allow only the new OAI to access the bucket contents. Create an interface VPC endpoint for CloudFront to securely communicate with the ALB.

D.

Create an origin access identity (OAI) in CloudFront. Modify the S3 bucket policy to allow only the new OAI to access the bucket contents. Associate the ALB with a security group that allows only incoming traffic from the CloudFront service to communicate with the ALB.

Answer: C

Explanation:

QUESTION NO: 224

Which of the following are valid configurations for using SSL certificates with Amazon CloudFront?
(Choose three.)

- A.**
Default AWS Certificate Manager certificate
- B.**
Custom SSL certificate stored in AWS KMS
- C.**
Default CloudFront certificate
- D.**
Custom SSL certificate stored in AWS Certificate Manager
- E.**
Default SSL certificate stored in AWS Secrets Manager
- F.**
Custom SSL certificate stored in AWS IAM

Answer: A,C,D

Explanation:

QUESTION NO: 225

An AWS account administrator created an IAM group and applied the following managed policy to require that each individual user authenticate using multi-factor authentication:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "ec2:*",
      "Resource": "*"
    },
    {
      "Sid": "BlockAnyAccessUnlessSignedInWithMFA",
      "Effect": "Deny",
      "Action": "ec2:*",
      "Resource": "*",
      "Condition": {
        "BoolIfExists": {
          "aws:MultiFactorAuthPresent": false
        }
      }
    }
  ]
}
```

After implementing the policy, the administrator receives reports that users are unable to perform Amazon EC2 commands using the AWS CLI.

What should the administrator do to resolve this problem while still enforcing multi-factor authentication?

A.

Change the value of `aws:MultiFactorAuthPresent` to true.

B.

Instruct users to run the `aws sts get-session-token` CLI command and pass the multi-factor authentication `--serial-number` and `--token-code` parameters. Use these resulting values to make API/CLI calls.

C.

Implement federated API/CLI access using SAML 2.0, then configure the identity provider to enforce multi-factor authentication.

D.

Create a role and enforce multi-factor authentication in the role trust policy. Instruct users to run the `sts assume-role` CLI command and pass `--serial-number` and `--token-code` parameters. Store the resulting values in environment variables. Add `sts:AssumeRole` to `NotAction` in the policy.

Answer: B

Explanation:

QUESTION NO: 226

A recent security audit identified that a company's application team injects database credentials into the environment variables of an AWS Fargate task. The company's security policy mandates that all sensitive data be encrypted at rest and in transit.

Which combination of actions should the security team take to make the application compliant with the security policy? (Choose three.)

A.

Store the credentials securely in a file in an Amazon S3 bucket with restricted access to the application team IAM role. Ask the application team to read the credentials from the S3 object instead.

B.

Create an AWS Secrets Manager secret and specify the key/value pairs to be stored in this secret.

C.

Modify the application to pull credentials from the AWS Secrets Manager secret instead of the environment variables.

D.

Add the following statement to the container instance IAM role policy:

```
{
  "Effect": "Allow",
  "Action": [
    "ssm:GetParameters",
    "secretsmanager:GetSecretValue",
    "kms:Decrypt"
  ],
  "Resource": [
    "arn:aws:secretsmanager:<region>:<aws_account_id>:secret:secret_name",
    "arn:aws:kms:<region>:<aws_account_id>:key/key_id"
  ]
}
```

E.

Add the following statement to the task execution role policy:

```
{
  "Effect": "Allow",
  "Action": [
    "ssm:GetParameters",
    "secretsmanager:GetSecretValue",
    "kms:Decrypt"
  ],
  "Resource": [
    "arn:aws:secretsmanager:<region>:<aws_account_id>:secret:secret_name",
    "arn:aws:kms:<region>:<aws_account_id>:key/key_id"
  ]
}
```

F.

Log in to the AWS Fargate instance, create a script to read the secret value from AWS Secrets Manager, and inject the environment variables. Ask the application team to redeploy the application.

Answer: A,E,F

Explanation:

QUESTION NO: 227

A security engineer is responsible for providing secure access to AWS resources for thousands of developers in a company's corporate identity provider (IdP). The developers access a set of AWS services from their corporate premises using IAM credentials. Due to the volume of requests for provisioning new IAM users, it is taking a long time to grant access permissions. The security engineer receives reports that developers are sharing their IAM credentials with others to avoid provisioning delays. This causes concern about overall security for the security engineer.

Which actions will meet the program requirements that address security?

A.

Create an Amazon CloudWatch alarm for AWS CloudTrail events. Create a metric filter to send a notification when the same set of IAM credentials is used by multiple developers.

B.

Create a federation between AWS and the existing corporate IdP. Leverage IAM roles to provide federated access to AWS resources.

C.

Create a VPN tunnel between the corporate premises and the VPC. Allow permissions to all AWS services only if it originates from corporate premises.

D.

Create multiple IAM roles for each IAM user. Ensure that users who use the same IAM credentials

cannot assume the same IAM role at the same time.

Answer: B

Reference:

https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_common-scenarios_federated-users.html

QUESTION NO: 228

A company hosts an application on Amazon EC2 that is subject to specific rules for regulatory compliance. One rule states that traffic to and from the workload must be inspected for network-level attacks. This involves inspecting the whole packet.

To comply with this regulatory rule, a security engineer must install intrusion detection software on a c5n.4xlarge EC2 instance. The engineer must then configure the software to monitor traffic to and from the application instances.

What should the security engineer do next?

A.

Place the network interface in promiscuous mode to capture the traffic.

B.

Configure VPC Flow Logs to send traffic to the monitoring EC2 instance using a Network Load Balancer.

C.

Configure VPC traffic mirroring to send traffic to the monitoring EC2 instance using a Network Load Balancer.

D.

Use Amazon Inspector to detect network-level attacks and trigger an AWS Lambda function to send the suspicious packets to the EC2 instance.

Answer: C

Explanation:

QUESTION NO: 229

A company's security officer is concerned about the risk of AWS account root user logins and has assigned a security engineer to implement a notification solution for near-real-time alerts upon account root user logins.

How should the security engineer meet these requirements?

A.

Create a cron job that runs a script to download the AWS IAM security credentials file, parse the file for account root user logins, and email the security team's distribution list.

B.

Run AWS CloudTrail logs through Amazon CloudWatch Events to detect account root user logins and trigger an AWS Lambda function to send an Amazon SNS notification to the security team's distribution list.

C.

Save AWS CloudTrail logs to an Amazon S3 bucket in the security team's account. Process the CloudTrail logs with the security engineer's logging solution for account root user logins. Send an Amazon SNS notification to the security team upon encountering the account root user login events.

D.

Save VPC Flow Logs to an Amazon S3 bucket in the security team's account, and process the VPC Flow Logs with their logging solutions for account root user logins. Send an Amazon SNS notification to the security team upon encountering the account root user login events.

Answer: B

Reference:

<https://aws.amazon.com/blogs/mt/monitor-and-notify-on-aws-account-root-user-activity/>

QUESTION NO: 230

A company wants to encrypt data locally while meeting regulatory requirements related to key exhaustion. The encryption key can be no more than 10 days old or encrypt more than 2^{16} objects. Any encryption key must be generated on a FIPS-validated hardware security module (HSM). The company is cost-conscious, as it plans to upload an average of 100 objects to Amazon S3 each second for sustained operations across 5 data producers.

Which approach MOST efficiently meets the company's needs?

A.

Use the AWS Encryption SDK and set the maximum age to 10 days and the maximum number of messages encrypted to 2^{16} . Use AWS Key Management Service (AWS KMS) to generate the master key and data key. Use data key caching with the Encryption SDK during the encryption process.

B.

Use AWS Key Management Service (AWS KMS) to generate an AWS managed CMK. Then use Amazon S3 client-side encryption configured to automatically rotate with every object.

C.

Use AWS CloudHSM to generate the master key and data keys. Then use Boto 3 and Python to locally encrypt data before uploading the object. Rotate the data key every 10 days or after 2^{16} objects have been uploaded to Amazon S3.

D.

Use server-side encryption with Amazon S3 managed encryption keys (SSE-S3) and set the master key to automatically rotate.

Answer: C

Explanation:

QUESTION NO: 231

A company is setting up products to deploy in AWS Service Catalog. Management is concerned that when users launch products, elevated IAM privileges will be required to create resources.

How should the company mitigate this concern?

A.

Add a template constraint to each product in the portfolio.

B.

Add a launch constraint to each product in the portfolio.

C.

Define resource update constraints for each product in the portfolio.

D.

Update the AWS CloudFormation template backing the product to include a service role configuration.

Answer: B

Reference:

<https://aws.amazon.com/blogs/mt/how-to-launch-secure-and-governed-aws-resources-with-aws-cloudformation-and-aws-service-catalog/>

QUESTION NO: 232

A company is implementing a new application in a new AWS account. A VPC and subnets have been created for the application. The application has been peered to an existing VPC in another account in the same AWS Region for database access. Amazon EC2 instances will regularly be created and terminated in the application VPC, but only some of them will need access to the databases in the peered VPC over TCP port 1521. A security engineer must ensure that only the EC2 instances that need access to the databases can access them through the network.

How can the security engineer implement this solution?

A.

Create a new security group in the database VPC and create an inbound rule that allows all traffic from the IP address range of the application VPC. Add a new network ACL rule on the database subnets. Configure the rule to TCP port 1521 from the IP address range of the application VPC. Attach the new security group to the database instances that the application instances need to access.

B.

Create a new security group in the application VPC with an inbound rule that allows the IP address range of the database VPC over TCP port 1521. Create a new security group in the database VPC with an inbound rule that allows the IP address range of the application VPC over port 1521. Attach the new security group to the database instances and the application instances that need database access.

C.

Create a new security group in the application VPC with no inbound rules. Create a new security group in the database VPC with an inbound rule that allows TCP port 1521 from the new application security group in the application VPC. Attach the application security group to the application instances that need database access, and attach the database security group to the database instances.

D.

Create a new security group in the application VPC with an inbound rule that allows the IP address range of the database VPC over TCP port 1521. Add a new network ACL rule on the database subnets. Configure the rule to allow all traffic from the IP address range of the application VPC. Attach the new security group to the application instances that need database access.

Answer: A

Explanation:**QUESTION NO: 233**

A company is running an application on Amazon EC2 instances in an Auto Scaling group. The application stores logs locally. A security engineer noticed that logs were lost after a scale-in event. The security engineer needs to recommend a solution to ensure the durability and availability of log data. All logs must be kept for a minimum of 1 year for auditing purposes.

What should the security engineer recommend?

A.

Within the Auto Scaling lifecycle, add a hook to create and attach an Amazon Elastic Block Store (Amazon EBS) log volume each time an EC2 instance is created. When the instance is terminated, the EBS volume can be reattached to another instance for log review.

B.

Create an Amazon Elastic File System (Amazon EFS) file system and add a command in the user data section of the Auto Scaling launch template to mount the EFS file system during EC2 instance creation. Configure a process on the instance to copy the logs once a day from an instance Amazon Elastic Block Store (Amazon EBS) volume to a directory in the EFS file system.

C.

Build the Amazon CloudWatch agent into the AMI used in the Auto Scaling group. Configure the CloudWatch agent to send the logs to Amazon CloudWatch Logs for review.

D.

Within the Auto Scaling lifecycle, add a lifecycle hook at the terminating state transition and alert the engineering team by using a lifecycle notification to Amazon Simple Notification Service (Amazon SNS). Configure the hook to remain in the Terminating:Wait state for 1 hour to allow manual review of the security logs prior to instance termination.

Answer: A

Explanation:**QUESTION NO: 234**

A company needs to retain log data archives for several years to be compliant with regulations. The log data is no longer used, but it must be retained.

What is the MOST secure and cost-effective solution to meet these requirements?

A.

Archive the data to Amazon S3 and apply a restrictive bucket policy to deny the s3:DeleteObject API.

B.

Archive the data to Amazon S3 Glacier and apply a Vault Lock policy.

C.

Archive the data to Amazon S3 and replicated it to a second bucket in a second AWS Region. Choose the S3 Standard-Infrequent Access (S3 Standard-IA) storage class and apply a restrictive bucket policy to deny the s3:DeleteObject API.

D.

Migrate the log data to a 16 TB Amazon Elastic Block Store (Amazon EBS) volume. Create a snapshot of the EBS volume.

Answer: C

Explanation:

QUESTION NO: 235

A company uses an Amazon S3 bucket to store reports. Management has mandated that all new objects stored in this bucket must be encrypted at rest using server-side encryption with a client specified AWS Key Management Service (AWS KMS) CMK owned by the same account as the S3 bucket. The AWS account number is 111122223333, and the bucket name is reportbucket. The company's security specialist must write the S3 bucket policy to ensure the mandate can be implemented.

Which statement should the security specialist include in the policy?

A.

```
{
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3:::reportbucket/*",
  "Condition": {
    "StringEquals": {
      "s3:x-amz-server-side-encryption": "AES256"
    }
  }
}
```

B.

```
{
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3:::reportbucket/*",
  "Condition": {
    "StringNotLike": {
      "s3:x-amz-server-side-encryption-aws-kms-key-id": "arn:aws:kms:
*:111122223333:key/*"
    }
  }
}
```

C.

```
{
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3:::reportbucket/*",
  "Condition": {
    "StringNotLike": {
      "s3:x-amz-server-side-encryption": "aws:kms"
    }
  }
}
```

D.

```
{
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3:::reportbucket/*",
  "Condition": {
    "StringNotLikeIfExists": {
      "s3:x-amz-server-side-encryption-aws-kms-key-id": "arn:aws:kms:
*:111122223333:key/*"
    }
  }
}
```

Answer: A

Explanation:**QUESTION NO: 236**

A company website runs on Amazon EC2 instances behind an Application Load Balancer (ALB). The instances run in an Auto Scaling group across multiple Availability Zones. There is an Amazon CloudFront distribution in front of the ALB. Users are reporting performance problems. A security engineer discovers that the website is receiving a high rate of unwanted requests to the CloudFront distribution originating from a series of source IP addresses.

How should the security engineer address this problem?

A.

Using AWS Shield, configure a deny rule with an IP match condition containing the source IPs of the unwanted requests.

B.

Using Auto Scaling, configure the maximum an instance value to an increased count that will absorb the unwanted requests.

C.

Using an Amazon VPC NACL, configure an inbound deny rule for each source IP CIDR address of the unwanted requests.

D.

Using AWS WAF, configure a web ACL rate-based rule on the CloudFront distribution with a rate limit below that of the unwanted requests.

Answer: D

Explanation:**QUESTION NO: 237**

A developer is building a serverless application hosted on AWS that uses Amazon Redshift as a data store. The application has separate module for read/write and read-only functionality. The modules need their own database users for compliance reasons.

Which combination of steps should a security engineer implement to grant appropriate access? (Choose two.)

A.

Configure cluster security groups for each application module to control access to database users that are required for read-only and read-write.

B.

Configure a VPC endpoint for Amazon Redshift. Configure an endpoint policy that maps database users to each application module, and allow access to the tables that are required for read-only and read/write.

C.

Configure an IAM policy for each module. Specify the ARN of an Amazon Redshift database user that allows the GetClusterCredentials API call.

D.

Create local database users for each module.

E.

Configure an IAM policy for each module. Specify the ARN of an IAM user that allows the GetClusterCredentials API call.

Answer: A,D

Explanation:

QUESTION NO: 238

A company uses an external identity provider to allow federation into different AWS accounts. A security engineer for the company needs to identify the federated user that terminated a production Amazon EC2 instance a week ago.

What is the FASTEST way for the security engineer to identify the federated user?

A.

Review the AWS CloudTrail event history logs in an Amazon S3 bucket and look for the TerminateInstances event to identify the federated user from the role session name.

B.

Filter the AWS CloudTrail event history for the TerminateInstances event and identify the assumed IAM role. Review the AssumeRoleWithSAML event call in CloudTrail to identify the corresponding username.

C.

Search the AWS CloudTrail logs for the TerminateInstances event and note the event time. Review the IAM Access Advisor tab for all federated roles. The last accessed time should match the time when the instance was terminated.

D.

Use Amazon Athena to run a SQL query on the AWS CloudTrail logs stored in an Amazon S3 bucket and filter on the `TerminateInstances` event. Identify the corresponding role and run another query to filter the `AssumeRoleWithWebIdentity` event for the user name.

Answer: A

Reference:

<https://aws.amazon.com/blogs/security/how-to-easily-identify-your-federated-users-by-using-aws-cloudtrail/>

QUESTION NO: 239

A company has two software development teams that are creating applications that store sensitive data in Amazon S3. Each team's data must always be separate. The company's security team must design a data encryption strategy for both teams that provides the ability to audit key usage. The solution must also minimize operational overhead.

What should the security team recommend?

A.

Tell the application teams to use two different S3 buckets with separate AWS Key Management Service (AWS KMS) AWS managed CMKs. Limit the key policies to allow encryption and decryption of the CMKs to their respective teams only. Force the teams to use encryption context to encrypt and decrypt.

B.

Tell the application teams to use two different S3 buckets with a single AWS Key Management Service (AWS KMS) AWS managed CMK. Limit the key policy to allow encryption and decryption of the CMK only. Do not allow the teams to use encryption context to encrypt and decrypt.

C.

Tell the application teams to use two different S3 buckets with separate AWS Key Management Service (AWS KMS) customer managed CMKs. Limit the key policies to allow encryption and decryption of the CMKs to their respective teams only. Force the teams to use encryption context to encrypt and decrypt.

D.

Tell the application teams to use two different S3 buckets with a single AWS Key Management Service (AWS KMS) customer managed CMK. Limit the key policy to allow encryption and decryption of the CMK only. Do not allow the teams to use encryption context to encrypt and decrypt.

Answer: B

Explanation:

QUESTION NO: 240

A security engineer is designing a solution that will provide end-to-end encryption between clients and Docker containers running in Amazon Elastic Container Service (Amazon ECS). This solution will also handle volatile traffic patterns.

Which solution would have the MOST scalability and LOWEST latency?

A.

Configure a Network Load Balancer to terminate the TLS traffic and then re-encrypt the traffic to the containers.

B.

Configure an Application Load Balancer to terminate the TLS traffic and then re-encrypt the traffic to the containers.

C.

Configure a Network Load Balancer with a TCP listener to pass through TLS traffic to the containers.

D.

Configure Amazon Route to use multivalue answer routing to send traffic to the containers.

Answer: B

Explanation:

QUESTION NO: 241

A company uses an AWS Key Management Service (AWS KMS) CMK to encrypt application data before it is stored. The company's security policy was recently modified to require encryption key rotation annually. A security engineer must ensure that annual global key rotation is enabled for the key without making changes to the application.

What should the security engineer do to accomplish this requirement?

A.

Create new AWS managed keys. Configure the key schedule for the annual rotation. Create an alias to point to the new keys.

B.

Enable automatic annual key rotation for the existing customer managed CMKs. Update the application encryption library to use a new key ID for all encryption operations. Fall back to the old key ID to decrypt data that was encrypted with previous versions of the key.

C.

Create new AWS managed CMKs. Configure the key schedule for annual rotation. Create an alias to point to the new CMKs.

D.

Enable automatic annual key rotation for the existing customer managed CMKs. Update the application encryption library to use a new key ID for all encryption operations. Create a key grant for the old CMKs and update the code to point to the ARN of the grants.

Answer: D

Reference:

<https://docs.aws.amazon.com/kms/latest/developerguide/rotate-keys.html>

QUESTION NO: 242

A company is collecting AWS CloudTrail log data from multiple AWS accounts by managing individual trails in each account and forwarding log data to a centralized Amazon S3 bucket residing in a log archive account. After CloudTrail introduced support for AWS Organizations trails, the company decided to further centralize management and automate deployment of the CloudTrail logging capability across all of its AWS accounts.

The company's security engineer created an AWS Organizations trail in the master account, enabled server-side encryption with AWS KMS managed keys (SSE-KMS) for the log files, and specified the same bucket as the storage location. However, the engineer noticed that logs recorded by the new trail were not delivered to the bucket.

Which factors could cause this issue? (Choose two.)

A.

The CMK key policy does not allow CloudTrail to make encrypt and decrypt API calls against the key.

B.

The CMK key policy does not allow CloudTrail to make GenerateDatakey API calls against the key.

C.

The IAM role used by the CloudTrail trail does not have permissions to make PutObject API calls against a folder created for the Organizations trail.

D.

The S3 bucket policy does not allow CloudTrail to make PutObject API calls against a folder created for the Organizations trail.

E.

The CMK key policy does not allow the IAM role used by the CloudTrail trail to use the key for cryptographic operations.

Answer: A,D

Explanation:

QUESTION NO: 243

A company's AWS CloudTrail logs are all centrally stored in an Amazon S3 bucket. The security team controls the company's AWS account. The security team must prevent unauthorized access and tampering of the CloudTrail logs.

Which combination of steps should the security team take? (Choose three.)

A.

Configure server-side encryption with AWS KMS managed encryption keys (SSE-KMS)

B.

Compress log file with secure gzip.

C.

Create an Amazon EventBridge (Amazon CloudWatch Events) rule to notify the security team of any modifications on CloudTrail log files.

D.

Implement least privilege access to the S3 bucket by configuring a bucket policy.

E.

Configure CloudTrail log file integrity validation.

F.

Configure Access Analyzer for S3.

Answer: B,C,E

Explanation:

QUESTION NO: 244

A company needs to migrate several applications to AWS. This will require storing more than 5,000 credentials. To meet compliance requirements, the company will use its existing password management system for key rotation, auditing, and integration with third-party secrets containers. The company has a limited budget and is seeking the most cost-effective solution that is still secure.

How should the company accomplish this at the LOWEST cost?

A.

Configure the company's key management solution to integrate with AWS Systems Manager Parameter Store.

B.

Configure the company's key management solution to integrate with AWS Secrets Manager.

C.

Use an Amazon S3 encrypted bucket to store the secrets and configure the applications with the appropriate roles to access the secrets.

D.

Configure the company's key management solution to integrate with AWS CloudHSM.

Answer: D

Explanation:

QUESTION NO: 245

A company has a web-based application using Amazon CloudFront and running on Amazon Elastic Container Service (Amazon ECS) behind an Application Load Balancer (ALB). The ALB is terminating TLS and balancing load across ECS service tasks. A security engineer needs to design a solution to ensure that application content is accessible only through CloudFront and that it is never accessible directly.

How should the security engineer build the MOST secure solution?

A.

Add an origin custom header. Set the viewer protocol policy to HTTP and HTTPS. Set the origin protocol policy to HTTPS only. Update the application to validate the CloudFront custom header.

B.

Add an origin custom header. Set the viewer protocol policy to HTTPS only. Set the origin protocol policy to match viewer. Update the application to validate the CloudFront custom header.

C.

Add an origin custom header. Set the viewer protocol policy to redirect HTTP to HTTPS. Set the origin protocol policy to HTTP only. Update the application to validate the CloudFront custom header.

D.

Add an origin custom header. Set the viewer protocol policy to redirect HTTP to HTTPS. Set the origin protocol policy to HTTPS only. Update the application to validate the CloudFront custom header.

Answer: C

Explanation:

QUESTION NO: 246

A large government organization is moving to the cloud and has specific encryption requirements. The first workload to move requires that a customer's data be immediately destroyed when the customer makes that request.

Management has asked the security team to provide a solution that will securely store the data, allow only authorized applications to perform encryption and decryption, and allow for immediate destruction of the data.

Which solution will meet these requirements?

A.

Use AWS Secrets Manager and an AWS SDK to create a unique secret for the customer-specific data.

B.

Use AWS Key Management Service (AWS KMS) and the AWS Encryption SDK to generate and store a data encryption key for each customer.

C.

Use AWS Key Management Service (AWS KMS) with service-managed keys to generate and

store customer-specific data encryption keys.

D.

Use AWS Key Management Service (AWS KMS) and create an AWS CloudHSM custom key store. Use CloudHSM to generate and store a new CMK for each customer.

Answer: A

Explanation:

QUESTION NO: 247

A security engineer is defining the controls required to protect the AWS account root user credentials in an AWS Organizations hierarchy. The controls should also limit the impact in case these credentials have been compromised.

Which combination of controls should the security engineer propose? (Choose three.)

A.

Apply the following SCP:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "GRRESTRICTROOTUSER",
      "Effect": "Deny",
      "Action": "*",
      "Resource": [
        "*"
      ],
      "Condition": {
        "StringLike": {
          "aws:PrincipalArn": [
            "arn:aws:iam::*:root"
          ]
        }
      }
    }
  ]
}
```

B.

Apply the following SCP:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "GRRESTRICTROOTUSER",
      "Effect": "Deny",
      "Principal": "arn:aws:iam::*:root",
      "Action": "*",
      "Resource": [
        "*"
      ]
    }
  ]
}
```

C.

Enable multi-factor authentication (MFA) for the root user.

D.

Set a strong randomized password and store it in a secure location.

E.

Create an access key ID and secret access key, and store them in a secure location.

F.

Apply the following permissions boundary to the root user:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "GRRESTRICTROOTUSER",
      "Effect": "Deny",
      "Action": "*",
      "Resource": [
        "*"
      ],
      "Condition": {
        "StringLike": {
          "aws:PrincipalArn": [
            "arn:aws:iam::*:root"
          ]
        }
      }
    }
  ]
}
```

Answer: A,D,F

Explanation:

QUESTION NO: 248

A VPC endpoint for Amazon CloudWatch Logs was recently added to a company's VPC. The company's system administrator has verified that private DNS is enabled and that the appropriate route tables and security groups have been updated. The role attached to the Amazon EC2 instance is:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "logs:CreateLogGroup",
        "logs:CreateLogStream",
        "logs:PutLogEvents",
        "logs:DescribeLogStreams"
      ],
      "Resource": [
        "arn:aws:logs:*:*:*"
      ]
    }
  ]
}
```

The CloudWatch Logs agent is running and attempting to write to a CloudWatch Logs stream in the same AWS account. However, no logs are being updated in CloudWatch Logs.

What is the likely cause of this issue?

A.

The EC2 instance role is not allowing the appropriate Put actions.

B.

The EC2 instance role policy is incorrect and should be changed to:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "logs:CreateLogGroup",
        "logs:CreateLogStream",
        "logs:PutLogEvents",
        "logs:DescribeLogStreams"
      ],
      "Resource": [
        "*"
      ]
    }
  ]
}
```

C.

The CloudWatch Logs endpoint policy is not allowing the appropriate Put actions.

D.

The CloudWatch Logs resource policy is not allowing the appropriate List actions.

Answer: C

Explanation:

QUESTION NO: 249

Amazon GuardDuty has detected communications to a known command and control endpoint from a company's Amazon EC2 instance. The instance was found to be running a vulnerable version of a common web framework. The company's security operations team wants to quickly identify other compute resources with the specific version of that framework installed.

Which approach should the team take to accomplish this task?

A.

Scan all the EC2 instances for noncompliance with AWS Config. Use Amazon Athena to query AWS CloudTrail logs for the framework installation.

B.

Scan all the EC2 instances with the Amazon Inspector Network Reachability rules package to identify instances running a web server with RecognizedPortWithListener findings.

C.

Scan all the EC2 instances with AWS Systems Manager to identify the vulnerable version of the web framework.

D.

Scan all the EC2 instances with AWS Resource Access Manager to identify the vulnerable version of the web framework.

Answer: B